

Network Security

ความปลอดภัยในเครือข่ายคอมพิวเตอร์



Type Of Network Threat

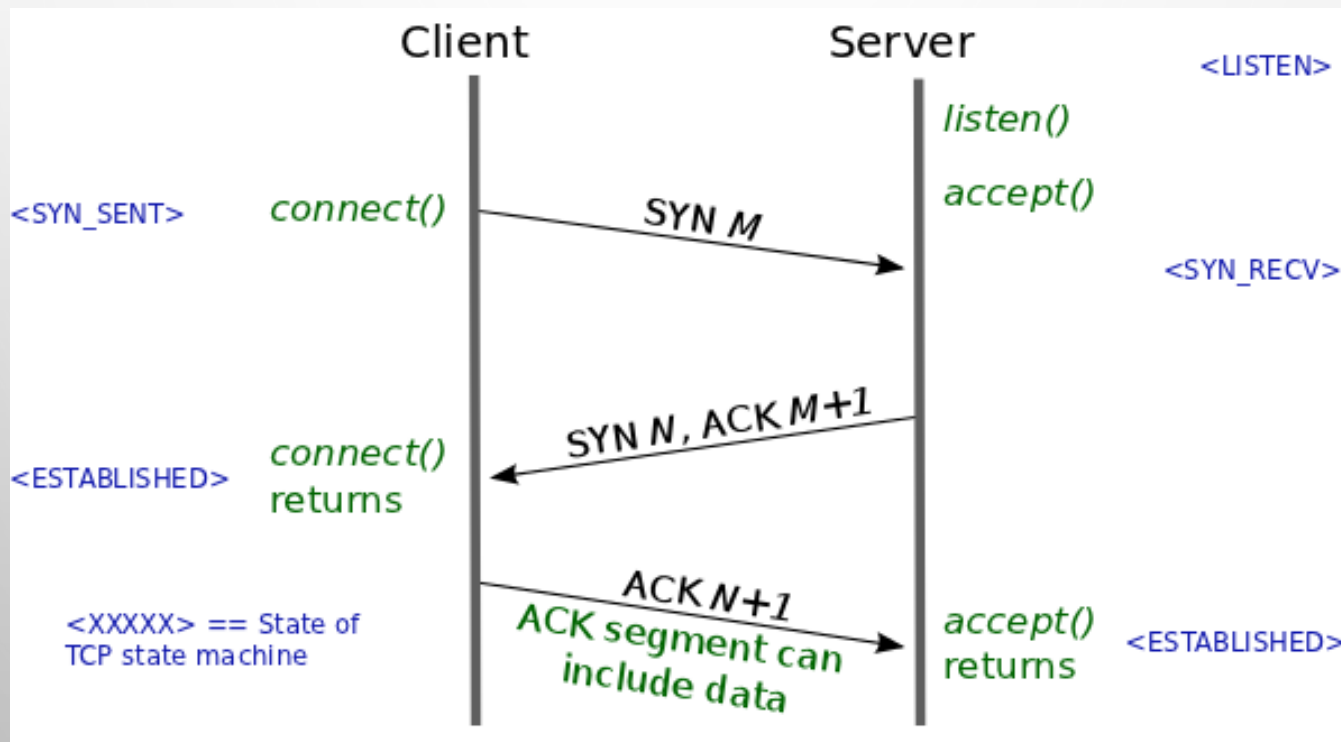
- การเข้าถึงโดยไม่ชอบ (Unauthorized Access)
- การปลอมตัว (Impersonation)
- การปฏิเสธการให้บริการ (Denial of Service or DoS)

Denial-of-service Attack : DoS

- DoS คือ การที่บุคคลใดบุคคลหนึ่งกระทำการต่อเครือข่ายหรือ Firewall ขององค์กรโดยการ
 - ทำให้ยุ่ง (Disrupting)
 - ทำให้ล่ม (Crashing)
 - ทำให้ติดขัด (Jamming)
 - ทำให้ท่วม (Flooding)
- เป็นการทำให้ User หรือผู้ใช้บริการที่แท้จริงไม่สามารถใช้งานระบบได้
- ประเภทหลักๆ ของ DoS
 - SYN flood (TCP SYN attack หรือ TCP SYN flooding, ICMP, UDP)
 - Smurf attack (Smurf IP DoS Attack)

SYN Flood

- เป็นการโจมตี protocol TCP ที่มีจุดอ่อนตรง TCP 3 ways Handshake (connection oriented)



SYN Flood (ต่อ)

Three way handshake:

Step 1: client host sends TCP SYN segment to server

- SYN=1, ACK=0
- specifies initial seq #
- no data

Step 2: server host receives SYN, replies with SYN-ACK segment

- SYN=1, ACK=1
- server host allocates buffers
- specifies server initial seq. #

Step 3: client receives SYN-ACK, replies with ACK segment, which may contain data

- SYN=0, ACK=1

SYN Flood (ต่อ)

- ทำการโจมตีโดยปลอม IP ที่แตกต่างกันแล้วเปิดการเชื่อมต่อ (SYN) ไปยังเครื่องเซิร์ฟเวอร์พร้อมกันเป็นจำนวนมาก ๆ ที่ฝั่ง Server เมื่อได้รับสัญญาณ SYN ก็จะส่ง SYN-ACK กลับไปยัง IP ปลอมเหล่านั้น เครื่องเซิร์ฟเวอร์ก็จะไม่ได้รับสัญญาณ ACK กลับมา เนื่องจาก IP เหล่านั้นอาจไม่มีอยู่จริง (หรือ IP นั้นไม่ได้ SYN ไปจริง จึงไม่ตอบ ACK กลับไป) ทำให้เซิร์ฟเวอร์อยู่ในสถานะรอ Hacker จะทำเช่นนี้เรื่อย ๆ จนช่องทางการให้บริการของเครื่อง Server เต็มก็จะทำให้ผู้ใช้ที่แท้จริงไม่สามารถใช้บริการได้

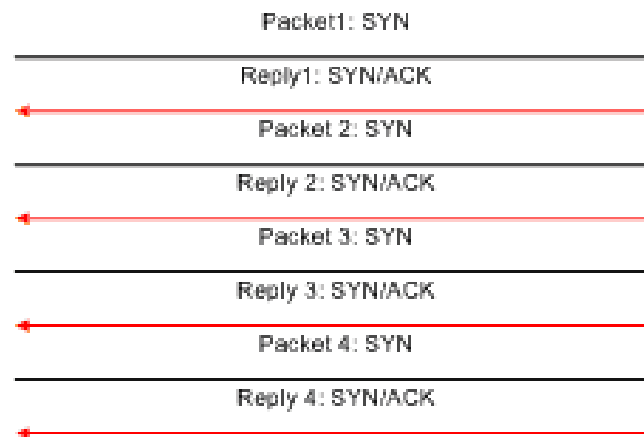
SYN Flood (ต่อ)

Pump As
Many SYN
Packets as
I can

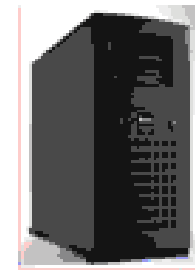


Attacker

Spoofed
SYN
Packets



I'm not getting
any response for
the SYN/ACK I
sent and now I'm
Choking



Server
(Victim)

Sorry dude too busy to talk to you

How come
I'm not
getting
replies from
server

Packet 1: SYN



User

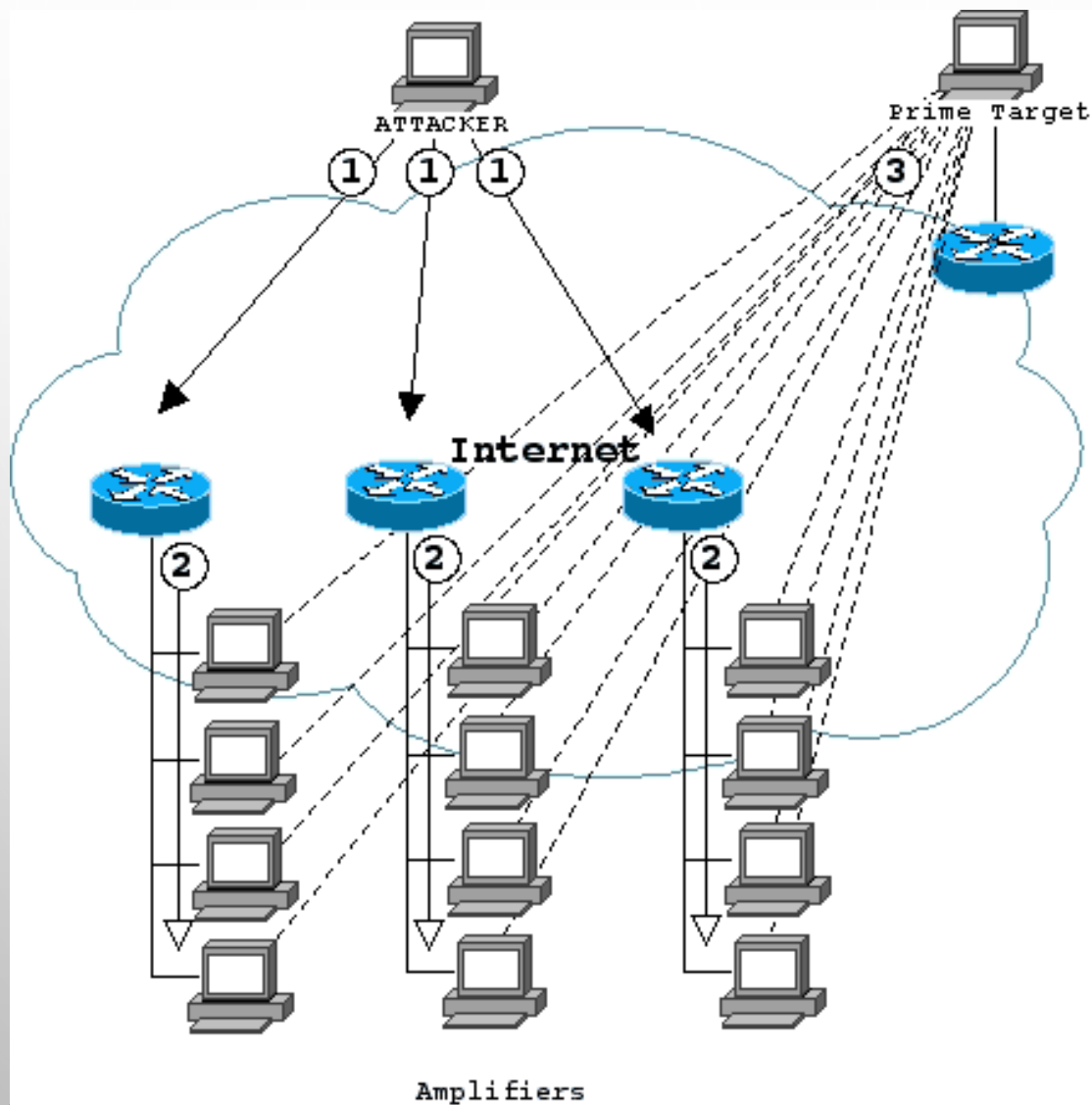
SYN Flood (ต่อ)

- การป้องกัน SYN Flood
 - เมื่อเครื่องเซิร์ฟเวอร์ SYN-ACK กลับไปแล้วไม่มีการ ACK ตอบกลับมาจาก Client
 - Server อาจใช้การ restart connection เพื่อรอ request ต่อไป

Smurf

- เป็นการโจมตีที่ Hacker ปลอมตัวเป็นเครื่อง Server (ปลอม IP Address เป็นเครื่อง Server) แล้ว Broadcast ออกไปยังเครื่องต่าง ๆ หลายเครื่อง เมื่อเครื่องจำนวนมากได้รับการ Broadcast ก็ จะ Reply กลับมายังเครื่อง Server จริงที่ Hacker ต้องการโจมตี ทำให้เครื่อง Server ได้รับ ICMP reply เป็นจำนวนมาก จนไม่สามารถให้บริการตามปกติได้ (การโจมตีแบบนี้สามารถโจมตีได้ทุก ๆ OS โดยใช้เครือข่ายในการโจมตี)

Smurf (ต่อ)



PoD (Ping of Death) : IP Fragmentation Attacks

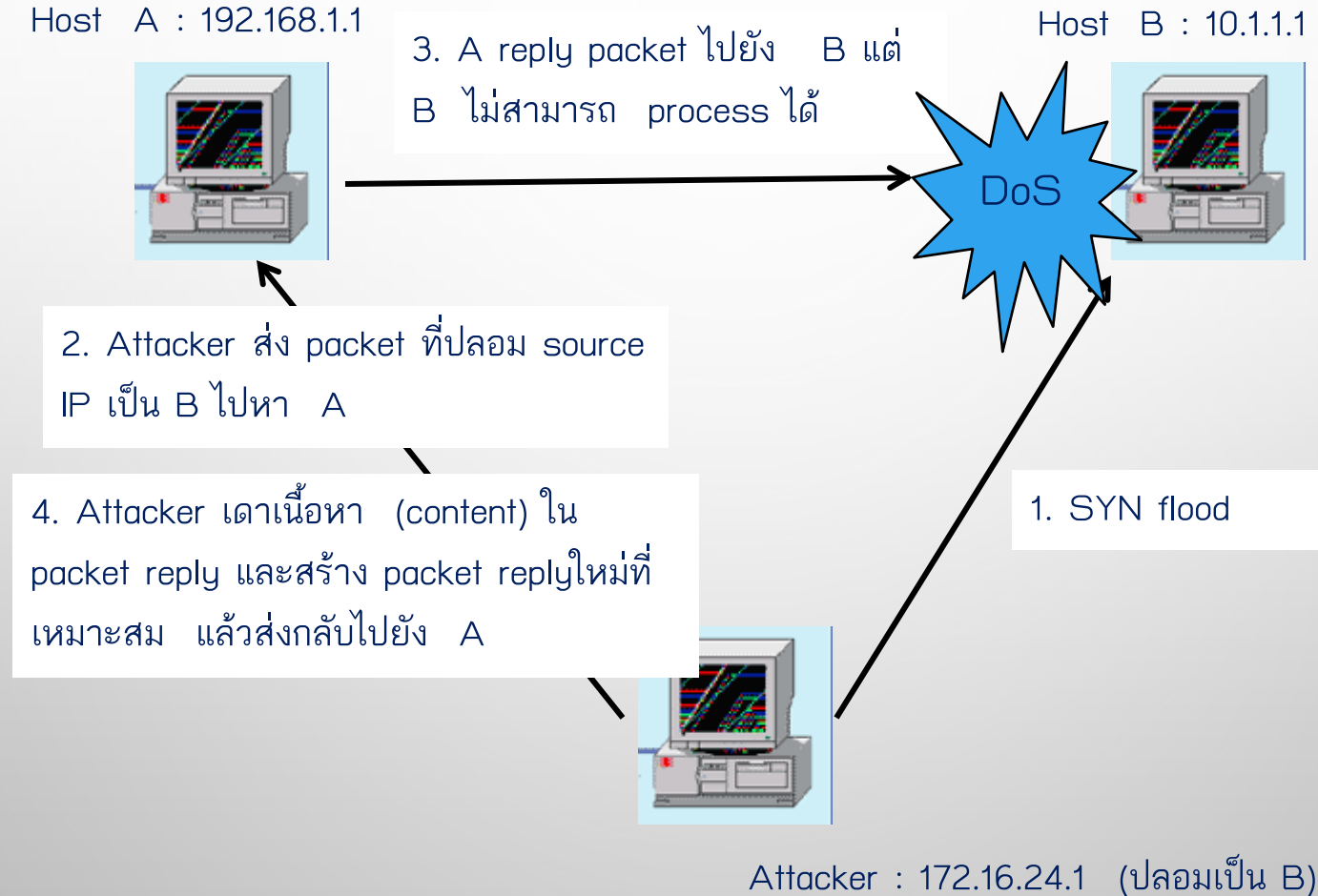
- PoD เป็นการใช้เทคนิค IP packet fragmentation ในการโจมตีระบบแบบทางไกลให้ล่มโดย Hacker จะส่ง packet ที่มีขนาดใหญ่กว่าปกติที่ OS ของเครื่องเป้าหมายจะสามารถรับได้ เช่น ขนาด packet ปกติเป็น 65535 ไบต์ แต่ถ้าเป็นการโจมตีแบบ PoD อาจจะส่ง packet ขนาดตั้งแต่ 100,000 ไบต์ ขึ้นไป ไปยังเครื่องเป้าหมาย เมื่อเครื่องเป้าหมายไม่สามารถรับ packet ขนาดใหญ่เป็นพิเศษ (oversized) ได้ ทำเช่นนี้เรื่อย ๆ เครื่องเป้าหมายก็จะหยุดให้บริการ และล่มในที่สุด

Spoofing

เป็นการหลอกลวง หรือการปลอม โดยสิ่งที่ปลอมมี 4 ประเภทดังนี้

1. IP Address Spoofing
2. ARP Poisoning
3. Web Spoofing
4. DNS Spoofing

IP Address Spoofing



IP Address Spoofing (ต่อ)

- การปลอม IP Address เป็นการโจมตี ความเชื่อถือว่าระหว่าง 2 host โดยการปลอมตัวเองเป็น IP Address ของฝั่งใดฝั่งหนึ่งแล้วทำการปลอม source IP Address ของ packet ส่งไปให้อีกฝั่ง (A) , เมื่อ A ได้รับ packet คิดว่า packet ที่ได้รับเป็น B จริง จึงส่ง reply packet ไปยัง B แต่ B ไม่สามารถ process ได้เพราะโดน Attacker SYN Flood อยู่ ดังนั้น Attacker จึงถือโอกาสเดา content ใน packet ที่ A ส่งไปยัง B (ตัวจริง) และสร้าง packet ที่คาดว่าเป็นคำตอบที่เหมาะสมกลับไปยัง A ทำให้ A เข้าใจผิดว่า host B เปลี่ยนช่องทางการติดต่อเดิมไปยังช่องทางใหม่ และเชื่อว่า Attacker เป็น host B จริง

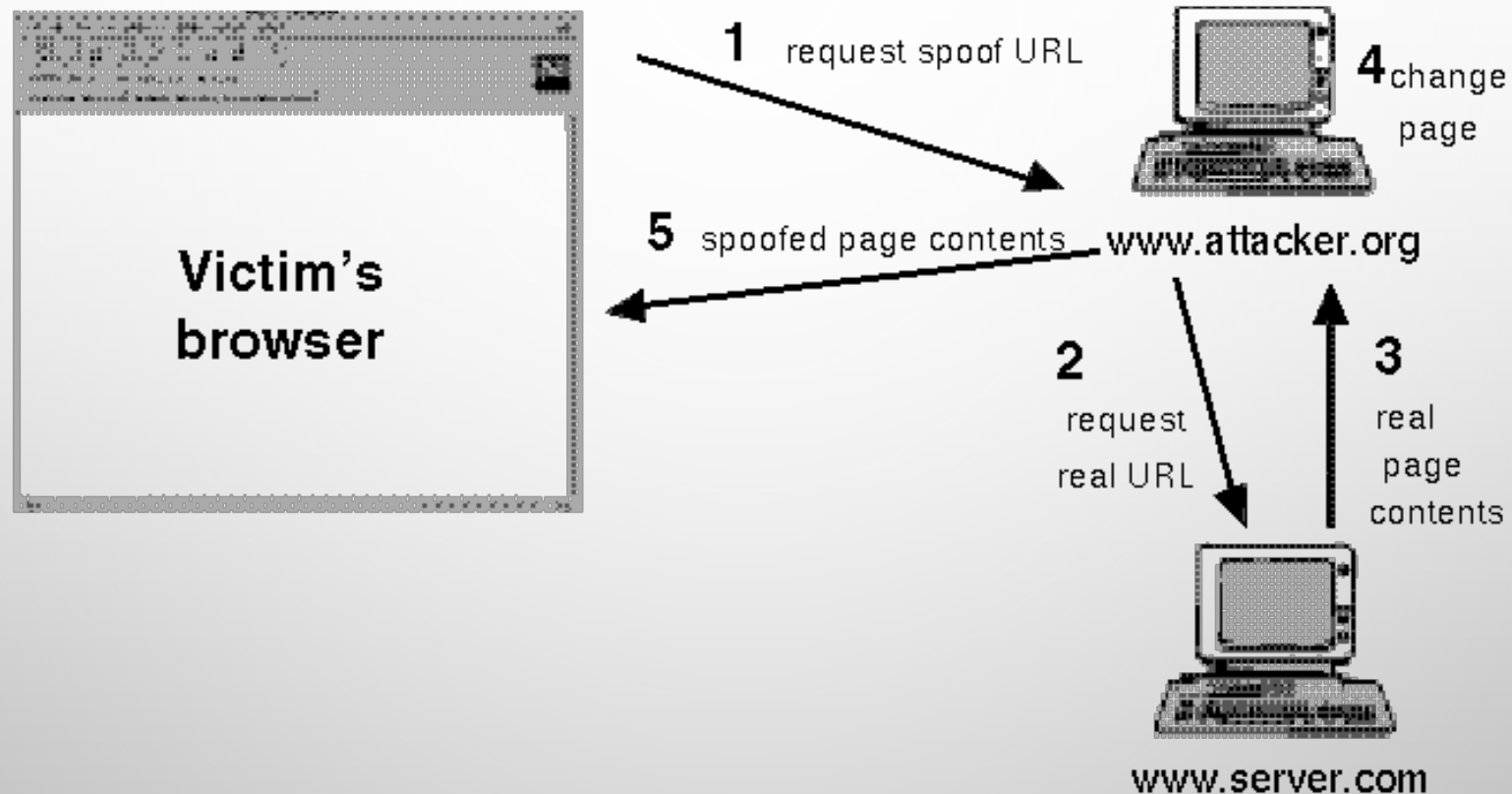
ARP Poisoning

- วิธีนี้เป็นการใช้คนกลาง (Man-in-the-Middle) ในการปลอมตัว โดยการทำงานของ ARP โดย Attacker จะยัด IP Address ของเครื่องคอมพิวเตอร์ที่ต้องการจะปลอมตัว แล้วแก้ไขให้การทำงานของ ARP ผิดพลาด โดยให้ ARP จี้ IP Address มายังเครื่อง MAC Address ของ Attacker เอง
- วิธีขัดขวาง – ให้ Network Switch ที่มี Feature ของ MAC binding

Web Spoofing

- เป็นการปลอมตัวให้เหยื่อเข้าใจผิดว่า web ที่ attacker สร้าง/จัดทำขึ้นมานั้น เป็น web site เป้าหมายที่เหยื่อต้องการเข้าถึงจริง ๆ
- การทำ web spoofing ใช้วิธีการ Main-in-the-Middle Attack และ DoS Attack
- วิธีขัดขวาง – ให้ความรู้แก่ user ในการตรวจสอบ web site ที่แท้จริงกับ web site ปลอมต่างกันอย่างไร

Web Spoofing (ต่อ)

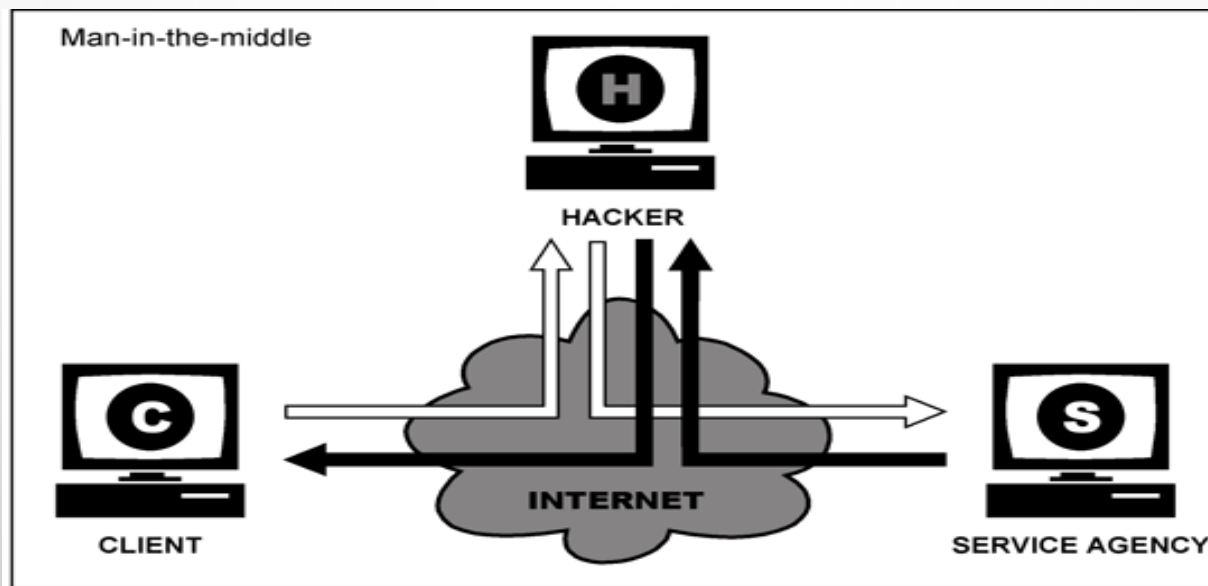


DNS Spoofing

- Attacker ปลอมตัวเป็น DNS Server เพื่อทำการแปลง URL ที่ user หรือเหยื่อ ร้องขอให้แปลงเป็นหมายเลข IP ที่ Attacker สร้างขึ้นมาแทน (ส่งไป IP Address ปลอม)
Attacker สามารถใช้วิธี DNS Spoofing นี้ redirect หรือ จัดการ email ต่าง ๆ ก่อนส่งไปยังปลายทางจริงที่ user ต้องการ
- วิธีขัดขวาง – ใช้การทำงาน DNS Server ที่มีความปลอดภัย, ออกแบบการใช้งานป้องกัน IP Address spoofing

Man-in-the-Middle Attack

- เป็นการโจมตีที่ Hacker อยู่ในตำแหน่งระหว่างกลางการติดต่อสื่อสารระหว่าง 2 โฮสต์ และสามารถดักฟัง/ดักจับข้อมูลในการติดต่อสื่อสารนั้น



- วิธีป้องกัน – config router ไม่ให้ทำการ redirect ICMP Packet

Replay Attack

- เป็นการลักลอบ ขโมย username, password และรอโอกาส user ตัวจริงออกจากระบบไป Attacker ก็จะ replay ปลอมตัวเป็น user เข้ามาในระบบ เป็นการโจมตีการพิสูจน์ตัวตนจริง โดยลักลอบ บันทึกข้อมูลการพิสูจน์ตัวตนจริงของ user และนำเอาข้อมูลการพิสูจน์ตัวตนจริงของ user ที่ได้มานั้นมา replay อีกครั้ง เพื่อปลอมตัวเป็น user เข้ามาในระบบ

IP Security หรือ IP Sec

- IP Sec ทำให้เกิดความลับ ความถูกต้อง พิสูจน์ได้ว่าเป็นตัวจริง
- IP Sec เป็นเฟรมเวิร์คมาตรฐานความปลอดภัย ของ IETF ซึ่งมีไว้สำหรับการทำ end-to-end encryption และ authentication บน public และ private networks
- แผนกไอที ขององค์กรสามารถนำเอา IP Sec มาประยุกต์ใช้ให้เหมาะสมกับ security policy ขององค์กรช่วยเพิ่มความมั่นใจในการรักษา ความลับ (C) ความถูกต้อง (I) และการพิสูจน์ตัวจริงผู้ส่ง (A) ของข้อมูล ที่ต้องการส่ง สื่อสาร ผ่านเครือข่าย internet, extranet, WANs หรือ LANs

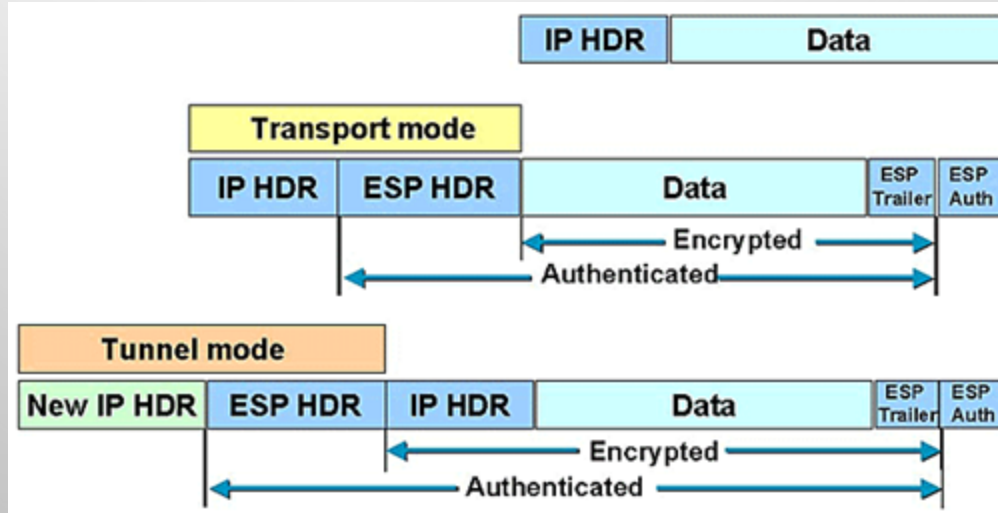
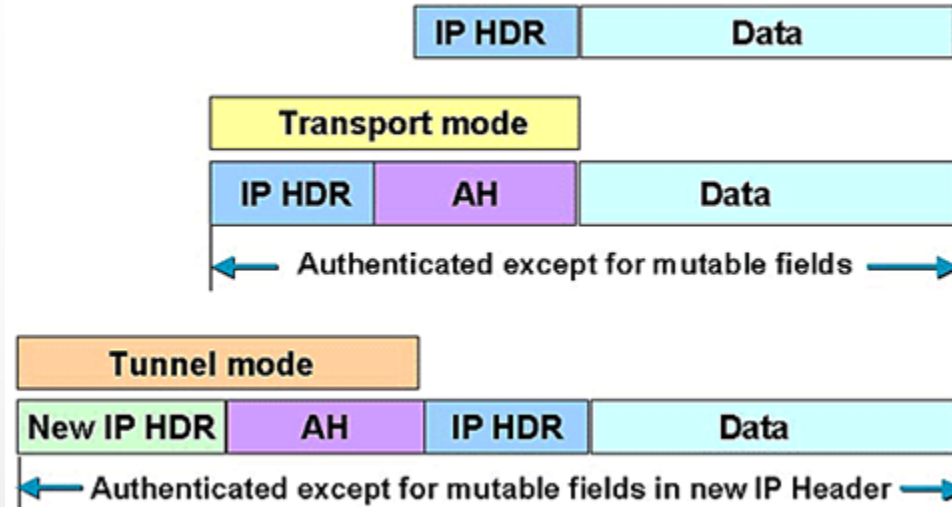
โปรโตคอลย่อยของ IP Sec

- **Authentication headers (Ahs)** ใส่ข้อมูลสำหรับการ Authentication ไว้ใน header เพื่อใช้ในการพิสูจน์ตัวผู้ส่งข้อมูล และความถูกต้องข้อมูล
- **Encapsulated security payloads (ESPs)** เก็บข้อมูลที่ใช้ในการ Authentication และการเข้ารหัสเพื่อใช้ในการพิสูจน์ตัวผู้ส่ง และเข้ารหัสข้อมูลเพื่อให้แน่ใจว่า ข้อมูลจะไม่ถูกดักจับ หรือไม่สามารถอ่านข้อมูลได้ หรือคัดลอก ข้อมูลไปได้

IP Sec Mode

- **Transport mode** นิยมใช้กับการสื่อสารแบบ peer-to-peer เพื่อใช้เป็น internet security data หรือ payload จะถูก encrypted แต่ไม่ encrypted IP header (ไม่มันจะส่งไปไม่ถูก)
- **Tunnel mode** มักใช้กับ remote access และ site-to-site รวมถึง VPN (Virtual Private Networks, ทำ public network ให้เป็น private network) mode นี้จะ encrypted ทั้ง packet (header+payload) แล้วแปะ header ใหม่ (ESP header)

IP Sec Mode (ต่อ)



Web Security

ความปลอดภัย บนเว็บ หมายความว่ารวมถึง

- ความปลอดภัยในระบบคอมพิวเตอร์ (Computer System)
- ความปลอดภัยในเครือข่าย (Network System)
- การบริการพิสูจน์ตัวจริง (Authentication Service)
- ความสมเหตุสมผลของข้อความ (Message Validation)
- ความเป็นส่วนตัว ของบุคคล (Personal Privacy Issue) – privacy คือความเป็นส่วนตัวอาจไม่มีความลับ
- การเข้ารหัสลับ

Web Security (ต่อ)

การตรวจสอบความปลอดภัยบนเว็บ อาจทำได้โดย

- สังเกตสัญลักษณ์ล็อคบนแถบที่อยู่ของ browser บ่งชี้ว่าเว็บไซต์กำลังใช้ HTTPS หมายถึงเป็นเว็บที่มีการเข้ารหัสลับ
- ตรวจสอบการเข้ารหัสเว็บเพจหรือ (สำหรับ browser อื่น ๆ) เลือก properties -> connection หากไม่มีการเข้ารหัสลับจะมีการแสดงคำว่า “Not Encrypted” หรือ “Cannot find Server”
- เลือกดูการรับรองความปลอดภัย ได้จากใบรับรอง (security certificate)

Standard for Web-based Security

- Secure Socket Layer (SSL)
- Secure Electronic Transaction (SET)

Digital Certificates

- **Digital Certificate** หรือ digital ID เป็น File Electronic ที่ทำหน้าที่เป็นหนังสือเดินทางออนไลน์ (Online Passport) ซึ่งจะถูกออกโดยบุคคลที่สามที่น่าเชื่อถือ (trusted third party) โดยเรียกว่าผู้ประกอบการใบรับรอง (Certificate Authority หรือ CA)
- **CA** จะทำหน้าที่ตรวจสอบ (verify) รูปพรรณ (identity) ของผู้ถือใบรับรอง
- Digital Certificate จะทนต่อการถูกรบกวน (tamper-proof) และไม่สามารถทำการปลอมได้, digital certificate จะเข้ารหัส transaction stream ระหว่างเครื่อง server และ browser ของ client โดยใช้เทคโนโลยีที่เรียกว่า SSL (Secure Sockets Layer)

Type of Digital Certificate

- Server Certificates
- Personal Certificate หรือ Client Certificate
- ใบรับรองดิจิทัล ทำหน้าที่ 2 อย่าง คือ
 - พิสูจน์ตัวจริงของผู้ถือใบรับรอง (บุคคล, website, router ฯลฯ)
 - ป้องกันการขโมย/การรบกวน ข้อมูลที่ถูกแลกเปลี่ยนกันแบบออนไลน์

Secure Sockets Layer (SSL)

- **SSL** ถูกออกแบบเพื่อให้บริการความปลอดภัยแก่ข้อมูลในระหว่างชั้น Protocol ระดับ Application Layer (เช่น HTTP, Telnet, FTP) และ Transport Layer
- Protocol SSL กำหนดให้มี
 - การเข้ารหัสลับข้อมูล (Data Encryption)
 - พิสูจน์ตัวตนจริงเครื่องที่ให้บริการ (Server Authentication/Integrity)
 - บำรุงรักษาของข้อความ (Message Integrity)
 - เลือกได้ว่าจะมีการพิสูจน์ตัวตนจริงเครื่อง Client (Client Authentication/Integrity) สำหรับการเชื่อมต่อ TCP/IP แต่ละครั้งหรือไม่

Secure Sockets Layer (SSL) (ต่อ)

- SSL เป็นมาตรฐานความปลอดภัยสำหรับ Web Browser และเครื่อง Server บนเครือข่ายอินเทอร์เน็ต หากมีการติดตั้ง Digital Certificate ก็จะสามารถเปิดใช้ความสามารถของ SSL ได้
- SSL กำหนดความยาวหรือความมั่นคงของกุญแจไว้ 2 ระดับคือ 40 (SSLv2) และ 128 (SSLv3) บิต
- สำหรับ Session Key ที่จะถูกสร้างขึ้นในการเข้ารหัสลับในแต่ละรายการหรือแต่ละครั้งในการรับส่งข้อมูล
- ใช้อัลกอริทึม RSA (ระบบกุญแจคู่) ในการพิสูจน์ตัวจริง (Authentication) เครื่อง Client และ Server และใช้เข้ารหัส (Encryption) กุญแจลับ (Session key) เพื่อแลกเปลี่ยนกุญแจ

SSL: Session Key Encryption

- ใช้ Public Key ในการแลกเปลี่ยน Session Key ระหว่าง Client และ Server
- ใช้ Session Key ในการเข้ารหัสข้อมูล ซึ่งจะสร้าง Session Key ขึ้นมาใช้ 1 Key ต่อ 1 ครั้ง
- Public Key จะถูกใช้เฉพาะในการ verify และ Encryption Session Key เท่านั้น

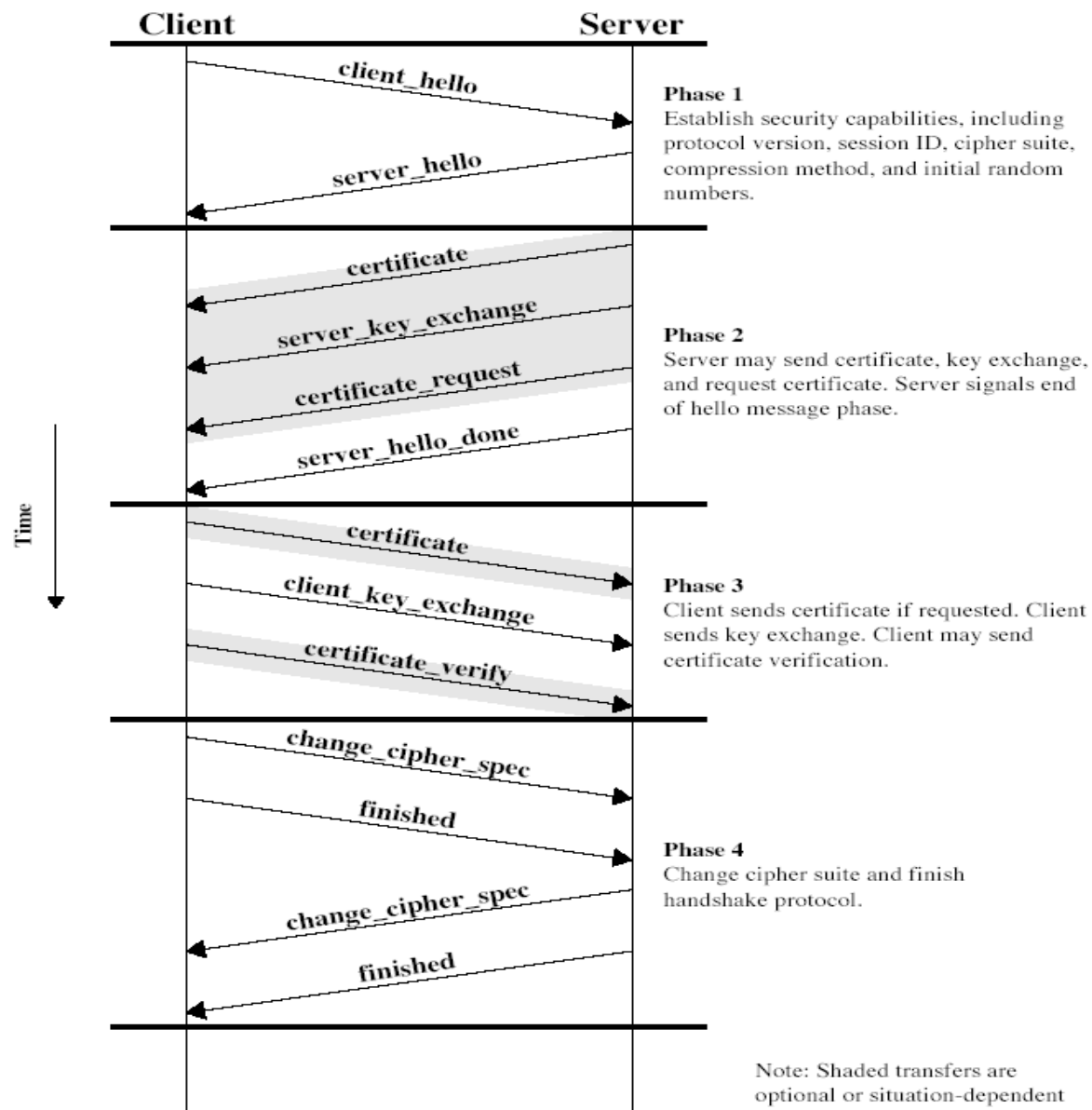
SSL: Information Encryption

- ข้อมูลที่จะต้องถูกเข้ารหัสนอกจาก HTTP request-reply แล้ว ยังรวมถึง
 - URL ที่ Client Request เพื่อไม่ให้ทราบว่า request web page ใด
 - Form ที่ใช้ในการกรอกข้อมูลต่าง ๆ
 - ข้อมูล HTTP Access Authorization ข้อมูลทั้งหมดทั้งจาก Server และจาก Client

SSL Process

- SSL ใช้การทำ handshake เพื่อสร้างความปลอดภัยในการสื่อสารแต่ละครั้ง โดยมีการทำงาน 4 phase หลักคือ
 - Phase 1: การเจรจาตกลงเกี่ยวกับอัลกอริทึมที่จะใช้
 - Phase 2: การแลกเปลี่ยนกุญแจและการพิสูจน์ทราบตัวจริงเซิร์ฟเวอร์
 - Phase 3: การแลกเปลี่ยนกุญแจและการพิสูจน์ทราบตัวจริงไคลเอนต์
 - Phase 4: การสิ้นสุดแฮนด์เชค

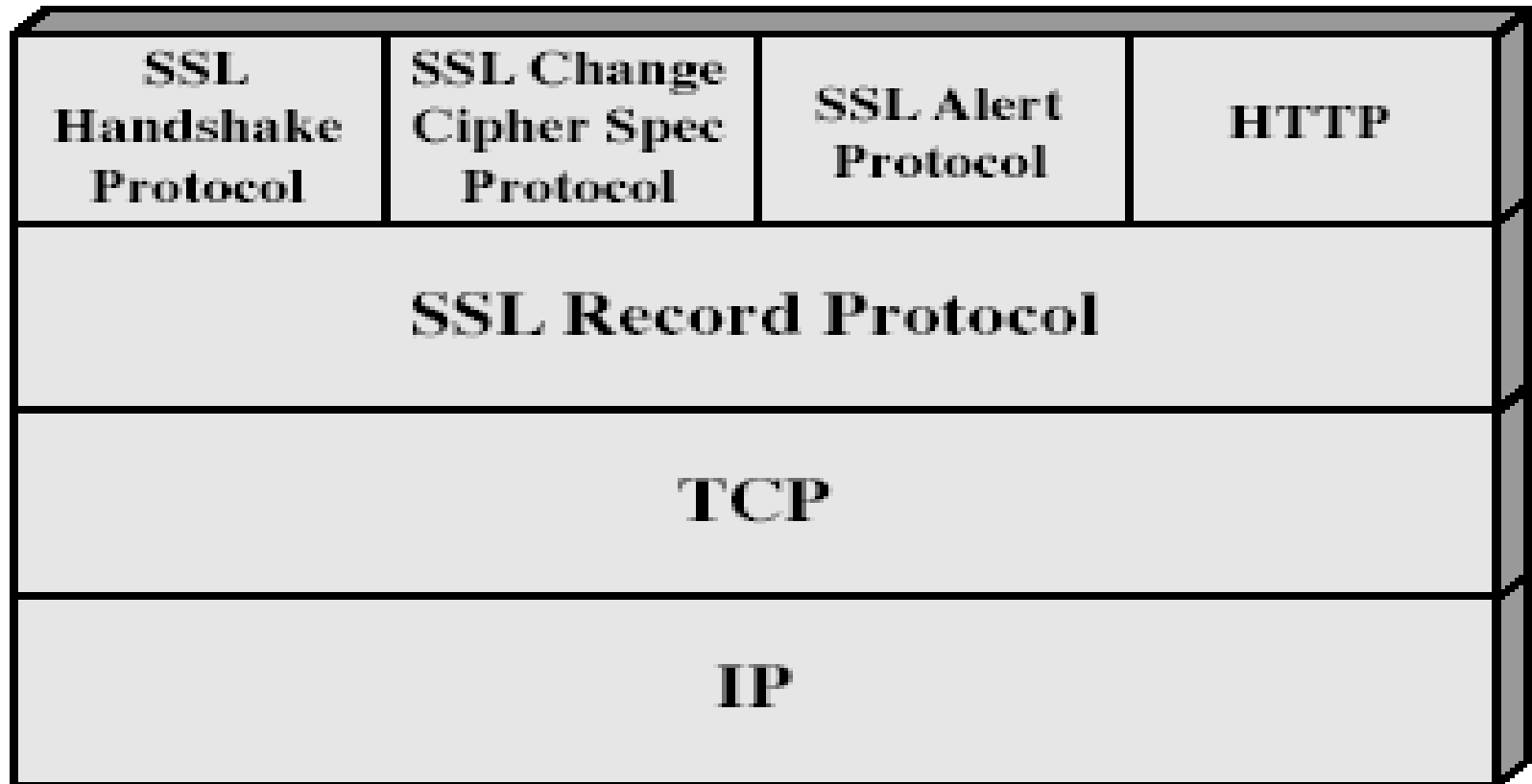
ขั้นตอนของ SSL Process



SSL (ต่อ)

- TLS (Transport Layer Security Protocol) พัฒนามาจาก SSL version 3 เป็นหลัก และมีความแตกต่างกับ SSL 3.0 น้อยมาก รายละเอียด ดูจาก RFC 2246 (เพิ่ม การแลกเปลี่ยนกุญแจแบบ Diffie-Hellman และลงลายมือชื่อแบบ DSS)
- PCT (Private Communication Technology) เป็นเทคโนโลยีของ Microsoft ซึ่งออกมาเป็นทางเลือกแทน SSL แต่เลิกใช้แล้ว
- WTLS (Wireless Transport Layer Security) เป็นการนำเอา TLS มาพัฒนาเพื่อใช้กับเครือข่ายแบบ wireless หรือ mobile network ใช้ในการ authenticate สำหรับ wireless transaction ทำให้การติดต่อสื่อสารถูกเข้ารหัสป้องกันภัยจาก Man-in-the-Middle Attack

SSL (ต่อ)



Protocol SSL และ S-HTTP, HTTPS

- S-HTTP (Secure Hyper Text Transfer Protocol) เป็นการขยายเพิ่มเติม Protocol HTTP ให้มีความปลอดภัย โดยเพิ่มฟังก์ชันการเข้ารหัสและถอดรหัสอยู่ภายใน HTTP โดยตรง ซึ่งทำให้มี security service คือ CIA และ non-repudiability
- HTTPS (HTTP over SSL) เป็นโปรโตคอลที่พัฒนาขึ้นมาแทน HTTP โดยปกติจะใช้พอร์ต 443 นิยมใช้กับอีคอมเมิร์ซหรือเว็บเพจหน้าล็อกอิน ซึ่งเป็นโปรโตคอลที่ถือว่าปลอดภัยสำหรับการสื่อสารผ่านเครือข่ายอินเทอร์เน็ต
 - เป็นโปรโตคอล HTTP ที่ใช้การเชื่อมต่อแบบ SSL หรือ TLS (ต้องใช้ใบรับรองดิจิทัล)

SET (Secure Electronic Transaction)

- ถูกออกแบบขึ้นมาเพื่อใช้เป็นเทคโนโลยีในการ Authenticate ของคู่ติดต่อสื่อสารที่มีการจ่ายเงินผ่านบัตรเครดิตซื้อขายแบบ Online ทุกชนิดรวมทั้ง Internet ด้วย
- ถูกพัฒนาขึ้นโดย VISA และ Master Card รวมไปถึงจนถึง Microsoft, IBM, Netcape, SAIC, RSA, Terisa, Systems และ VeriSign โดยมีจุดมุ่งหมายคือ เพื่อสร้างความปลอดภัยให้แก่
การทำธุรกรรม/ธุรกิจ ทำให้ลูกค้ามีความเชื่อถือในการซื้อขายแบบ E-Commerce

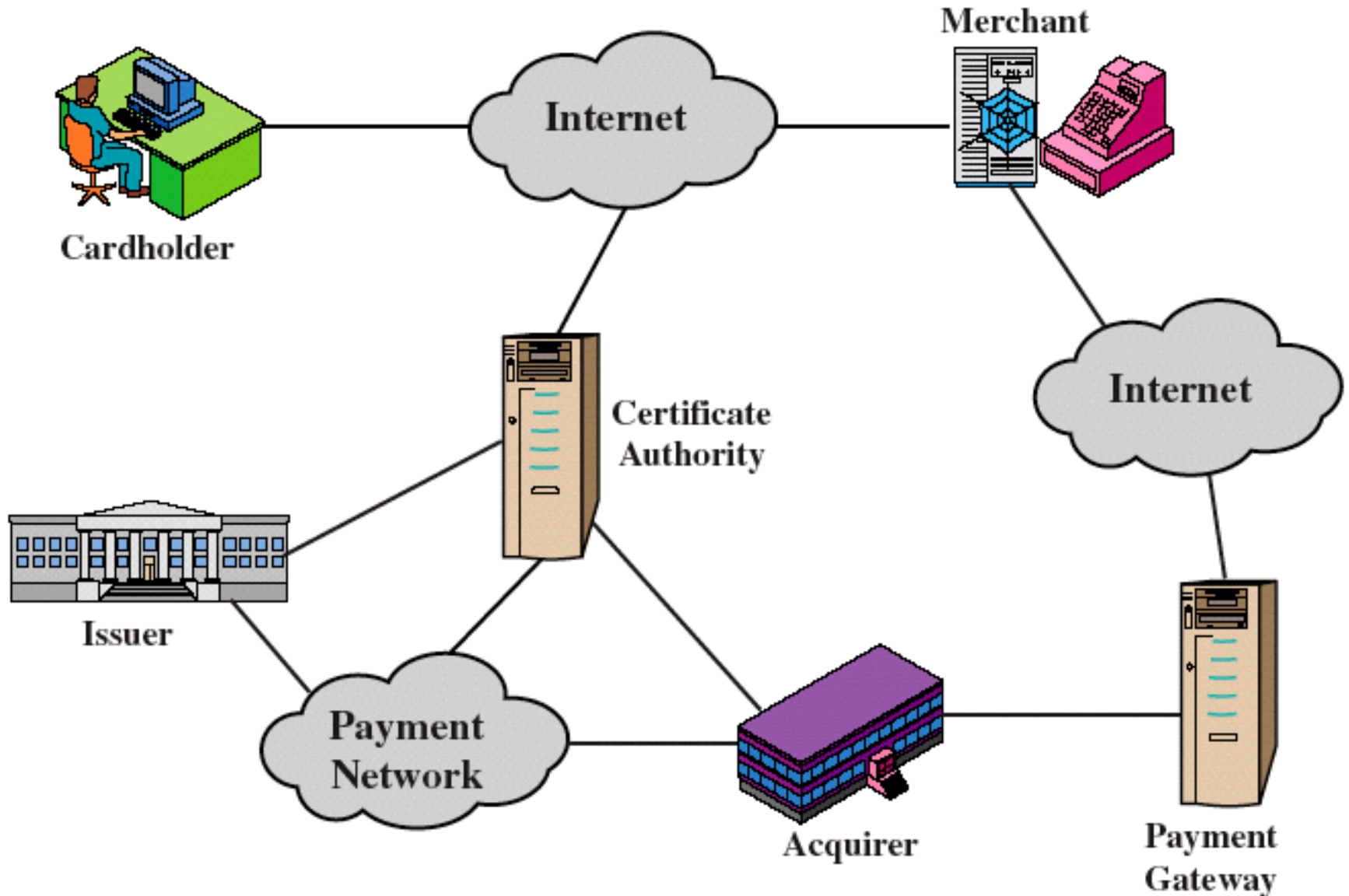
SET (ต่อ)

- การนำ SET มาใช้จะทำให้มีค่าใช้จ่ายที่สูงขึ้น แต่จะช่วยให้
 - ข้อมูลเป็นความลับ และเป็นส่วนตัว (Privacy)
 - เกิดบูรณภาพข้อมูล (Message Integrity)
 - พิสูจน์ตัวตน บุคคลที่เกี่ยวข้องกับ Transaction นั้น เช่น ผู้ถือบัตร, พ่อค้า

SET และ SSL ต่างกันอย่างไร

- SET ถูกออกแบบมาให้ใช้กับ E-Commerce โดยตรง และมีค่าใช้จ่ายสูงกว่า เนื่องจากมีความซับซ้อนกว่า
- SSL ไม่ได้ถูกออกแบบมาเพื่อ E-Commerce โดยตรง คือสามารถใช้กับข้อมูลอื่น ๆ ที่ต้องการให้เป็นความลับ

SET Component (SET Participant)



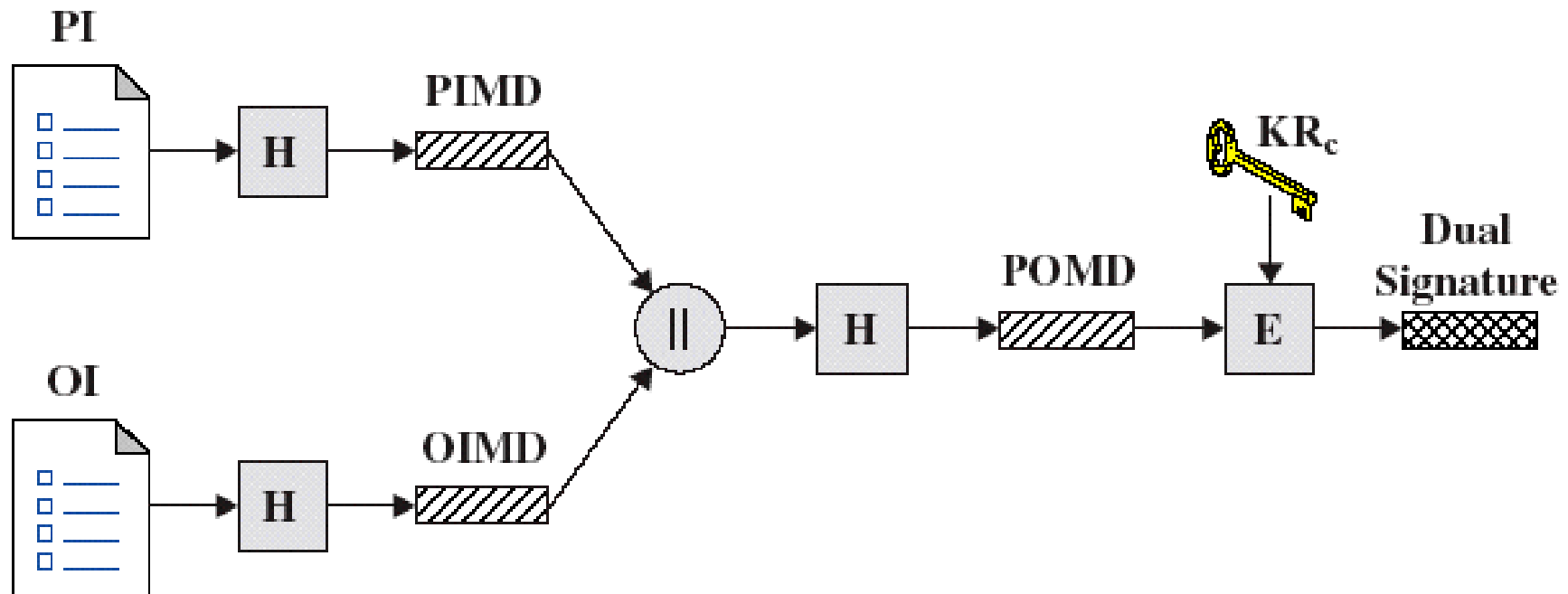
SET Component (ต่อ)

- ลูกค้าเปิดบัญชีบัตรเครดิต
- ลูกค้าได้รับ digital certificate
- พ่อค้ามีใบรับรอง certificate
- ลูกค้าสั่งซื้อ สินค้าและบริการ
- พ่อตรวจสอบ (verify) ใบรับรอง certificate
 - ข้อมูลการสั่งซื้อและการชำระเงิน ถูกส่งออกไป
 - พ่อค้าขออำนาจการส่งจ่าย
 - พ่อค้ายืนยันการสั่งซื้อ
 - พ่อค้าส่งสินค้าและบริการ
 - พ่อค้า **request** การชำระเงิน

Dual Signature

- Dual Signature ใช้เชื่อมโยงข้อความ 2 ข้อความที่จะส่งให้ผู้รับ 2 ฝ่ายคือ
 - ผู้ซื้อ ส่งข้อมูลการสั่งซื้อ (Order Information : OI) ให้แก่ผู้ขาย (Merchant)
 - ส่งข้อมูลชำระเงิน (Payment Information : PI) ให้แก่ธนาคาร โดยที่
 - ผู้ขายไม่จำเป็นต้องรู้เลขที่บัตรเครดิตของลูกค้า (ไม่ต้องรู้ PI)
 - ธนาคารไม่จำเป็นต้องรู้ รายละเอียดการสั่งซื้อของลูกค้า (ไม่ต้องรู้ OI)
- ทั้ง OI และ PI ถูกเก็บแยกออกจากกัน แต่ต้องเชื่อมโยงกัน เพื่อให้ ผู้ซื้อสามารถพิสูจน์ได้ว่าการส่งจ่ายในแต่ละครั้งของตน ส่งจ่ายซื้อสินค้าหรือบริการใด (หากจำเป็นต้องพิสูจน์)

การสร้าง Dual Signature



PI = Payment Information
OI = Order Information
H = Hash function (SHA-1)
|| = Concatenation

PIMD = PI message digest
OIMD = OI message digest
POMD = Payment Order message digest
E = Encryption (RSA)
KR_c = Customer's private signature key

Figure 7.9 Construction of Dual Signature

การสร้าง Dual Signature

- ผู้ที่เกี่ยวข้องมี 3 ฝ่าย คือ
 - ผู้ซื้อ (customer)
 - พ่อค้าหรือผู้ขาย (merchant) -> M
 - ธนาคาร (bank) -> B
- โดยที่
 - OI = ข้อมูลการสั่งซื้อ (พ่อค้าจะได้ OI และเห็นตัวแทน PI)
 - PI = ข้อมูลการส่งจ่าย (ธนาคารจะได้ PI และเห็นตัวแทน OI)
 - DS = dual signature

การสร้าง Dual Signature (ต่อ)

Dual signature อนุญาตให้พิสูจน์ดังนี้:

1. พ่อค้าได้รับข้อมูลสั่งซื้อ (Order Information)
2. ธนาคารได้รับข้อมูลส่งชำระเงิน (Payment Information) และตรวจสอบลายมือชื่อลูกค้า
3. ลูกค้ามีส่วนเชื่อมโยง OI และ PI และสามารถพิสูจน์ได้ในภายหลังว่า PI ไม่เกี่ยวข้องกับรายการซื้ออื่น

Secure Shell (SSH)

- Secure shell ช่วยในการพิสูจน์ตัวตนผู้ส่ง (Authentication) (เรียกว่า Strong Authentication) อาจเป็นโปรแกรมหรือโปรโตคอล ที่ใช้ในการ Login เข้าไปยังเครื่องคอมพิวเตอร์ผ่านทางเน็ตเวิร์ค, Execute Commands แบบ Remote Access, move files จากเครื่องหนึ่งไปยังอีกเครื่องหนึ่ง ได้อย่างปลอดภัย (บนช่องทางที่อาจจะไม่ปลอดภัย)
- ออกแบบสำหรับใช้รีโมทในระบบ Unix และ Linux โดยใช้พอร์ต 22
- Secure Shell มี 2 versions คือ
 - SSH1 และ
 - SSH2 มีการเปลี่ยนแปลงในส่วนของ FTP เป็น SFTP ช่วย Upload File ที่มีความลับได้อย่างปลอดภัย

Protection Provided by Secure Shell

- IP Spoofing
- IP Source routing
- DNS Spoofing
- การดักจับ (ขโมย) Password ที่ไม่มีการ Encrypt และข้อมูลอื่น ๆ ของ Host ที่อยู่ระหว่างทาง

Electronic Mail Security

- ความปลอดภัยในการใช้ e-mail นอกจากป้องกัน mail จากไวรัส ยังต้องดูแลความปลอดภัยในด้านอื่น ๆ ด้วย เช่น
 - Spam (junk mail) : Unsolicited Bulk E-mail (UBE)
 - Information leaks
 - Impersonation
 - Interception
 - Mail bombing
 - Offensive contents
 - Delivery failure

E-mail Security Controls

- Security policy
- Security software
- Eliminating spam
- Preventing information leaks
- Encryption
- Content control
- Combating viruses
- Reporting & archiving

E-mail Security Approaches

- Pretty Good Privacy (PGP) เป็น de-facto standard ในการเข้ารหัสอีเมล ที่ใช้กันอย่างแพร่หลาย ไม่ขึ้นกับองค์กรใด ๆ เหมาะกับการใช้งานส่วนตัวหรือระดับองค์กร
- Secure/MIME หรือ S/MIME (secure / multipurpose Internet mail extensions) เป็นมาตรฐาน internet protocol ที่ให้บริการเข้ารหัสลับและลายมือชื่อดิจิทัล กับข้อความ mail บนเครือข่ายอินเทอร์เน็ต

PGP (Pretty Good Privacy)

- PGP ใช้การเข้ารหัสแบบ public key ในการป้องกัน e-mail และ file ข้อมูล ทำให้สามารถติดต่อกับบุคคลอื่นได้อย่างปลอดภัย โดยไม่ต้องใช้ช่องทางที่ปลอดภัยในการแลกเปลี่ยนกุญแจ
- PGP สามารถทำงานได้เร็ว มีการจัดการกุญแจที่ซับซ้อน, digital signature, การบีบอัดข้อมูล และมีการออกแบบการใช้งานง่าย สามารถพิสูจน์ตัวจริงของ e-mail ได้

Summary of PGP Service

Function	Algorithm Used
Digital Signature	DSS/SHA or RSA/SHA
Message Encryption	CAST or IDEA or three-key triple DES with Diffie-Hellman or RSA
Compression	ZIP
E-mail Compatibility	Radix-64 conversion
Segmentation	-

Digital Signature & Message Encryption

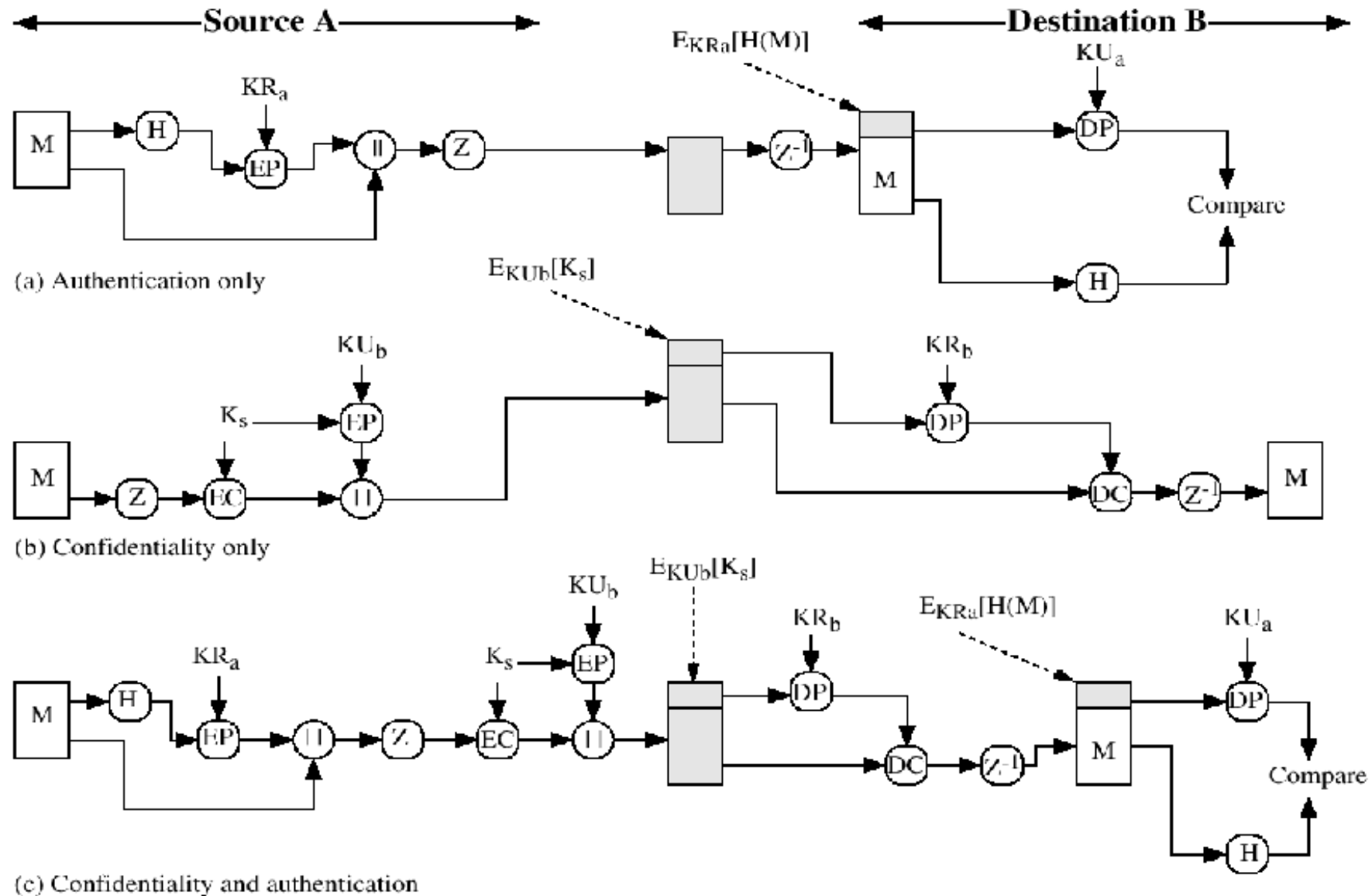


Figure 5.1 PGP Cryptographic Functions

Notation for Figure 5.1

- K_s session key used in symmetric encryption scheme
- KR_a = private key of user A
- KU_a = public key of user A
- EP = Encryption Public Key
- DP = Decryption Public Key
- EC = Symmetric Encryption
- DC = Symmetric Decryption
- H hash function, || concatenation
- Z compression using ZIP
- R64 = conversion to radix 64 ASCII format

Authentication using Digital Signature (a)

- Sender
 - นำข้อความที่ส่งมาหาค่า hash (ด้วยอัลกอริทึม SHA-1)
 - นำค่า hash มาเข้ารหัส ด้วยกุญแจส่วนตัวของผู้ส่ง (A) (SHA)
 - นำค่า hash ที่เข้ารหัสแล้ว มารวมกับข้อความที่จะส่ง และ zip แล้วส่งออกไป
- Receiver
 - ทำการ unzip แล้วนำค่า hash ที่เข้ารหัสไปถอดรหัสโดยใช้ public key ของผู้ส่ง (A)
 - นำข้อมูลที่ได้จากการ unzip มาหาค่า hash นำไปเปรียบเทียบกับผลลัพธ์ใน ขั้นที่ แล้ว
 - ถ้าผลลัพธ์ตรงกันหมายความว่า ข้อความที่ได้รับมาจากผู้ส่งจริงและไม่ถูกแก้ไข

Compression of PGP

- PGP บีบอัดข้อความหลังการลงลายมือชื่อ และก่อนเข้ารหัส ทำให้ไฟล์มีขนาดเล็กลงสำหรับการส่งอีเมล
- การลงลายมือชื่อก่อนการบีบอัด ทำให้
 - สามารถเก็บข้อความที่ยังไม่ได้บีบอัด และลายมือชื่อ สำหรับใช้ในการตรวจสอบในอนาคต
 - ช่วยให้ อัลกอริทึมที่ใช้ในการบีบอัดต่างๆ ทำงานร่วมกันได้
- การเข้ารหัสลับ ข้อความหลังการบีบอัด ช่วยให้ความปลอดภัยในการเข้ารหัสเพิ่มขึ้น เนื่องจากข้อความที่บีบอัดแล้วมีความซ้ำซ้อนน้อยกว่าต้นฉบับเดิมที่เป็นข้อความธรรมดา

E-mail Compatibility

- สมมติให้ Email message : new
- ASCII format: 01101110 01100101 01110111
- After encryption: 10010001 10011010 10001000
- เกิดปัญหาหลังจากเข้ารหัสคือ
 - รหัสไบนารีที่เข้ารหัสแล้วไม่ตรงกับรหัส ASCII
 - ในขณะที่ระบบอีเมลส่วนใหญ่ ยอมให้ใช้ข้อมูลที่ประกอบด้วยข้อความ ASCII ขนาด 8 bits เท่านั้น ทำให้ไม่สามารถส่งและประมวลผลได้

E-mail Compatibility (ต่อ)

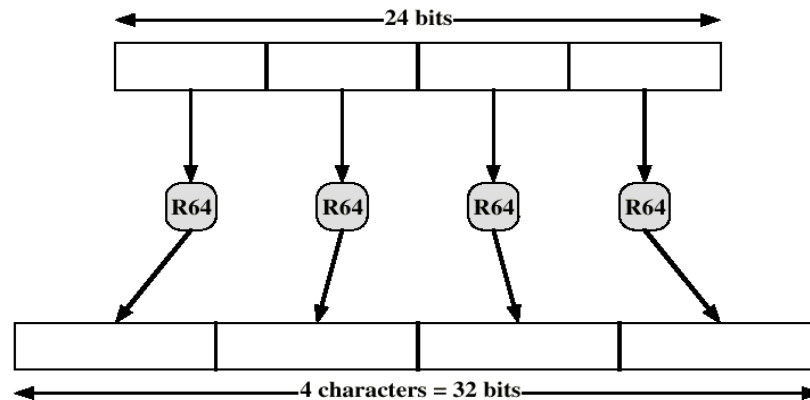


Figure 5.11 Printable Encoding of Binary Data into Radix-64 Format

- PGP แปลงข้อมูล (ใช้ได้ทุกภาษา) ออกเป็น block แต่ละ block แบ่งออกเป็น 4 ชุด มีขนาด 6 bits แล้วใช้ Radix-64 ทำการแปลงกระแสนข้อมูลขนาด 8 bits ซึ่งเป็นกระแสนข้อมูลอักขระ ASCII ที่สามารถพิมพ์ได้และผนวก CRC เพื่อตรวจหาความผิดพลาดจากการส่ง
- คนที่มี Private Key เท่านั้นจึงจะอ่านได้

PGP : Segmentation & Reassembly

- PGP จะแบ่งข้อมูลที่มีขนาดใหญ่เกินไป (อัตโนมัติ) ให้เป็นส่วน ๆ (Segment) ที่มีขนาดเล็ก ๆ พอที่จะส่งอีเมลได้
- การแบ่งเป็นส่วน ๆ นี้จะเป็นกระบวนการสุดท้าย หลังการแปลงข้อมูลแล้ว
- สำหรับ Session Key และ Digital Signature จะอยู่เฉพาะส่วนหัวของ Segment แรกเท่านั้น
- PGP ปลายทางด้านผู้รับ ต้องเอาส่วนหัวทิ้งไปก่อน และนำ block ต้นฉบับทั้งหมดมารวมกันใหม่ก่อนทำขั้นตอนอื่นต่อไป

X.509 Digital Certificate

- X.509 เป็น format ของใบรับรอง ที่เป็นมาตรฐานที่ได้รับการยอมรับ
- ใน PGP สามารถขอใบรับรองที่มีมาตรฐานใส่เข้าไปใน key pair ได้
- PGP ที่ได้รับการรับรองจาก CA ทำให้เชื่อมั่นได้ว่าเป็น public key ของจริง โดยขั้นตอนการขอใบรับรอง จะมีการส่ง e-mail ไปยัง e-mail ของเราเพื่อ activate หรืออาจใช้มือถือในการ activate

X.509 Digital Certificate (ต่อ)

- Each certificate contains:
 - Version (of the certificate format)
 - Serial number (unique within CA)
 - Signature algorithm identifier (to sign certificate)
 - Issuer (CA)
 - Validity period (from – to dates)
 - Subject (name of owner)
 - Public-key (algorithm, parameters, key)
 - Signature (of hash of all fields in certificate)

S/MIME

- Secure/Multipurpose Internet Mail Extension : เป็นมาตรฐานรับส่งข้อมูล MIME ให้มีความปลอดภัย โดยใช้ วิทยาการเข้ารหัสลับดังนี้
 - การพิสูจน์ตัวตนจริง (Authentication)
 - บุรณภาพของข้อความ (Message integrity)
 - การห้ามปฏิเสธความรับผิดชอบต่อต้นฉบับ (non-repudiation of original) โดยใช้ digital signature
 - ความเป็นส่วนตัว (privacy) และความปลอดภัยของข้อมูล โดยการเข้ารหัสลับ

S/MIME Functionality

- **Enveloped data (ข้อมูลปิดผนึก)** : ข้อมูลทั้งหมดจะถูกเข้ารหัส ประกอบด้วย ข้อมูลที่ถูกเข้ารหัส และกุญแจที่เข้ารหัส ซึ่งกระบวนการเข้ารหัส มีขั้นตอนดังนี้
 - ใช้ Session key เข้ารหัสข้อความ
 - ใช้ KU ของผู้รับเข้ารหัสด้วยอัลกอริทึม RSA เพื่อเข้ารหัส Session Key ที่จะใช้กับผู้รับ
 - นำข้อมูลทั้งหมดเข้ารหัส base64 และส่งไปยังผู้รับ
 - ผู้รับถอดรหัส base64
 - ผู้รับใช้ KR แต่ละคนทำการถอดรหัส Session key
 - ผู้รับใช้ Session key ถอดรหัสข้อความ

S/MIME Functionality (ต่อ)

- Sign data (พิสูจน์ตัวจริง) : ข้อมูลถูกรับรอง โดยลงลายมือชื่อดิจิทัล ลงบนค่า Hash (sign ค่า hash โดยใช้ private key ของผู้ส่ง) เนื้อหาและตัว signature จะถูกเข้ารหัสโดย base64 ในการเข้ารหัส
- การ sign แบบนี้ผู้รับที่ไม่มี S/MIME compatibility ไม่สามารถเปิดดูได้

S/MIME Functionality (ต่อ)

- **Clear - Sign data (ข้อมูลถูกรับรองกระจ่าง)**: จะเข้ารหัส bases64 เฉพาะส่วนลายมือชื่อ เนื้อหาไม่เข้ารหัสทำให้เครื่องรับปลายทางที่ไม่ได้ใช้ S/MIME สามารถเปิดดูได้ แต่ไม่สามารถพิสูจน์ลายมือชื่อได้
- **Signed and Enveloped data (ข้อมูลรับรองและปิดผนึก)**: ทำการ sign ก่อนแล้วค่อย encrypt (หรือ encrypt ก่อนแล้วจึงค่อย signed ก็ได้) ทั้งข้อความที่ถูกเข้ารหัสและลายเซ็นดิจิทัลจะถูกเข้ารหัสอีกชั้นหนึ่ง



End.



Wireless LAN Security

(ความปลอดภัยเครือข่ายไร้สาย)

วัตถุประสงค์

- เพื่อให้มีความรู้และเข้าใจมาตรฐาน Wireless LAN
- เพื่อให้มีความรู้และเข้าใจการพิสูจน์ทราบตัวตนของ Wireless LAN
- เพื่อให้มีความรู้และเข้าใจมาตรฐาน IEEE 802.11i และ IEEE 802.1X
- เพื่อให้มีความรู้และเข้าใจการเข้ารหัสข้อมูลแบบ WEP, WPA, WPA2
- เพื่อให้รู้และเข้าใจเครื่องมือต่าง ๆ ที่ใช้กับ Wireless LAN

Wireless LAN Standard

- **IEEE** ประกาศมาตรฐาน 802.11 WLAN หรือเรียกว่า Wi-Fi ในปี 1997 (ความเร็ว 1 Mbps & 2 Mbps)
- ปัญหาอุปกรณ์ทำงานรวมกันไม่ได้ **IEEE** จึงตั้งทีมงานขึ้นมา 2 กลุ่ม:
 - **TGa (Task Group a):** พัฒนามาตรฐาน IEEE 802.11a ใช้ความถี่ 5GHz มีความเร็ว 54Mbps
 - **TGb (Task Group b):** พัฒนามาตรฐาน IEEE 802.11b ใช้ความถี่ 2.4GHz มีความเร็ว 11Mbps
- **TGg (Task Group g)** พัฒนามาตรฐาน IEEE 802.11g ใช้ความถี่ 2.4GHz มีความเร็ว 54Mbps

Wireless LAN Standard (ต่อ)

- ต่อมาปี 2009 ได้ตั้ง TGn (Task Group n) เพื่อพัฒนามาตรฐาน IEEE 802.11n ใช้ความถี่ 2.4GHz และ 5GHz มีความเร็วสูงสุด 150Mbps
- ปี 2013 ได้ประกาศมาตรฐาน IEEE 802.11ac ใช้ความถี่ 2.4GHz และ 5GHz มีความเร็วสูงสุด 880Mbps/7Gbps
- ปี 2012 มีการประกาศมาตรฐาน IEEE 802.11ad ใช้ความถี่ 60GHz มีความเร็วสูงสุด 7Gbps เรียกว่า **WiGig**

Wireless LAN Standard (ต่อ)

Wi-Fi generations

V·T·E

Generation	IEEE standard	Adopted	Maximum link rate (Mb/s)	Radio frequency (GHz)
Wi-Fi 8	802.11bn	expected 2028 ^[1]	800 000 ^[2]	2.4, 5, 6 ^[3]
Wi-Fi 7	802.11be	expected 2024	0.4–23 059	2.4, 5, 6 ^[4]
Wi-Fi 6E	802.11ax	2021	0.4–9608 ^[5]	2.4, 5, 6 ^[a]
Wi-Fi 6				2.4, 5
Wi-Fi 5	802.11ac	2013	6.5–6933	5 ^[b]
Wi-Fi 4	802.11n	2009	6.5–600	2.4, 5
(Wi-Fi 3*)	802.11g	2003	6–54	2.4
(Wi-Fi 2*)	802.11a	1999		5
(Wi-Fi 1*)	802.11b	1999	1–11	2.4
(Wi-Fi 0*)	802.11	1997	1–2	2.4

**Wi-Fi 0*, *1*, *2*, and *3* are named by retroactive inference. They do not exist in the official nomenclature.^{[6][7][8]}

- https://en.wikipedia.org/wiki/IEEE_802.11n-2009

High-Speed WiFi

HIGH-SPEED INTERFACES AND PROTOCOLS FOR SHORT-RANGE VIDEO STREAMING

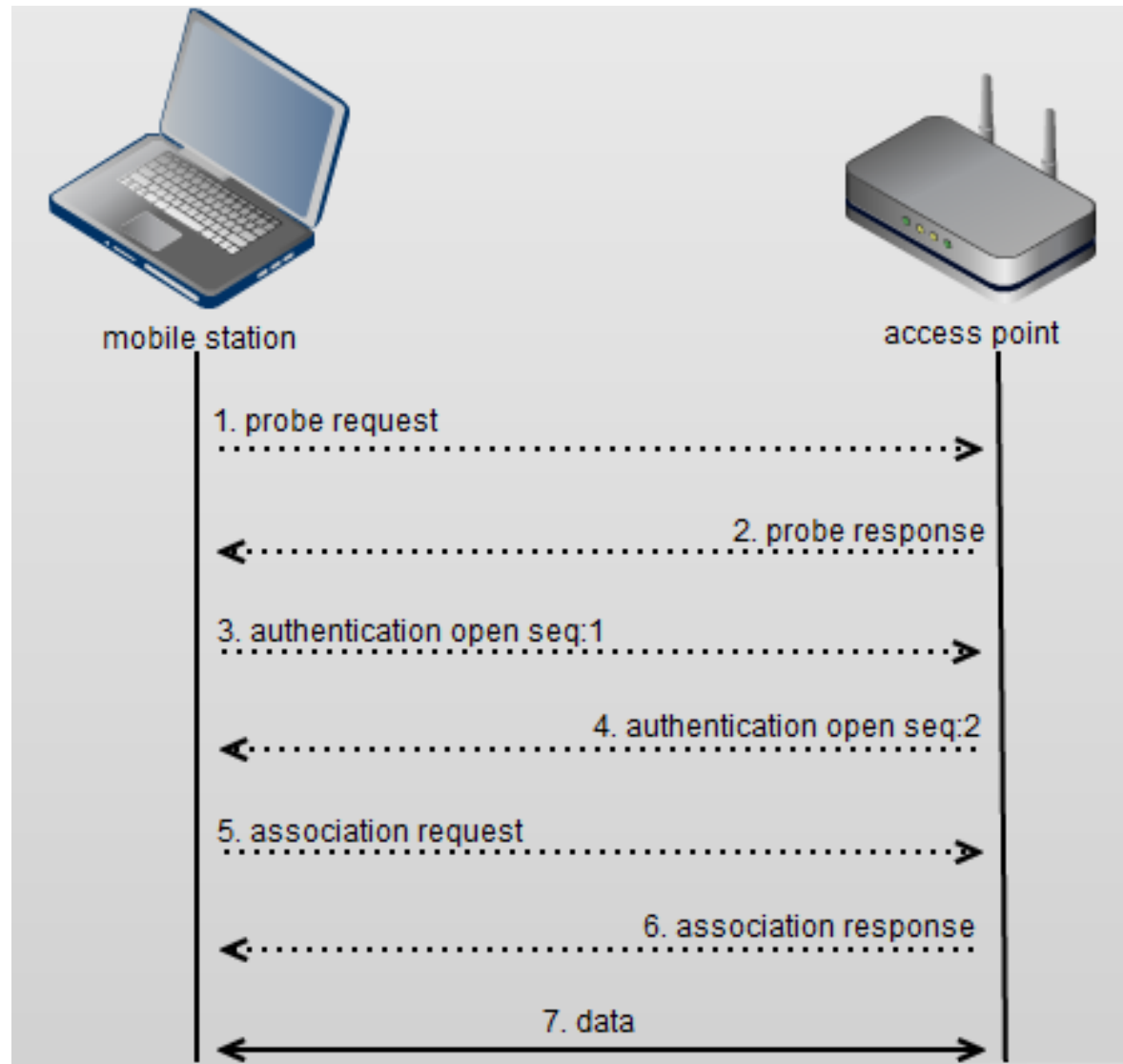
Technology	Frequency band	Maximum data rate	Maximum range (meters)	Key feature
802.11ad	60 GHz	7 Gbits/s	10	Beamforming
WirelessHD	60 GHz	10 to 28 Gbits/s	10	Beamforming
WHDI	5 GHz	1.5 Gbits/s	30	MIMO
802.11n	2.4 or 5 GHz	600 Mbits/s	100	MIMO
802.11ac	5 GHz	7 Gbits/s	50	MIMO
UWB	3.1 to 10.6 GHz	480 Mbits/s	10	Ultra-low power

- http://electronicdesign.com/site-files/electronicdesign.com/files/archive/electronicdesign.com/content/content/74186/74186_table1.gif

องค์ประกอบของ 802.11 (802.11 Component)

- Two pieces of equipment defined:
 - **Wireless station** คือ อุปกรณ์ได้แก่ เครื่องคอมพิวเตอร์ หรือ โน้ตบุ๊ก หรือ อุปกรณ์สื่อสารอื่นที่สามารถเชื่อมต่อแบบ Wi-Fi
 - **Access point** คืออุปกรณ์เชื่อมต่อระหว่างเครือข่ายไร้สายกับเครือข่ายมีสาย ประกอบด้วย:
 - สัญญาณวิทยุ
 - เครือข่ายใช้สาย (โดยปกติคือ IEEE 802.3)
 - Bridging Software

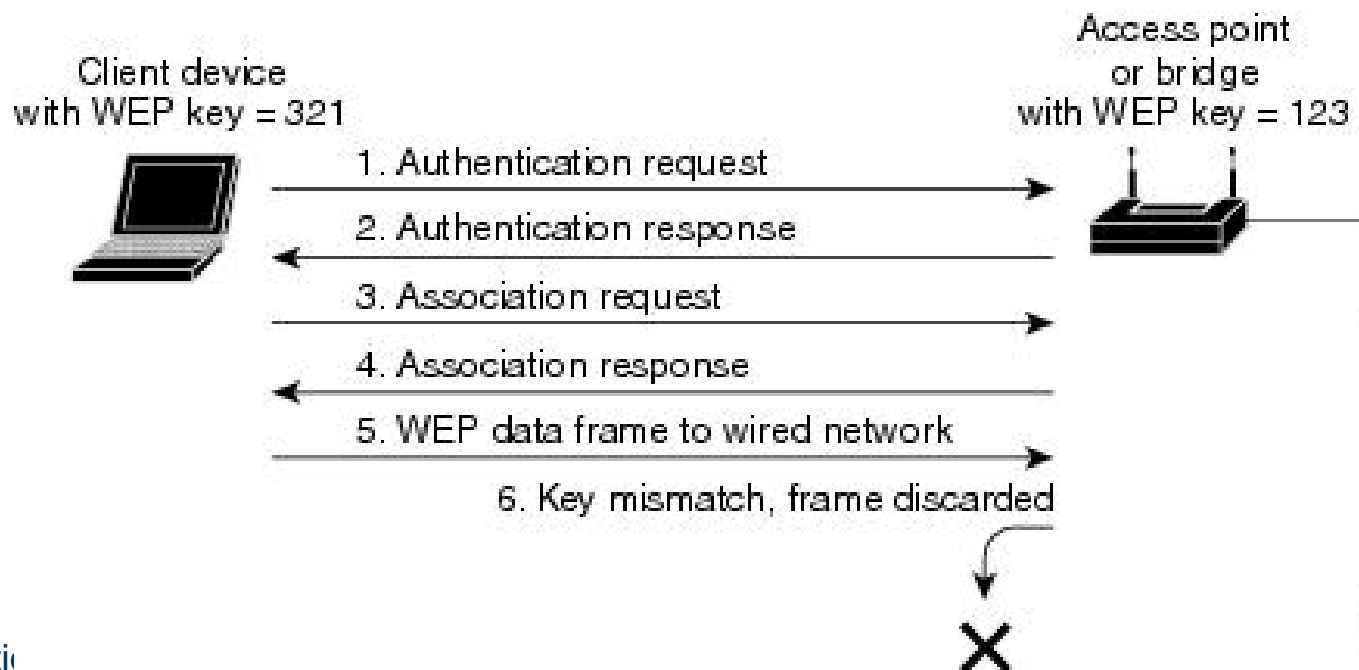
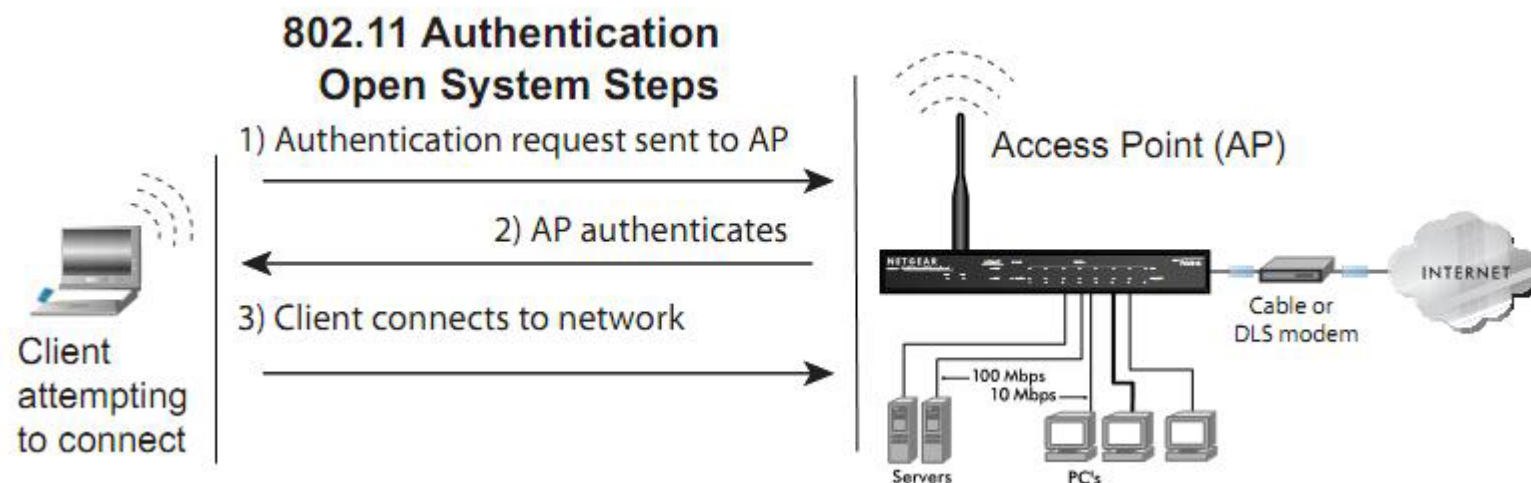
การพิสูจน์ทราบตัวตนของไวน์เลสแลน



การพิสูจน์ทราบตัวตนแบบเปิด (Open Authentication)

- เป็น วิธีพิสูจน์ทราบตัวตนแบบง่ายที่สุด
- AP จะอนุญาตให้เชื่อมต่อทุก ๆ การร้องขอ
- การพิสูจน์ทราบตัวตนมีการรับส่งเฟรมอยู่ 2 ประเภทคือ
 - เฟรมร้องขอการเชื่อมต่อ (**Authentication Request**)
 - เฟรมการตอบกลับการร้องขอ (**Authentication Response**)
- ถ้าไม่มีการเข้ารหัสข้อมูล เครื่องไคลเอนต์ทุกเครื่องที่ทราบหมายเลข SSID สามารถเข้าถึงเครือข่ายได้
- ถ้ามีการเข้ารหัสข้อมูล WEP เครื่องไคลเอนต์ต้องมี WEP คีย์ด้วย

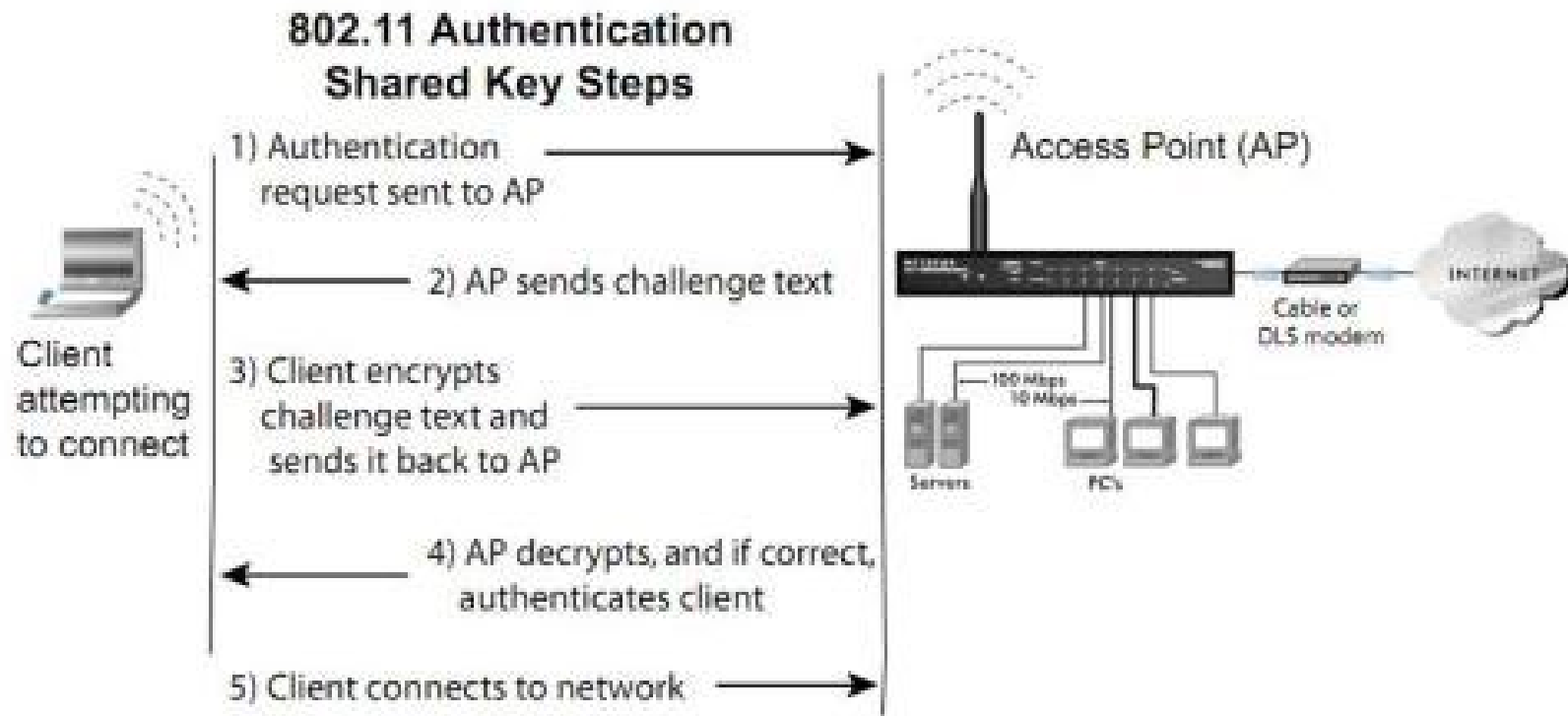
การพิสูจน์ทราบตัวตนแบบเปิด (Open Authentication) (ต่อ)



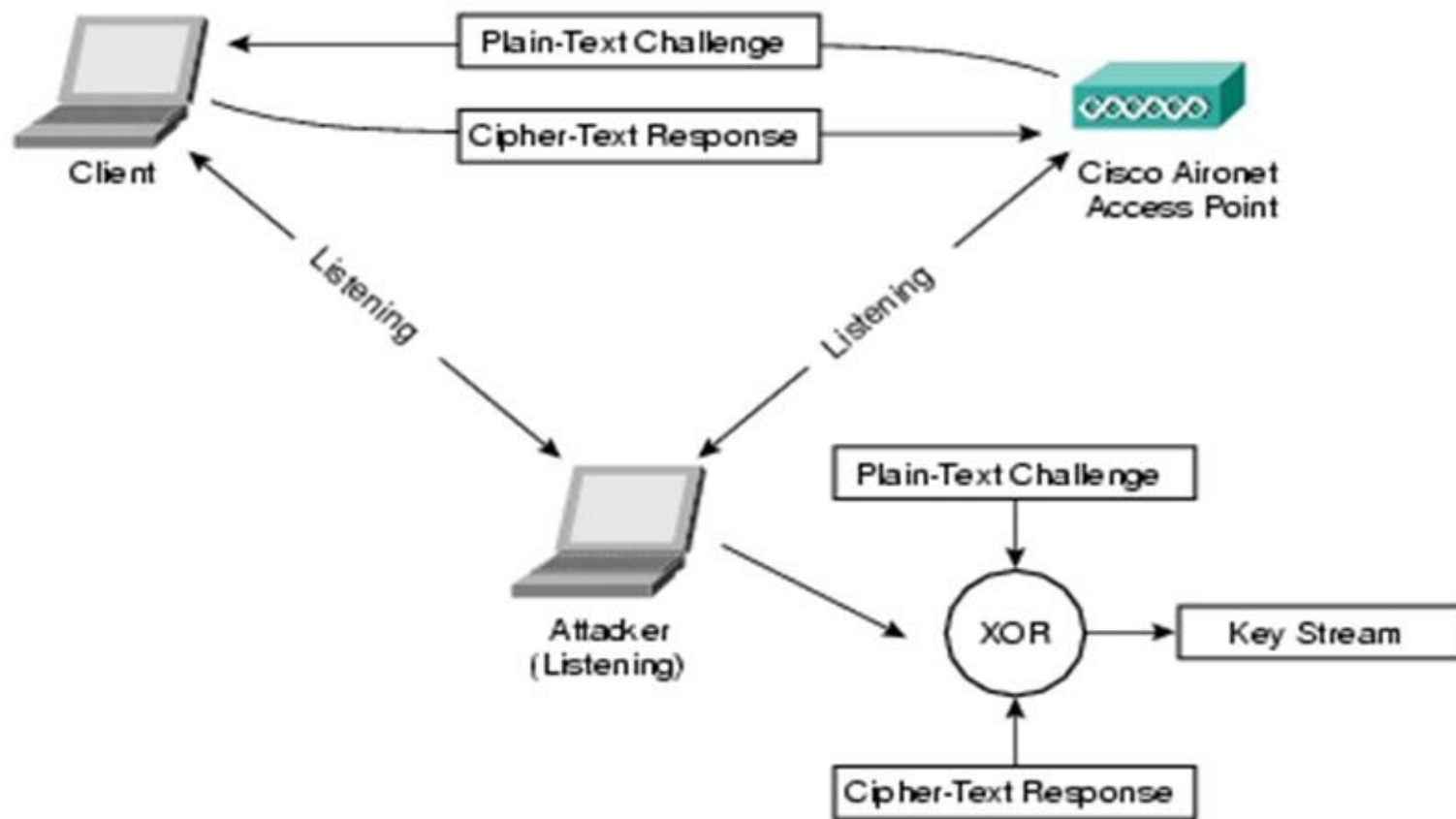
การพิสูจน์ทราบตัวตนแบบแชร์คีย์ (Shared Key Authentication)

- เครื่องไคลเอนต์ต้องกำหนดคีย์ WEP แบบตายตัวในทุกๆ เครื่อง ซึ่งมีขั้นตอนการพิสูจน์ทราบตัวตนดังนี้:
 - ไคลเอนต์ส่งการร้องขอไปยัง AP และระบุว่าต้องการใช้การพิสูจน์ทราบตัวตนแบบแชร์คีย์
 - AP ตอบกลับการร้องขอพร้อมกับชาลเลนจ์เท็กซ์ (Challenge Text) ซึ่งเป็นข้อความแบบสุ่ม
 - ไคลเอนต์ได้รับ Challenge Text แล้วเข้ารหัสด้วย WEP คีย์ ที่กำหนดไว้ก่อนหน้านี้แล้วส่งข้อความนี้กลับไปให้กับ AP
 - ถ้า AP สามารถถอดรหัสข้อความ และเปรียบเทียบกับ Challenge Text เดิมแล้วตรงกัน AP จะส่งการอนุญาตให้เชื่อมต่อเครือข่ายได้กลับไปยังไคลเอนต์

การพิสูจน์ทราบตัวตนแบบแชร์คีย์ (Shared Key Authentication) (ต่อ)



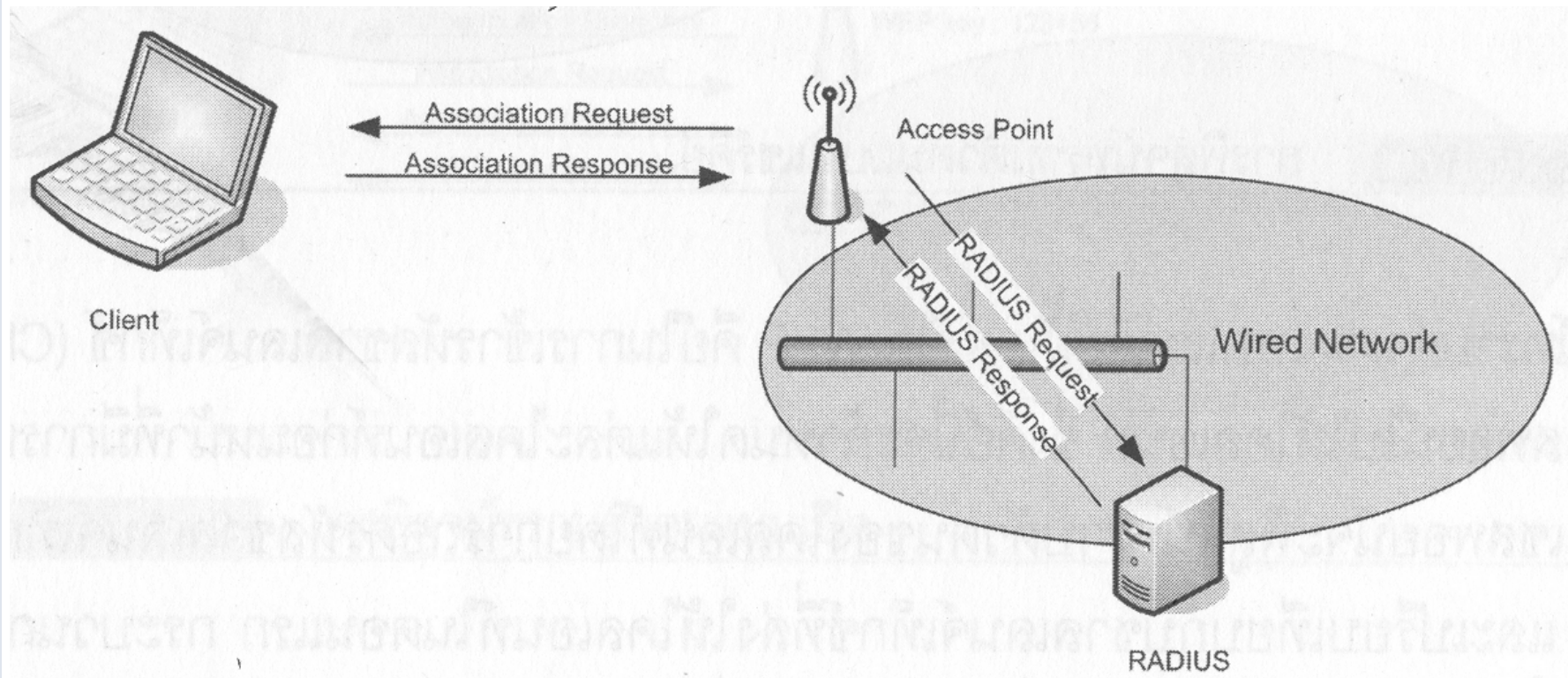
Vulnerability of Shared Key Authentication



การพิสูจน์ทราบตัวตนแบบใช้หมายเลข MAC

- เป็นการพิสูจน์ทราบตัวตนแบบใช้หมายเลข **MAC Address** ของเครื่องไคลเอนต์
- **AP** จะเก็บค่า **MAC Address** ของไคลเอนต์ที่อนุญาตให้เชื่อมต่อไว้ที่ **AP** หรือเครื่องเซิร์ฟเวอร์
- การพิสูจน์ทราบตัวตนวิธีนี้อาจถูกโจมตีด้วยเทคนิค **Spoofing** ได้
 - **UAA** (Universally Administered Address) สามารถเขียนทับไปยังหมายเลข **LAA** (Locally Administered Address)

MAC Address Authentication



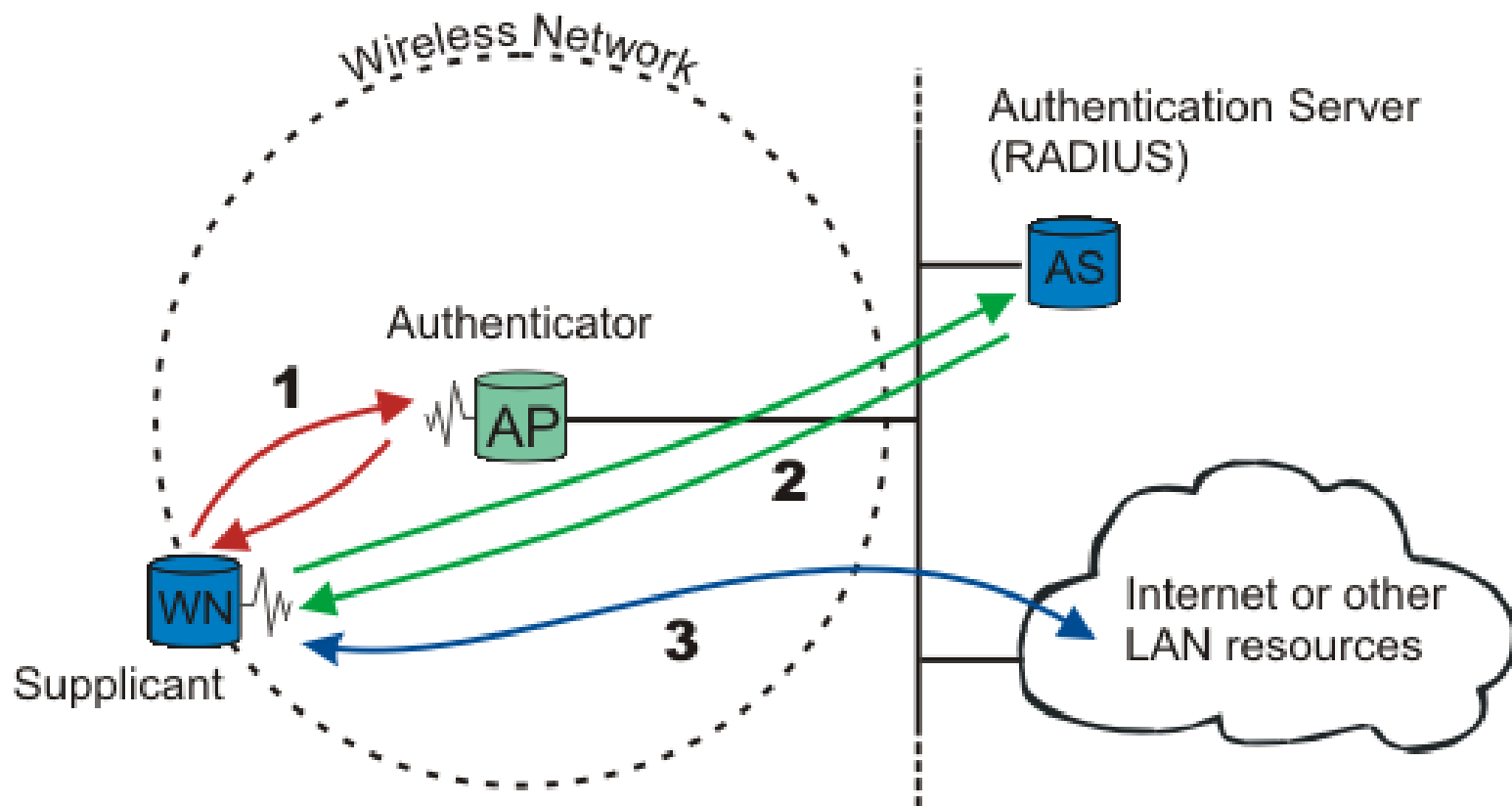
มาตรฐาน IEEE 802.11i

- ระบบพิสูจน์ทราบตัวตน และการเข้ารหัสข้อมูลที่กำหนดในมาตรฐาน IEEE 802.11 ไม่ปลอดภัย IEEE จึงได้พัฒนา IEEE 802.11i ขึ้น
- กลไกการรักษาความปลอดภัยที่สมบูรณ์ต้องประกอบด้วย:
 - โครงสร้างในการพิสูจน์ทราบตัวตน (Authentication Framework)
 - ขั้นตอนในการพิสูจน์ทราบตัวตน (Authentication Algorithm)
 - การรักษาความลับของข้อมูลและอัลกอริทึมที่ใช้ในการเข้ารหัส (Data privacy and encryption algorithm)
- ซึ่งทั้ง 3 ส่วน ได้กำหนดไว้ในมาตรฐาน IEEE 802.11i
 - ใช้โครงสร้างการพิสูจน์ทราบตัวตนตามมาตรฐาน IEEE 802.1X ทำงานที่ MAC เลเยอร์ ทำให้มีความปลอดภัยสูงขึ้น
 - โพรโทคอล EAP (Extensible Authentication Protocol) ใช้พิสูจน์ทราบตัวตนทั้งจากเซิร์ฟเวอร์กลาง (RADIUS) และสร้าง WEP คีย์แบบไดนามิกได้

มาตรฐาน IEEE 802.1X

- มาตรฐาน IEEE 802.1X เป็นเฟรมเวิร์คสำหรับการพิสูจน์ทราบตัวตน สำหรับอุปกรณ์ต่าง ๆ ที่เชื่อมต่อกับเครือข่าย (ใช้ได้กับที่ไม่ใช่ WLAN)
- รองรับการแลกเปลี่ยนคีย์ที่ใช้สำหรับการเข้ารหัสข้อมูล
- IEEE 802.1X เป็นมาตรฐานสำหรับการควบคุมการเข้าถึงเครือข่ายระดับพอร์ต (Port-based Network Access Control) โดยใช้โปรโตคอล EAP (Extensible Authentication Protocol) ในการแลกเปลี่ยนข้อมูล

มาตรฐาน IEEE 802.1X (ต่อ)



องค์ประกอบการพิสูจน์ตัวตนแบบ IEEE 802.1X

การพิสูจน์ทราบตัวตนตามมาตรฐาน IEEE 802.1X
ต้องประกอบ 3 ส่วนดังนี้

- **Supplicant** คือ ไคลเอนต์ (ซอฟต์แวร์) ที่เชื่อมต่อเข้ากับ WLAN
- **Authenticator** คือ AP ที่ทำหน้าที่เป็นตัวกลางในการพิสูจน์ทราบตัวตน
- **Authentication Server** คือ เครื่องเซิร์ฟเวอร์ที่ทำหน้าที่ในการพิสูจน์ทราบตัวตน ซึ่งส่วนใหญ่จะใช้ RADIUS เซิร์ฟเวอร์

โปรโตคอล EAP

- EAP (Extensible Authentication Protocol) เป็นโปรโตคอลมาตรฐานในการพิสูจน์ทราบตัวตนตามมาตรฐาน IEEE 802.1X
- ใช้ในการพิสูจน์ทราบตัวตนในเครือข่าย LAN และ WLAN ให้มีความปลอดภัยสูง
- การเชื่อมต่อจะมีการแสดงหลักฐานประกอบการตรวจสอบ (Credential) ต่อ AP หลังจากนั้น AP จะส่งผ่านหลักฐานไปยัง RADIUS เซิร์ฟเวอร์ โดยจะใช้โปรโตคอล EAP สำหรับส่งข้อมูล ซึ่งปัจจุบันมีการใช้โปรโตคอลนี้ในรูปแบบ EAP-MD5, LEAP, EAP-TLS, EAP-TTLS และ PEAP

โปรโตคอล EAP (ต่อ)

- EAP-MD5 หลักฐานที่ส่งไปยัง RADIUS คือ รหัสผู้ใช้และรหัสผ่านที่ถูกเข้ารหัสด้วย อัลกอริทึม MD5
- LEAP (Lightweight EAP) หรือ EAP-Cisco Wireless พัฒนาโดย Cisco มีกลไกส่งรหัสผู้ใช้และรหัสผ่านไปยังเซิร์ฟเวอร์ รวมถึงมีการบริหารจัดการ WEP คีย์ และเพิ่มกลไกการตรวจสอบทั้งเครื่องเซิร์ฟเวอร์และไคลเอนต์ได้ (แต่มีใช้เฉพาะอุปกรณ์ของ Cisco)
- EAP-TLS (Transport Layer Security) พัฒนาโดย Microsoft ไม่ใช้รหัสผู้ใช้และรหัสผ่านแต่ใช้ใบรับรองดิจิทัล X.509 แทน (มีค่าใช้จ่ายสูง)
- EAP-TTLS/MSCHAPv2 พัฒนาโดย ฟังก์ชันซอฟต์แวร์ ซึ่งมีการทำงานคล้าย EAP-TLS คือ มีการตรวจสอบฝั่งเซิร์ฟเวอร์โดยใช้ใบรับรองดิจิทัล ส่วนฝั่งผู้ใช้ถูกตรวจสอบโดยการใส่รหัสผู้ใช้และรหัสผ่าน
- PEAP (Protection EAP) พัฒนาโดย Microsoft , Cisco และ RSA Security และเป็นมาตรฐานแบบเปิด ทำหน้าที่เฉพาะพิสูจน์ทราบตัวตนไคลเอนต์ที่ต้องการเชื่อมต่อเท่านั้น
 - ใช้ public key ของ Certificate เฉพาะทางฝั่งเซิร์ฟเวอร์เท่านั้น โดยสร้าง SSL/TLS tunnel ระหว่างไคลเอนต์และเซิร์ฟเวอร์เพื่อป้องกันการแอบดักอ่านข้อมูล

การเข้ารหัสข้อมูลใน WLAN

- WEP (Wire Equivalent Privacy)
- WPA (Wi-Fi Protection Access)
- TKIP (Temporal Key Integrity Protocol)
- WPA2 (Wi-Fi Protection Access II)

WEP (Wire Equivalent Privacy)

- การเข้ารหัสใช้ RC4 ซึ่งเป็นการเข้ารหัสแบบสตรีมไซเฟอร์สมมาตร
- โคลเอนต์และ AP จะต้องใช้คีย์เดียวกันในการเข้าและถอดรหัสข้อมูล
- ช่องโหว่ของ WEP
 - Fluhrer, Mantin และ Sharmir พบจุดอ่อนจากขั้นตอนการทำ KSA (Key Scheduling Algorithm) ของการเข้ารหัสแบบ RC4 เนื่องจากเฟรมข้อมูลมีการส่งค่า IV ซึ่งสามารถดักจับและวิเคราะห์หาคีย์ได้
 - อีกจุดอ่อนหนึ่งคือสามารถวิเคราะห์หาคีย์แบบ Inductive คือดูจากเฟรมที่รายงานข้อผิดพลาดระหว่าง AP และ โคลเอนต์
 - WEP มีการใช้คีย์แบบคงที่โดยกำหนดไว้ที่โคลเอนต์สำหรับการพิสูจน์ทราบตัวตนทำให้การบริหารจัดการคีย์ทำได้ยาก

WPA (Wi-Fi Protection Access)

- เนื่องจากการพิสูจน์พบว่า WEP ไม่ปลอดภัย TGi จึงได้ออกแบบระบบรักษาความปลอดภัยในมาตรฐาน IEEE 802.11i (ปี 2004)
- Wi-Fi มาจากคำว่า Wireless Fidelity เป็นองค์กรนานาชาติก่อตั้งในปี 1999 เพื่อออกใบรับรองมาตรฐานในการทำงานร่วมกันได้ของอุปกรณ์ WLAN (Wi-Fi certificate)
- อุปกรณ์ที่ได้รับมาตรฐาน Wi-Fi® หมายถึงอุปกรณ์เหล่านั้นถูกรับรองว่าสามารถทำงานร่วมกันได้อย่างแน่นอน
- WPA มีการใช้ TKIP ในการเข้ารหัสข้อมูลแทน WEP ซึ่งการเข้ารหัสคล้ายกับ WEP แต่มีการเปลี่ยนคีย์ใหม่ทุก ๆ แพ็กเก็ต มีการพิสูจน์ทราบตัวตนแบบแฮชคีย์
- มีการจัดการคีย์ 2 แบบคือ
 - กำหนดให้มีเซิร์ฟเวอร์ (RADIUS) สำหรับพิสูจน์ทราบตัวตนแยกต่างหาก เรียกว่า WPA-Enterprise
 - ใช้การแฮชคีย์ ไม่จำเป็นต้องมีเซิร์ฟเวอร์แยกต่างหาก เรียกว่า WPA-Personal หรือ WPA-PSK (Pre-shared Key)

TKIP (Temporal Key Integrity Protocol)

- การเข้ารหัสแบบ WEP นั้นเป็นกลไกการเข้ารหัสที่ไม่มีประสิทธิภาพ และมีช่องโหว่
- TGi ได้พัฒนากลไกการเข้ารหัสข้อมูลเพื่อเพิ่มประสิทธิภาพ เรียกว่า TKIP
- โดยเพิ่มประสิทธิภาพให้กับ WEP อยู่ 2 ทางคือ
 - เพิ่มฟังก์ชัน MIC (Message Integrity Check) กับเฟรมข้อมูลของ WEP
 - เปลี่ยนคีย์กับทุก ๆ เฟรมข้อมูลของ WEP

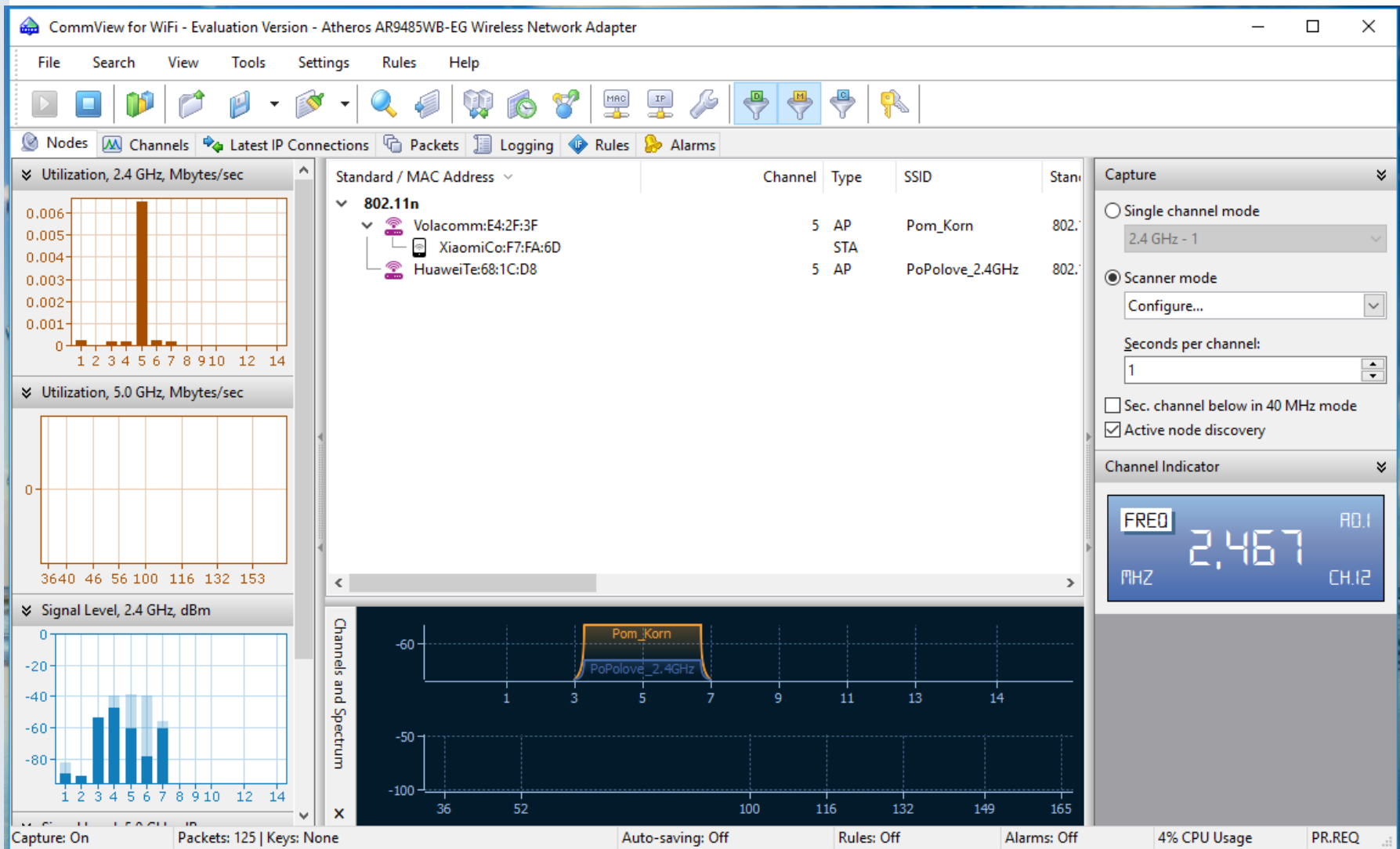
WPA2 (Wi-Fi Protection Access II)

- WPA เป็นโปรโตคอลที่ออกแบบมาเพื่อแก้ไขปัญหของ WEP ชั่วคราว เมื่อ IEEE 802.11i พัฒนาเสร็จแล้วจึงเรียกอัลกอริทึมเข้ารหัสของมาตรฐานนี้ว่า WPA2 โดยมีส่วนที่เพิ่มขึ้นจาก WPA เช่น
 - การใช้อัลกอริทึมในการเข้ารหัสที่แข็งแกร่งกว่าคือ CCMP (Counter-Mode/CBC-MAC Protocol) ซึ่งเข้ารหัสข้อมูลโดยใช้ AES แทน TKIP
 - การเข้ารหัสลับข้อมูลของ CCMP ใช้ AES ในโหมด Counter Mode
 - การพิสูจน์ทราบตัวตนและการรักษาความลับใช้ CBC-MAC (Cipher Block Chaining Message Authentication Code)
 - ใช้คีย์มีความยาว 128 บิต
- นอกจากนี้ยังเพิ่มกลไกการรักษาความปลอดภัยใหม่ เรียกว่า ESN (Enhance Security Network) โดยใช้ AES เข้ารหัสคีย์ แทน RC4
- PSK (Pre-Shared Key) เป็นโหมดการทำงานของ WPA2 ซึ่งเหมาะสำหรับใช้ในออฟฟิศขนาดเล็ก ที่ไม่ต้องการใช้มาตรฐาน IEEE 802.1X เต็มรูปแบบ

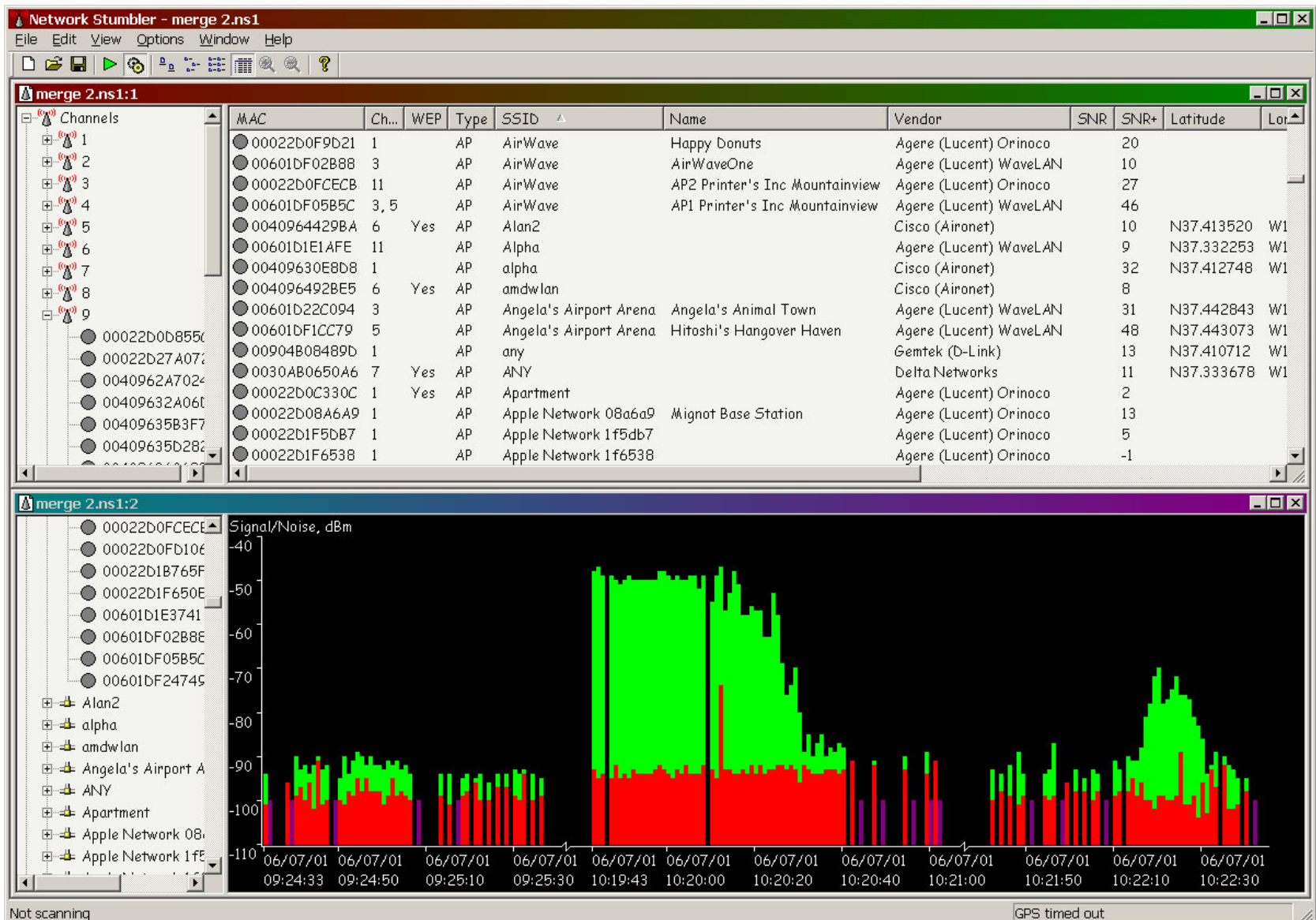
เครื่องมือสแกน WLAN

- เครื่องมือสแกน WLAN ถูกนำมาใช้สำหรับการบริหารจัดการเครือข่าย WLAN เพื่อวางแผน ออกแบบ ติดตั้งและมอนิเตอร์
- เครื่องมือสำหรับสแกนที่นิยมได้แก่
 - CommView (ดาวน์โหลดที่ www.tamos.com)
 - Netstumbler
 - Vistumbler
 - NetServeyoyr
 - insider
 - Kismet
 - Xirrus Wi-Fi Inspector
 - Meraki WiFi Stumbler

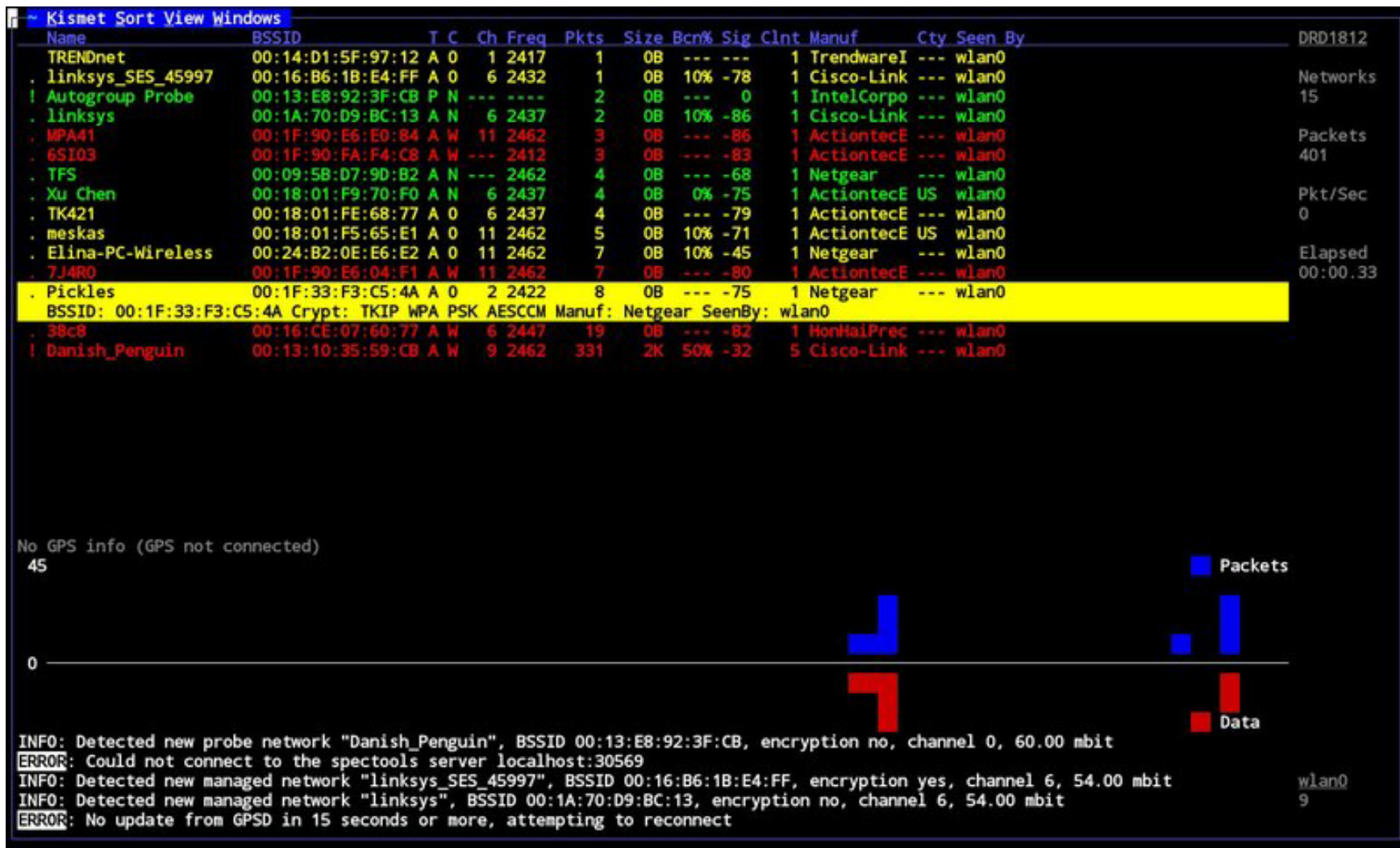
ตัวอย่าง เครื่องมือสแกน WLAN



ตัวอย่าง เครื่องมือสแกน NetStumbler



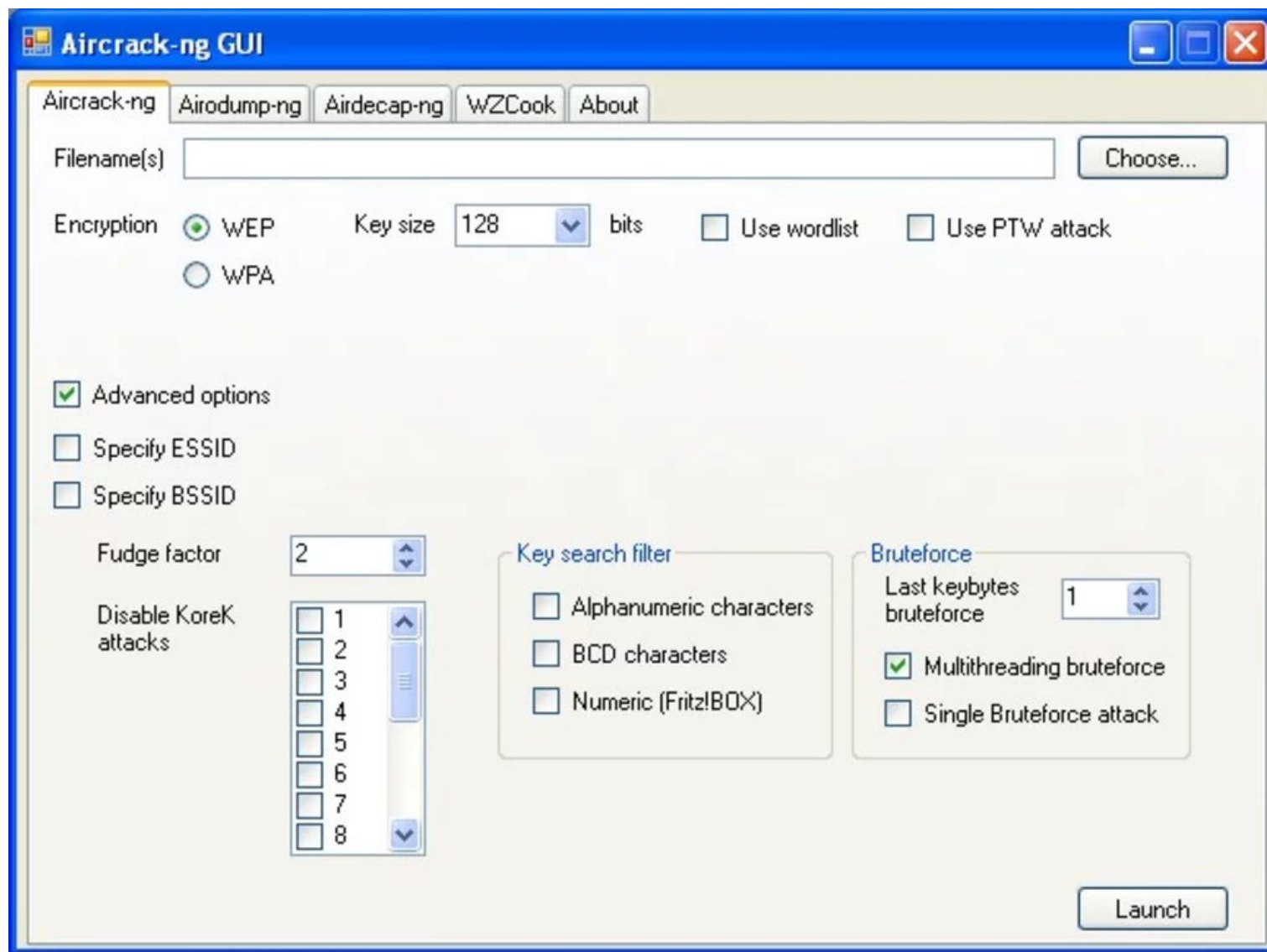
ตัวอย่าง เครื่องมือสแกน Kismet



การเจาะ WLAN

- หากไม่มีการพิสูจน์ทราบตัวตนสามารถเชื่อมต่อได้เลย แค่เลือก SSID
- กรณีมีการป้องกัน ปกติมี 3 แบบคือ WEP, WPA และ WPA2 ซึ่งแบบ WEP สามารถถอดรหัสได้ง่ายกว่าแบบอื่น
- ขั้นตอนการเจาะ WLAN มีดังนี้
 - ใช้เครื่องสแกนเครือข่าย (CommView for WiFi) ทำการดักจับแพ็กเก็ตและทำการบันทึกเก็บไว้จำนวนหนึ่ง (ประมาณ 100,000 – 500,000 แพ็กเก็ต)
 - นำแพ็กเก็ตที่บันทึกไว้ไปทำการถอดรหัส โดยใช้ซอฟต์แวร์ในการแคร็กรหัสผ่าน เช่น Aircrack-ng (ซึ่งสามารถถอดรหัสคีย์ของ WEP และ WPA ได้ แต่ขึ้นอยู่กับความยากง่ายของคีย์ที่กำหนด)
 - AirSnort (WEP), CowPatty (Brute-Force), ASLeap (LEAP)

ตัวอย่าง การเจาะ WLAN



ตัวอย่าง การเจาะ WLAN

```
C:\ Aircrack-ng

Aircrack-ng 0.4.2

[00:00:04] Tested 21263 keys (got 1008195 IVs)

KB    depth  byte(vote)
0     0/ 1    8E< 66> 3D< 17> 2D< 17> DA< 16> BF< 10> F4< 8>
1     0/ 1    CC< 243> 9B< 16> 69< 15> AB< 10> 0B< 8> F3< 4>
2     0/ 1    28< 183> DA< 16> CA< 11> 97< 8> 2B< 8> 98< 8>
3     0/ 1    0C< 212> AC< 20> 69< 19> F8< 15> 63< 12> F4< 11>
4     0/ 1    4A< 96> 89< 33> EA< 14> 36< 12> 99< 11> 54< 9>
5     0/ 1    AC< 164> 3B< 33> 37< 27> 91< 21> 03< 20> 01< 15>
6     0/ 1    49< 251> 86< 60> A9< 33> 16< 27> DF< 25> 2F< 18>
7     0/ 1    B7< 290> 88< 61> 9C< 42> 33< 23> 8D< 21> 5C< 19>
8     0/ 1    71< 858> 38< 51> 1A< 33> C9< 26> E8< 18> 6D< 14>
9     0/ 1    6B< 345> F0< 24> 9D< 22> A8< 20> 19< 17> 4C< 14>
10    0/ 1    78< 437> CC< 36> 9E< 29> 2F< 24> F6< 22> D1< 22>

KEY FOUND! [ 8E:CC:28:0C:4A:AC:49:B7:71:6B:78:53:0D ]

C:\aircrack-ng-0.4.2-win\bin>
```



End.



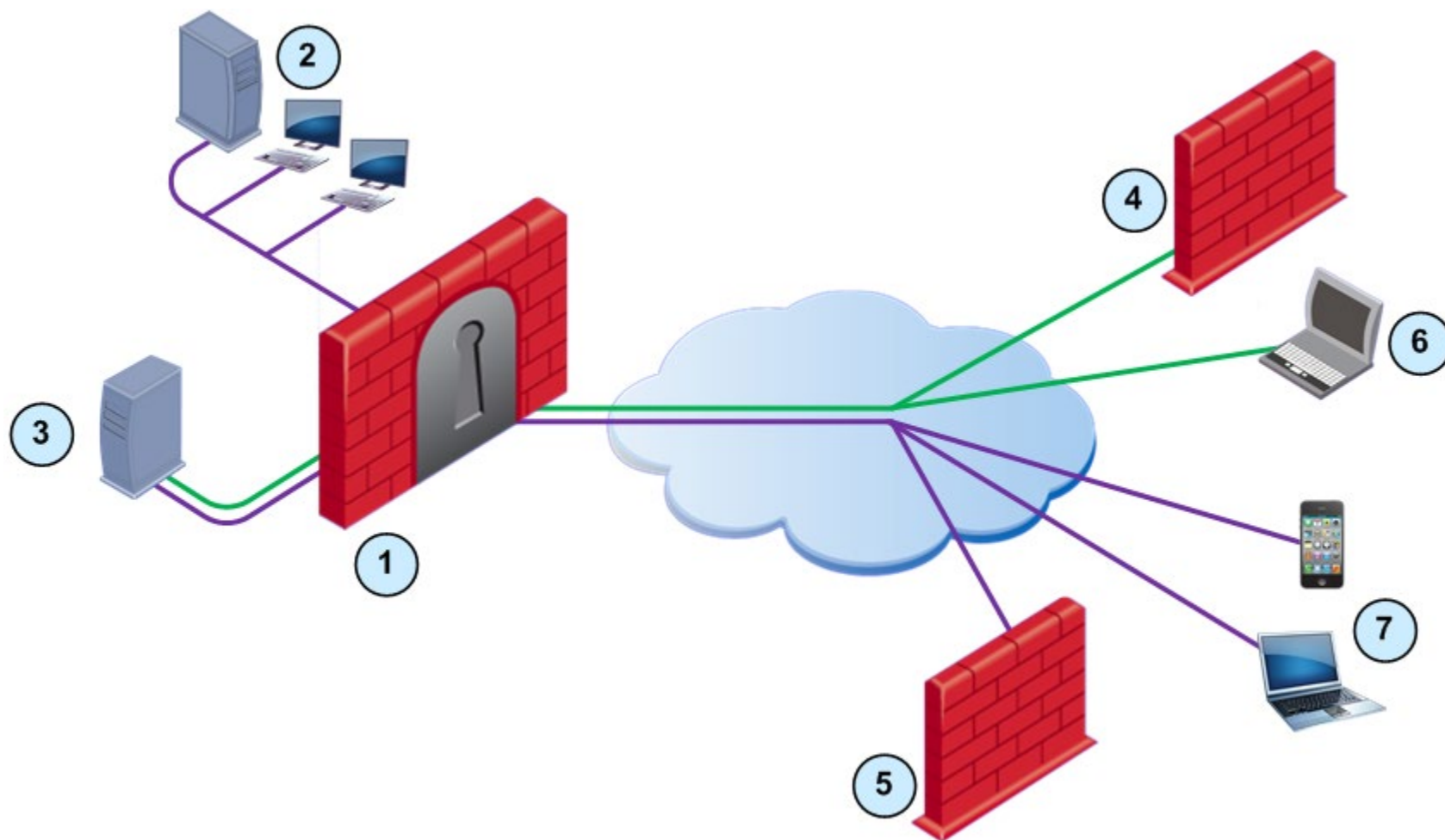
Firewall

ไฟร์วอลล์

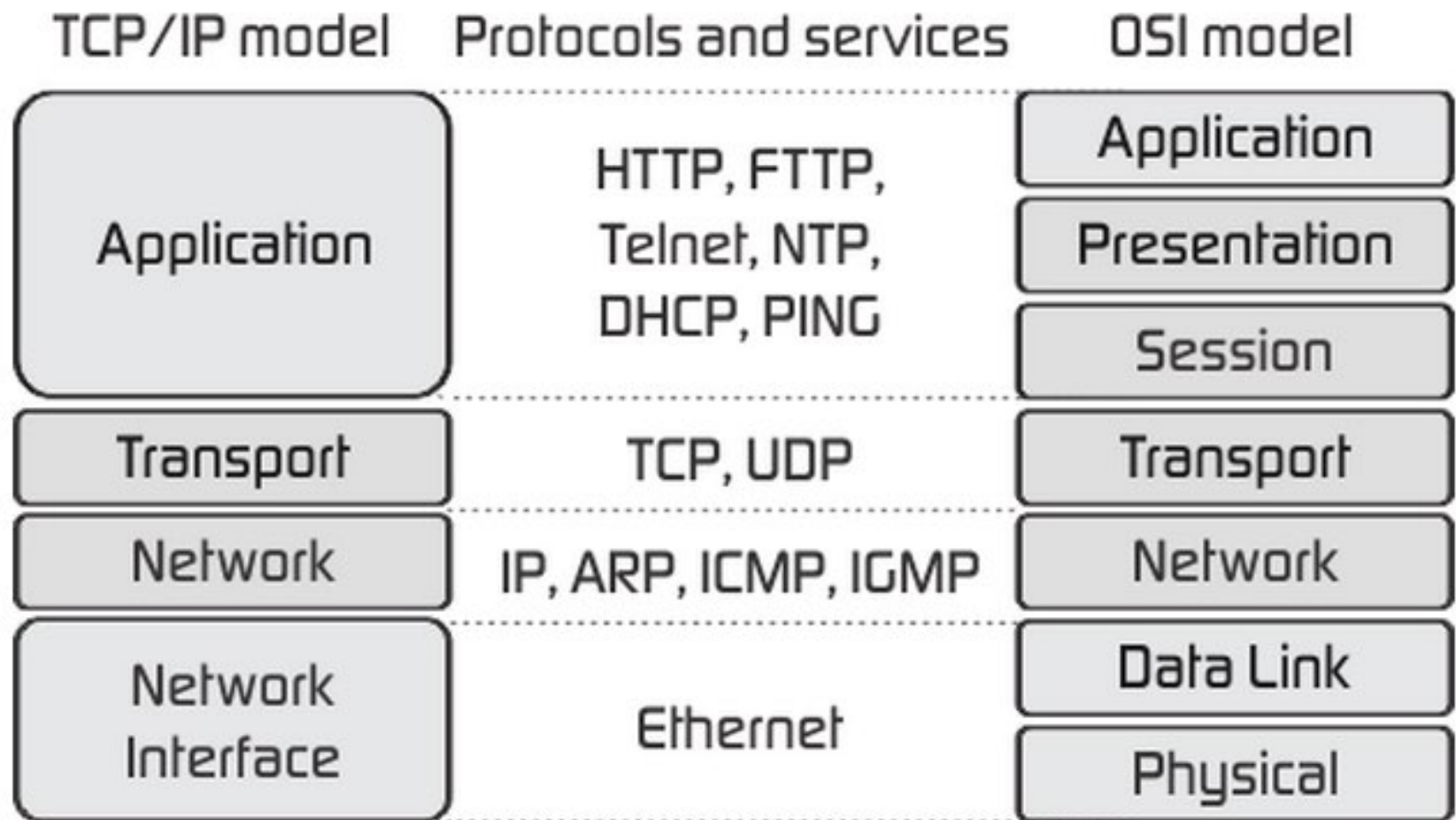
ไฟร์วอลล์ (Firewall)

- ทำหน้าที่ในการกรอง packet ว่า packet ใดที่จะอนุญาตให้ เข้า – ออก เครือข่ายภายในหรือ packet ใดอนุญาตให้ออกสู่ภายนอก
- สามารถกำหนดได้ว่าต้องการ packet ใด เข้าได้บ้าง packet ใดออกได้บ้าง
- อาจจะมีการติดตั้ง firewall บน router กรอง packet หรือใช้ในระดับ application
- ปกติจะเน้น packet ที่มาจากเครือข่ายภายนอก ส่วน packet ภายในองค์กรถือว่าเป็น packet ที่น่าเชื่อถือ

หลักการทำงานของไฟร์วอลล์



โปรโตคอล TCP/IP



ประเภทของไฟร์วอลล์

- โฮสต์เบสไฟร์วอลล์ (Host Based Firewall)
 - บางครั้งเรียกว่า Personal Firewall
 - เป็นไฟร์วอลล์ที่หลักการทำงานที่ง่าย และราคาถูกส่วนใหญ่เป็นไฟร์วอลล์ที่เป็นซอฟต์แวร์ที่ติดตั้งที่โฮสต์หรือเครื่องคอมพิวเตอร์
 - เช่น ZoneAlarm, Norton Personal Firewall , Windows Firewall
- เน็ตเวิร์คไฟร์วอลล์ (Network Firewall)
 - บางครั้งเรียกว่า Enterprise Firewall
 - มีกลไกทำงานที่ซับซ้อน ราคาแพง มักถูกออกแบบในลักษณะฮาร์ดแวร์
 - รองรับการทำงานหลายยูสเซอร์ จัดการทราฟฟิกต่างๆ และมีความน่าเชื่อถือสูง

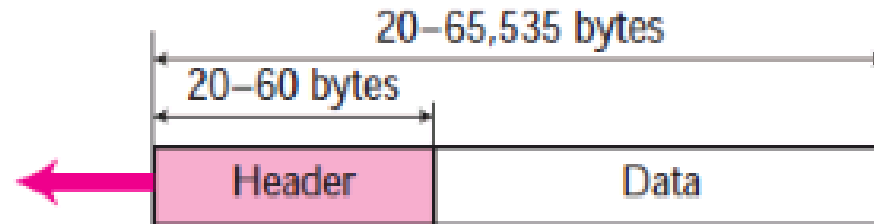
Generation of Firewall

- First Generation/ Packet Filtering Firewall
- Second Generation/ Application-Level Firewall
- Third Generation/ Stateful Inspection Firewall
- Fourth Generation/ Dynamic Filtering Firewall
- Fifth Generation/ Kernel Proxy

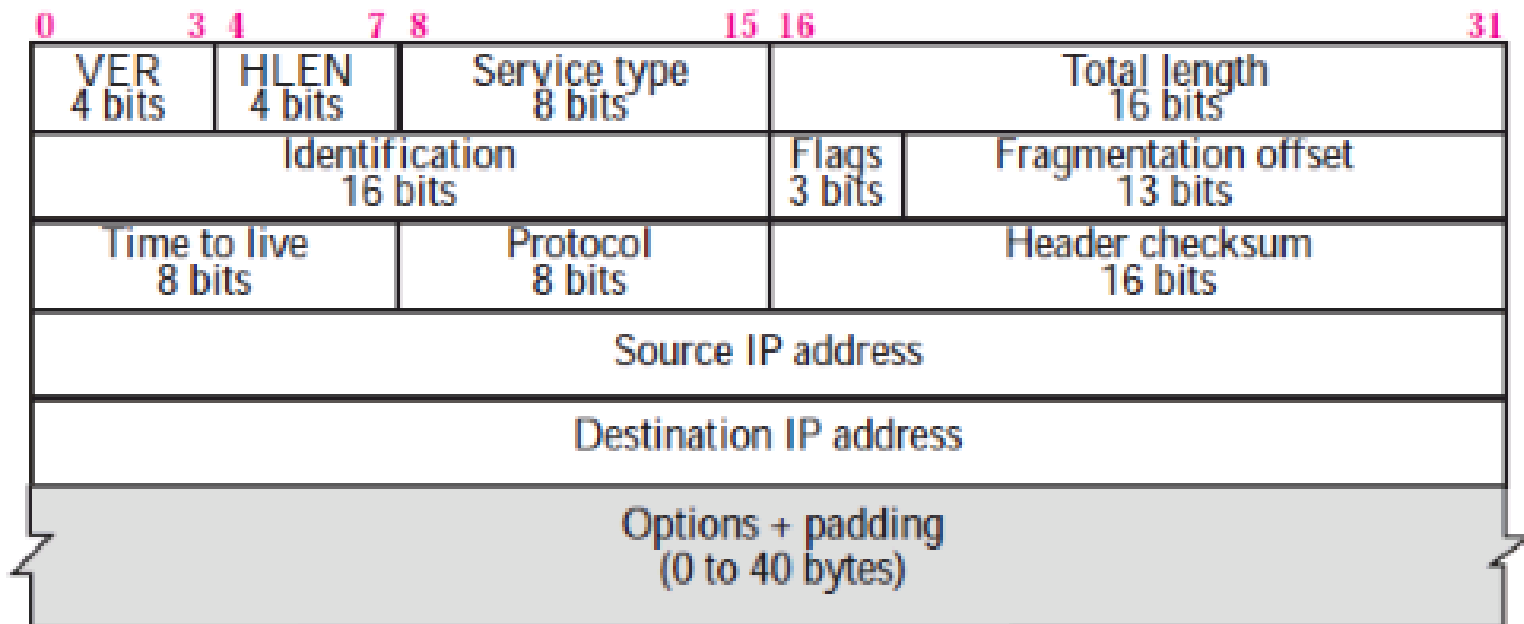
First Generation

- Firewall ในยุคนี้เรียกว่า Packet Filtering เนื่องจากในการกรองข้อมูลจะอนุญาต Packet อะไร เข้า-ออก เครือข่ายภายในบ้าง
- โดยสังเกต Packet จาก Header ว่ามีหมายเลข IP ต้นทางอะไร
- ซึ่งมักจะดูจาก IP Packet เช่น Packet Type, Port Request แต่สิ่งที่มักจะดูหลัก ๆ มี 3 อย่าง คือ
 - IP Source และ Destination Address
 - Direction (Inbound/Outbound)
 - TCP หรือ UDP และดูว่า Port ที่ Request เป็น Port อะไร

IP (Internet Protocol)



a. IP datagram



b. Header format

Packet Filter Firewall

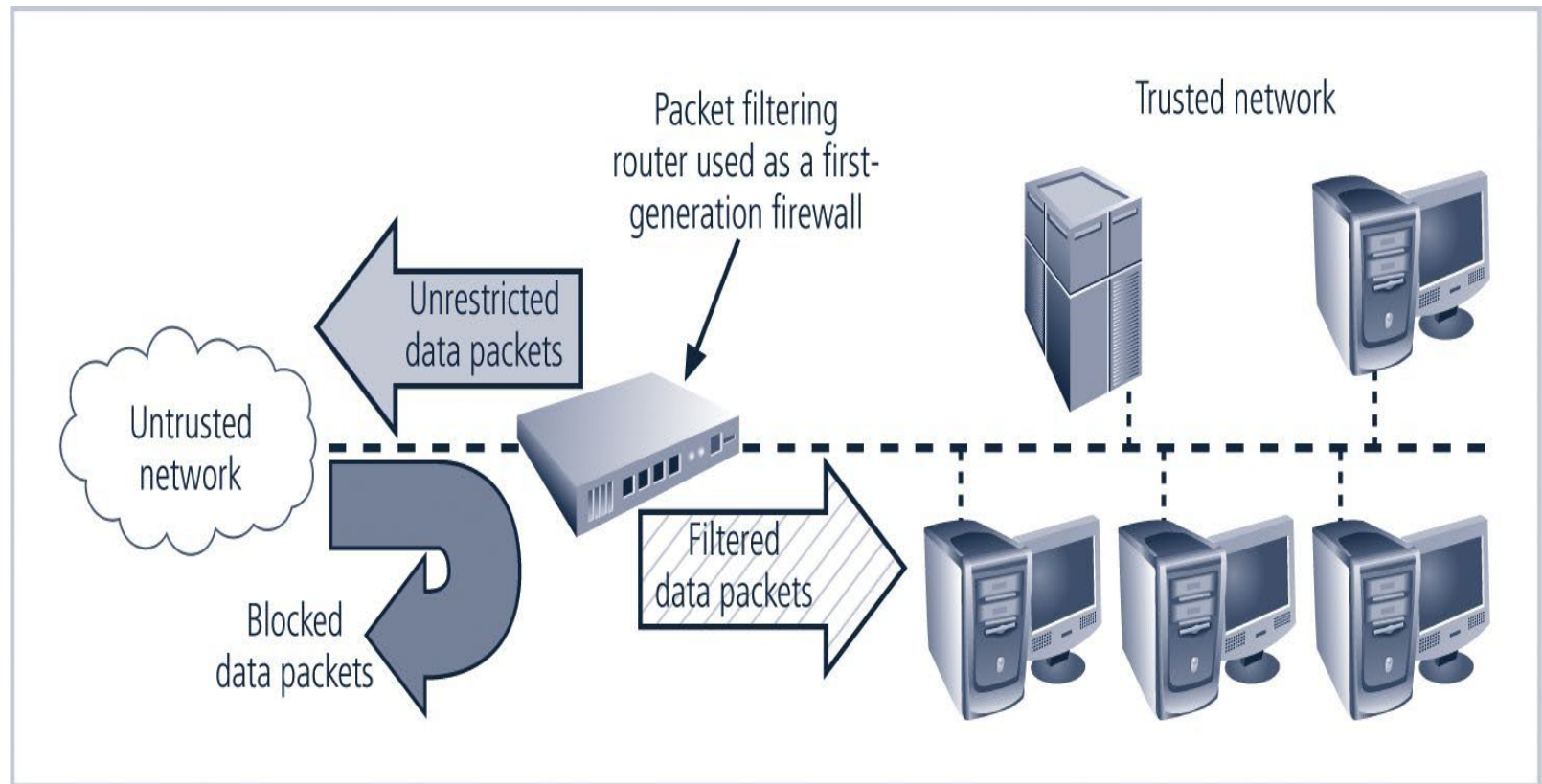
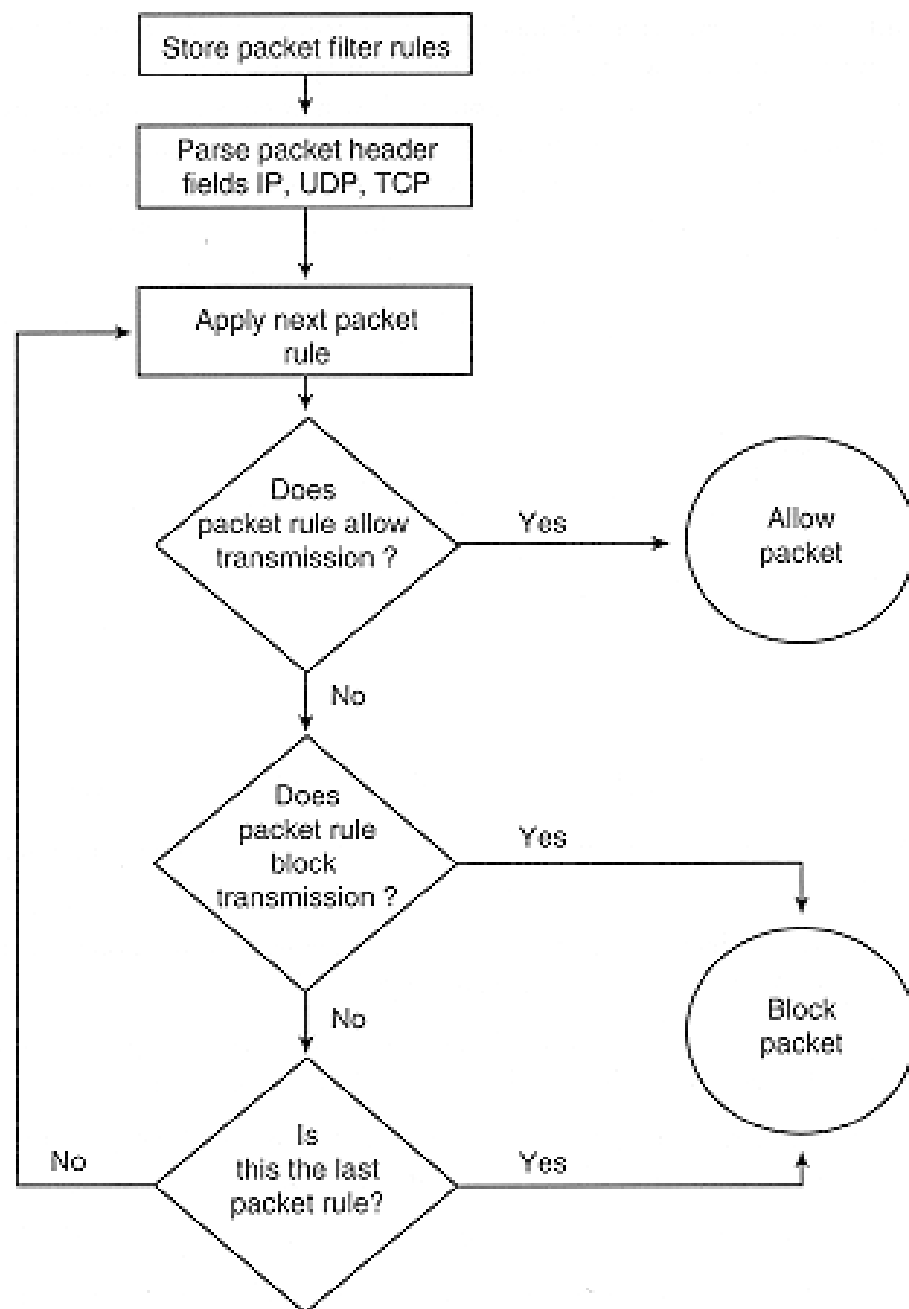


FIGURE 9-5 Packet Filtering Firewall

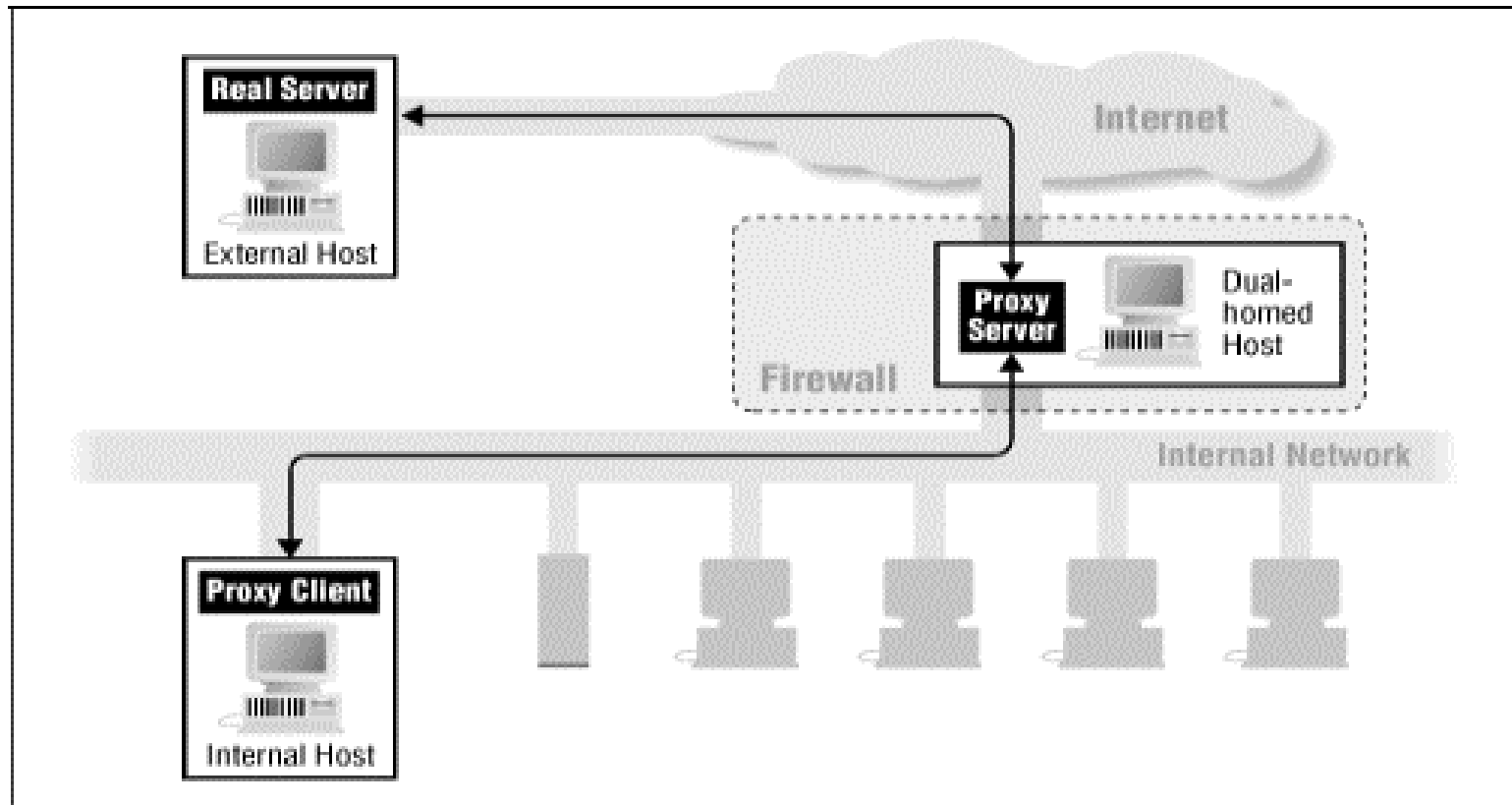
Flowchart of Packet Filter Operation



Second Generation

- ในยุคนี้เรียกว่า Application-Level Firewall หรือ Proxy Server ซึ่งจะแยกเป็นคนละส่วนกับ Filtering Router ของยุคแรก
- Proxy Server เป็นตัวแทนที่คอยบริการบุคคลภายนอก ทำให้บุคคลภายนอกไม่สามารถติดต่อกับเครื่องที่ให้บริการจริง
- สามารถตรวจสอบข้อมูลในชั้น Network Layer, Transport Layer และ Application Layer
- Proxy Server จะสร้าง IP Packet ใหม่เพื่อส่งต่อไปยังเป้าหมาย
- ไคลเอนต์ส่งการร้องขอไปยัง Firewall จากนั้น Firewall จะตรวจสอบนโยบาย ถ้าอนุญาต Firewall จะสร้างการเชื่อมต่อไปยังเซิร์ฟเวอร์แทนไคลเอนต์

Application-level Firewall



โปรโตคอลในระดับแอปพลิเคชัน

โปรโตคอล	พอร์ต	อธิบาย
DNS	TCP/UDP หมายเลข 53	แปลงชื่อโดเมนเป็นหมายเลข IP
HTTP	TCP หมายเลข 80	รับส่งเอกสารเว็บเพจ
HTTPS	SSL/TLS หมายเลข 443	เข้ารหัสข้อมูลรับส่งระหว่างเว็บเซิร์ฟเวอร์และเบราว์เซอร์
SMTP	TCP หมายเลข 25	ส่งจดหมายอิเล็กทรอนิกส์
POP	TCP หมายเลข 110	อ่านอีเมลจากเมลบ็อกซ์
IMAP	TCP หมายเลข 143	จัดการอีเมลบนเมลบ็อกซ์
SNMP	TCP/UDP หมายเลข 161	แลกเปลี่ยนข้อมูลเกี่ยวกับการจัดการเครือข่าย
FTP	TCP หมายเลข 21	โอนย้ายไฟล์

Third Generation

- เป็นการพัฒนามาจากยุคที่ 1 ซึ่งจะมีความสามารถมากกว่าการ Packet Filtering ทำงานในชั้นที่ 4 (Transport Layer)
- โดยจะมีการติดตามการเชื่อมต่อ เก็บสถานะการเชื่อมต่อลงใน State Table (ติดตามดูพฤติกรรม การติดต่อสื่อสารก่อน แล้วค่อยทำการ Filtering) อาจเรียกว่า Stateful Inspection Firewall
- **แต่มีข้อเสียคือ** ทำให้เสียเวลามากขึ้นเพราะมีการทำงานที่ซับซ้อน
- โดยปกติจะตรวจสอบข้อมูลจากโปรโตคอล
 - TCP
 - UDP

Fourth Generation

- ไฟร์วอลล์ในยุคที่สี่ อาจเรียกว่า Dynamic Packet Filtering Firewall
 - ยอมให้เฉพาะ packet ที่เชื่อมต่อผ่าน Source, Destination และ Port Address ที่กำหนดไว้ใน Rule เท่านั้น
 - ต้องมีความเข้าใจเกี่ยวกับหน้าของ Protocol เพื่อใช้กำหนดการเปิด-ปิด ช่องทางใน Firewall ได้ถูกต้อง
 - เป็นการทำงานที่อยู่ระหว่าง Static Packet Filters และ Application Proxy

Fifth Generation

- ไฟร์วอลล์ในยุคที่ห้า บางที่เรียกว่า Kernel Proxy ซึ่งเป็นไฟร์วอลล์แบบพิเศษ ที่ทำงานภายใน Kernel ของ Windows NT
- จะทำงานบนชั้นแอปพลิเคชัน เพื่อวิเคราะห์แพ็กเก็ตโดยจะสร้างเครือข่ายเสมือนขึ้นมาขณะที่มีแพ็กเก็ตเข้ามา
- โดยจะตรวจสอบแพ็กเก็ตที่ เลเยอร์ต่างๆ ของสแต็กโปรโตคอล โดยตรวจสอบความปลอดภัยในเคอร์เนล
- ทำงานได้เร็วกว่า Proxy Firewall (application firewall) ทั้งนี้จะขึ้นอยู่กับ **เคอร์เนล (Kernel)** ของระบบ

Next Generation Firewall

- ไฟร์วอลล์ที่ทำงาน Application Layer มีความสามารถควบคุมแอปพลิเคชันหรือซอฟต์แวร์ได้แบบเชิงลึก และมีคุณสมบัติการป้องกันอัตโนมัติ
- ลักษณะของ Next Generation Firewall
 - สามารถระบุและกรองแอปพลิเคชันได้
 - มีฟังก์ชันของ Firewall มาตรฐานครบถ้วน เช่น Stateful Inspection Firewall, Routing, Network Address Translation (NAT), Port Address Translation (PAT) และสามารถทำ Virtual Private Network (VPN) ได้
 - สามารถป้องกันการโจมตีอัตโนมัติ (Intrusion Prevention System: IPS) และตรวจสอบ Packet เชิงลึก (Deep Packet Inspection)
 - สามารถทำ SSL Inspection
 - สามารถทำ Malware Filtering

Firewall Component

- Network policy
- Advance Authentication
- Packet Filtering และ Application Gateway (Proxy Server)

Network Policy

- เป็นนโยบายการเข้าถึงเครือข่าย (ถือว่าเป็นสิ่งจำเป็น) ที่ใช้ในการ Implement Firewall
- การออกแบบ ติดตั้ง Firewall ต้องอาศัย Policy
- Policy มีหลายระดับ สำหรับที่เกี่ยวกับ firewall ที่เป็นระดับสุดท้าย คือ การลงรายละเอียดจาก Policy ไปเป็น Access Control List (Lower-Level Policy เป็นระดับที่จะ Config Firewall อาจเรียกว่า Firewall Policy ก็ได้)

Network Policy (ต่อ)

- High-Level Policy จะเป็นระดับที่กำหนดว่ามี Service อะไร จะอนุญาตหรือไม่ อย่างไร ควบคุมได้ 2 ทิศทางดังนี้
 - Service Access Policy เป็นการกำหนด Service ที่อนุญาตให้ใช้งาน
 - Firewall Design Policy เป็นนโยบายสำหรับออกแบบ Firewall ซึ่งมีแนวคิด 2 แบบคือ
 - Permit ทุก Service ก่อนแล้วค่อยปิด Service ที่ต้องการปิด
 - Deny ทุก Service ก่อนแล้วค่อยเปิด Service ที่ต้องการให้บริการ

Advance Authentication Mechanism

- เนื่องจาก Firewall จะอยู่ระหว่างจุดซึ่งเป็นทางเข้า-ออก ซึ่งอาจติดตั้งระบบ Authentication ในการเข้าถึงเครือข่ายไว้ตรง Firewall ที่จุดเดียวกัน

Packet Filtering and Application Gateway

- Packet Filtering
 - เป็น Firewall ที่กรอง Packet ซึ่งสามารถเลือกกรองจาก
 - Source IP address
 - Destination IP address
 - TCP/UDP Source Port (Port บอกว่าได้ว่าเป็น Service อะไร)
 - TCP/UDP Destination Port

Packet Filtering and Application Gateway: packet filtering

TABLE 6-1 Sample Firewall Rule and Format

Source Address	Destination Address	Service (HTTP, SMTP, FTP, Telnet)	Action (Allow or Deny)
172.16.x.x	10.10.x.x	Any	Deny
192.168.x.x	10.10.10.25	HTTP	Allow
192.168.0.1	10.10.10.10	FTP	Allow

Packet Filtering and Application Gateway (ต่อ)

- Application Gateway
 - สามารถกำหนดรายละเอียดได้ว่า Service ย่อย ๆ อะไรที่จะอนุญาตหรือไม่อนุญาต
 - Proxy Server มีบริการเช่น Web, Mail, Telnet, FTP
 - Proxy Server อาจจะมีฟังก์ชัน การ Authentication, Log File

Screen-host Firewall System

- เป็นการเชื่อมต่อที่รวมเอา Packet Filtering Router ใช้ควบคู่กับ Proxy Server
- ช่วยให้เกิด Traffic ลดลง และลดภาระงานให้กับ Proxy
- ในระดับ Application จะใช้ Proxy เป็นตัวกรอง โพรโทคอลในระดับ Application ตัวอย่างเช่น HTTP, FTP เป็นต้น

Screen-host Firewall System (cont.)

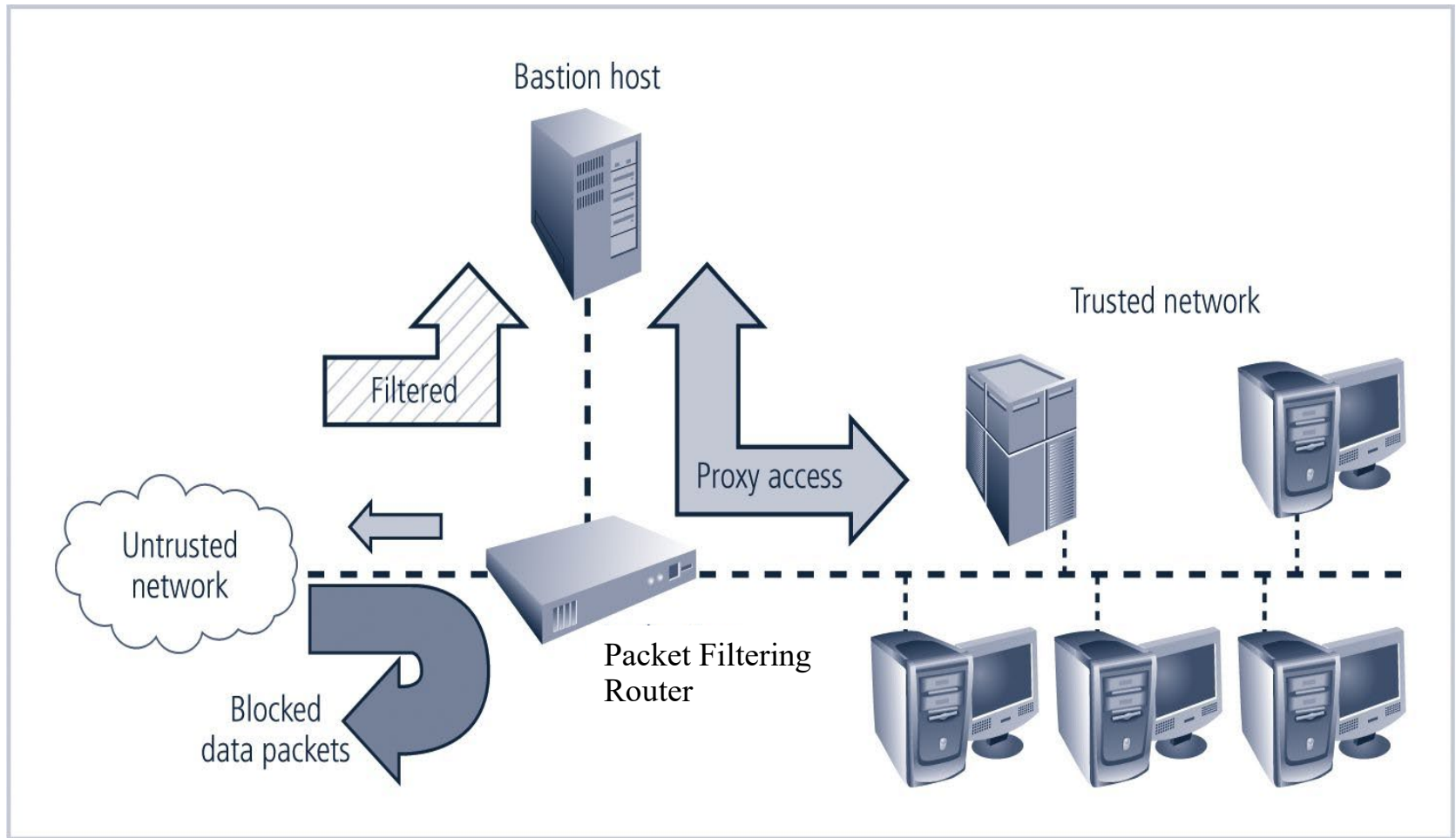


FIGURE 9-6 Screened-Host Firewall

Dual-homed Host Firewall

- การ Configuration ในส่วนของจุดที่ติดตั้งไฟร์วอลล์ (Bastion Host) ประกอบด้วย LAN Card 2 อัน
 - อันหนึ่งเชื่อมต่อไปยังเครือข่ายภายนอก
 - อีกอันหนึ่งเชื่อมต่อไปยังเครือข่ายภายใน สิ่งที่ได้จากการออกแบบอย่างนี้ก็เพื่อแยก Traffic ที่มาจากเครือข่ายภายนอกและมาจากเครือข่ายภายในออกจากกัน (แยกทางกายภาพ)
- Network-Address Translation (NAT) ได้ถูกนำมา Implement กับสถาปัตยกรรมแบบนี้
 - แปลงหมายเลข IP จากเครือข่ายภายนอกไปเป็นช่วงหมายเลขไอพีที่กำหนดไว้สำหรับ หมายเลข IP ของเครือข่ายภายใน

Dual-homed Host Firewall (ต่อ)

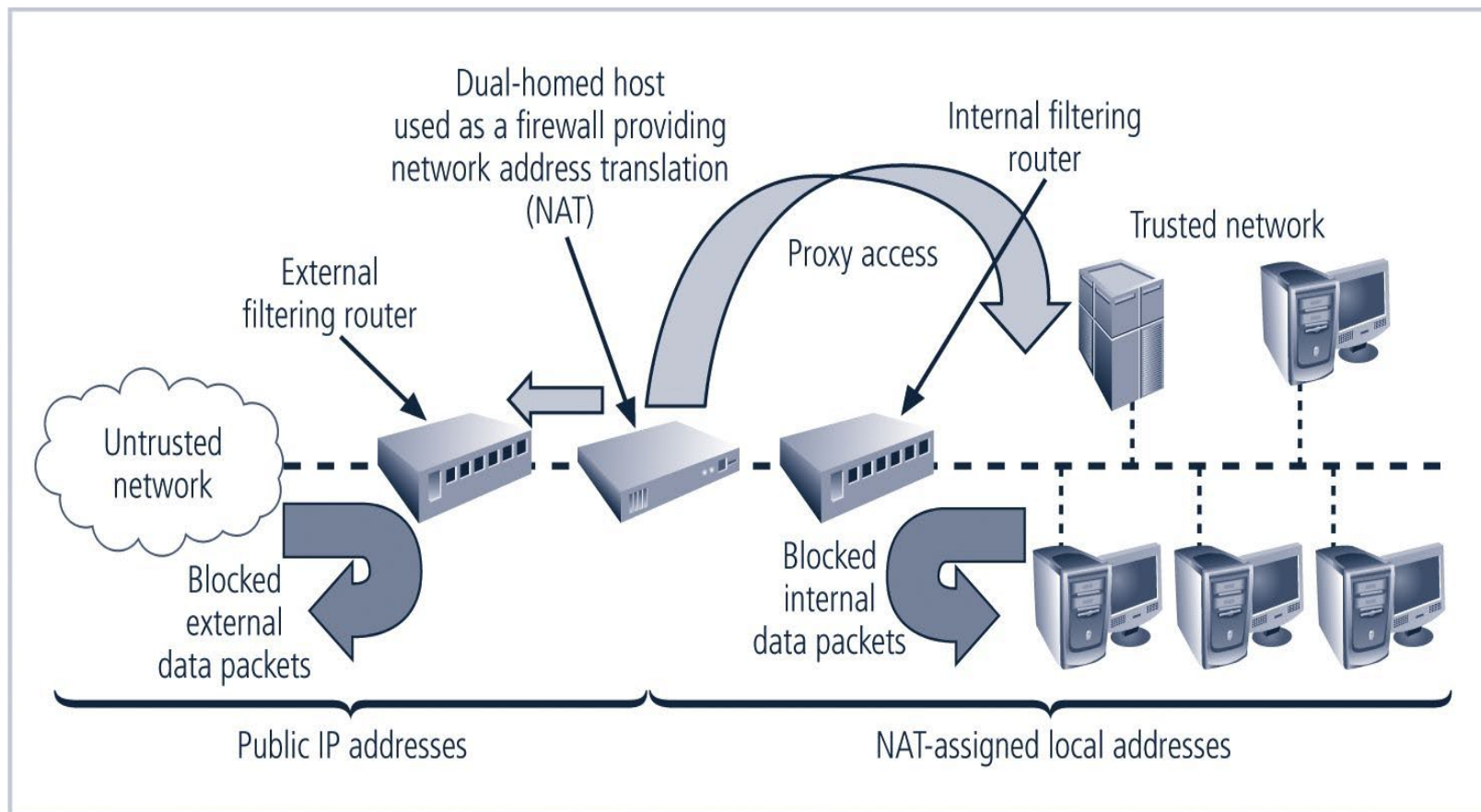


FIGURE 9-7 Dual-Homed Host Firewall

Screened-Subnet Firewalls (with DMZ)

- เป็นการวาง Server ที่ต้องการให้ภายนอกใช้ (เช่น web server, mail server) อยู่ใน Demilitarized Zone (DMZ zone) และมีการดูแลความปลอดภัยบริเวณ DMZ zone อย่างแน่นหนา
- ยังคงใช้ Packet Filtering Router สองตัวสำหรับ Filter เครือข่ายภายในและภายนอก
- เครือข่ายภายในและภายนอกแยกกันอย่างชัดเจน หากเครือข่ายภายนอกต้องการใช้บริการก็ต้องผ่าน Proxy Server

Screened-Subnet Firewalls (with DMZ) (cont.)

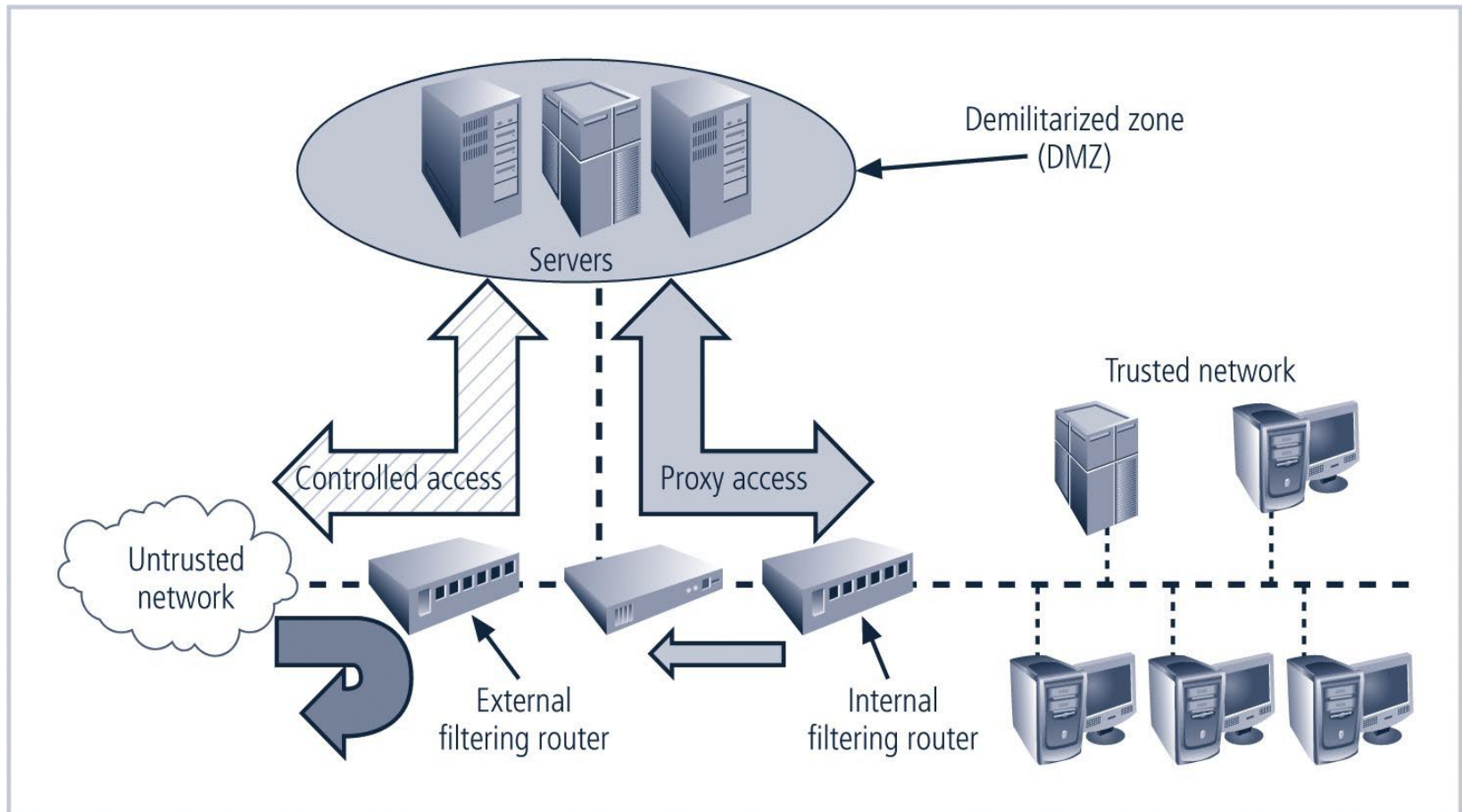


FIGURE 9-8 Screened-Subnet (DMZ)

การเลือก firewall ให้เหมาะสมกับความต้องการ

- จะต้องดูความสามารถในการป้องกัน กับค่าใช้จ่าย ที่องค์กรรับได้
- ราคาขั้นต่ำ มี Feature อะไรบ้าง
- การ Config, Setup ทำได้ง่ายหรือไม่
- สามารถรองรับ ปรับให้เหมาะสมกับเครือข่าย หากเครือข่ายมีขนาดใหญ่ ขึ้น ได้หรือไม่

Configuring and Managing Firewall

การ Setup, Config Firewall โดยทั่วไป ที่แนะนำเช่น

- อนุญาต Traffic ทั้งหมดของเครือข่ายภายในให้สามารถออกสู่ข้างนอก หรืออาจจะ Block พนักงานบางตำแหน่งไม่ให้ติดต่อเครือข่ายภายนอก
- กำหนดให้ Firewall Device ไม่อนุญาตให้เครือข่ายภายนอกเข้าถึงเครือข่ายภายในโดยตรง
- อนุญาตให้ Mail (SMTP) เข้ามาใน Firewall ได้ แต่ต้องมั่นใจได้ว่าจะมาตามเส้นทางที่กำหนดไว้
- ไม่อนุญาตให้ใช้ ICMP
- Block Telnet เนื่องจากการ Authentication ไม่ปลอดภัย
- การให้บริการ Web ต้องจัดให้อยู่ใน DMZ Zone (ภายนอกต้องผ่าน Proxy)

ประสิทธิภาพการป้องกันของ Firewall ขึ้นอยู่กับ

- ชนิดของ Firewall
- กระบวนการ การติดตั้งและใช้งาน
- Service Access Policy



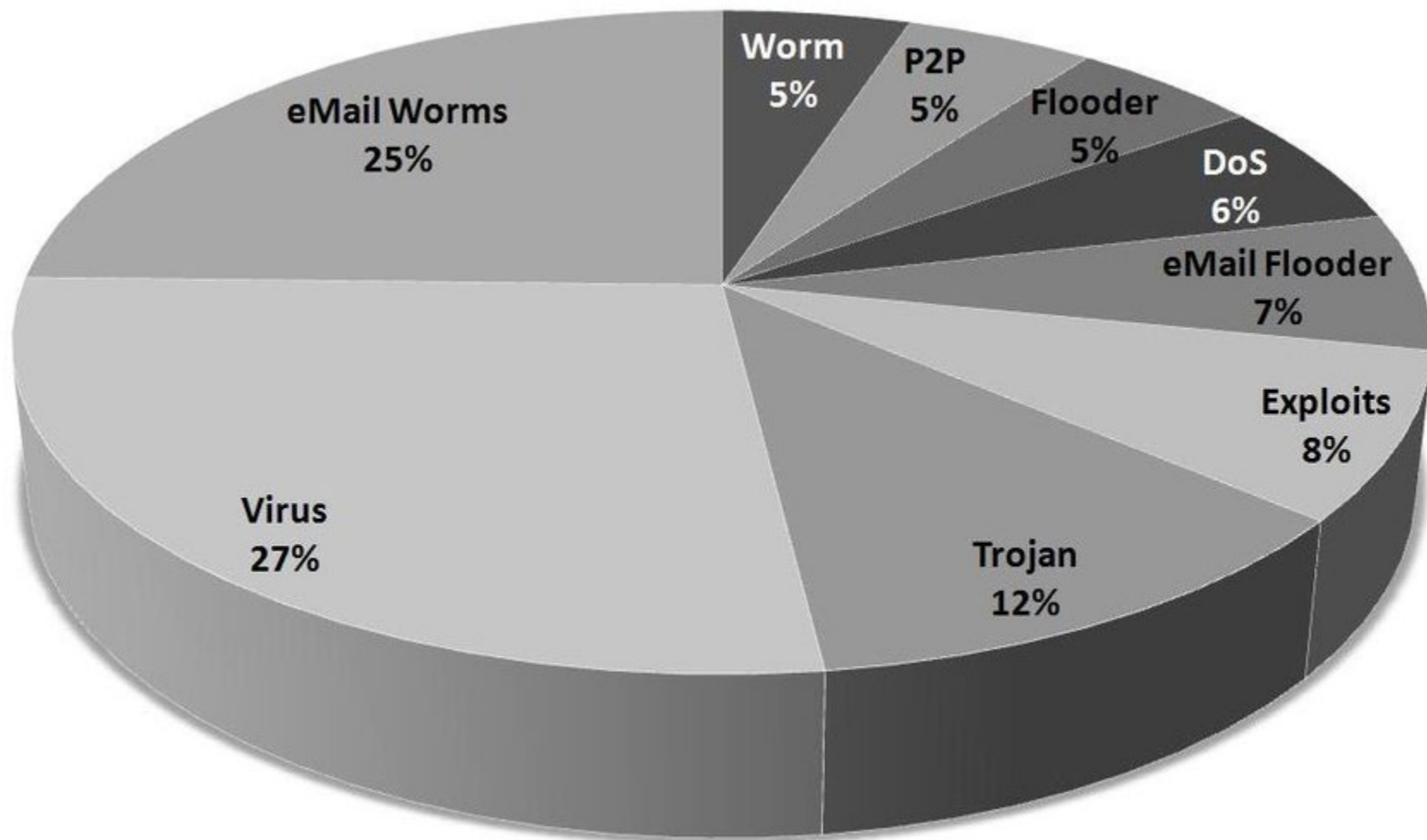
End.



Malware

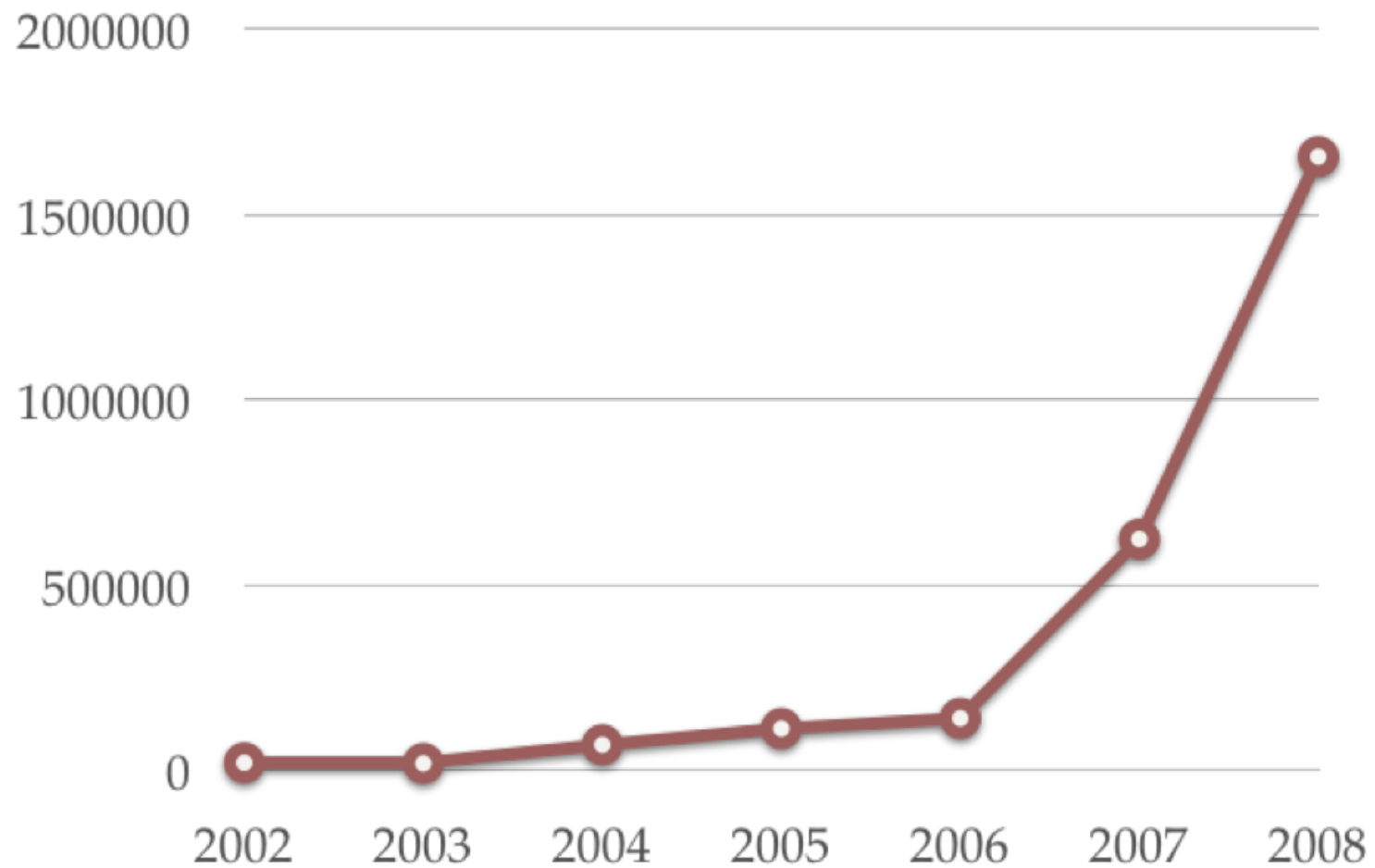
มัลแวร์

การแพร่กระจายมัลแวร์



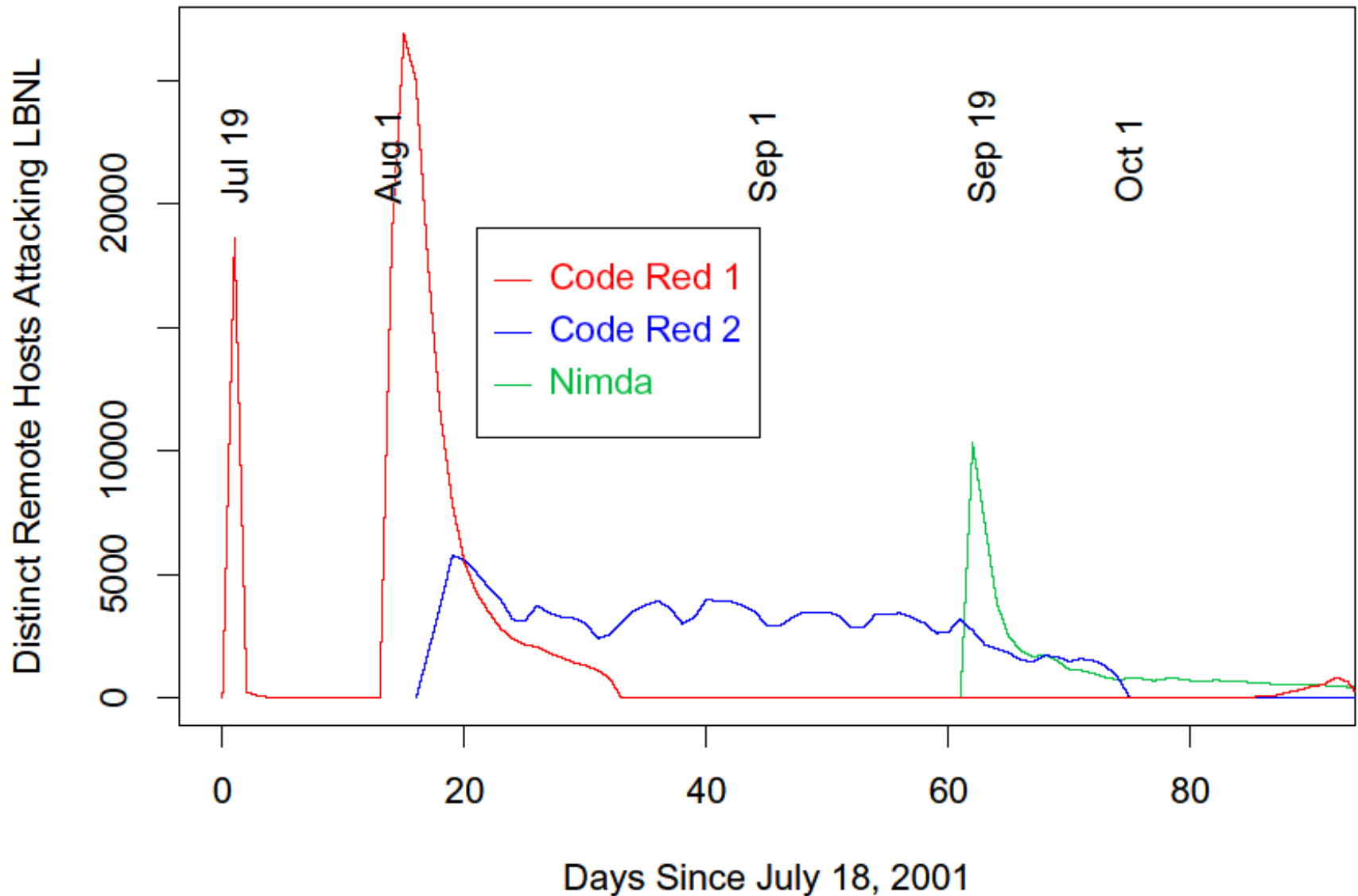
ที่มา: F-Sign: Automatic, Function-Based Signature Generation for Malware - Scientific Figure on ResearchGate. Available from: https://www.researchgate.net/figure/Distribution-of-malware-types_fig3_224177620 [accessed 15 Sept 2025]

Number of malware signatures



Symantec report 2009

ตัวอย่าง: การแพร่กระจายมัลแวร์



เทคนิคการโจมตีของไวรัส

- **วิศวกรรมซอฟต์แวร์ (Social Engineering)** : การโจมตีมักจะเกิดจากผู้เชี่ยวชาญทางคอมพิวเตอร์ หลอกล่อเป้าหมายคือผู้ใช้ทั่วไป
- **การโจมตีผ่านประตูหลัง (Backdoor)** : โปรแกรมมัลแวร์แอบสร้างช่องทางสื่อสารลับ ทำให้ผู้โจมตีทำการรีโมทเข้าทางช่องทางนี้
- **การขโมยบัญชีรายชื่ออีเมล** : เมื่อไวรัสเข้าสู่ระบบทำการแอบขโมยอีเมลที่เก็บในระบบ แล้วส่งอีเมลที่มีไวรัสออกไปโดยผู้ใช้ไม่รู้ตัว
- **การมีระบบส่งอีเมลในตัว** : ไวรัสที่สามารถส่งอีเมลที่มีไวรัสจำนวนมาก ๆ ด้วยตัวเอง ทำให้ตรวจสอบได้ยากเพราะดูเหมือนการส่งอีเมลปกติ
- **การใช้ประโยชน์จากช่องโหว่ของซอฟต์แวร์** : ไวรัสใช้ช่องโหว่ (บั๊ก, ข้อผิดพลาด) ของโปรแกรม เพื่อแพร่กระจายตัวเอง
- **การใช้ประโยชน์จากเทคโนโลยีอินเทอร์เน็ตใหม่ ๆ** : ผู้สร้างไวรัสอาศัยเครื่องมือบนอินเทอร์เน็ตที่กำลังนิยม เพื่อสำหรับการโจมตี

วิวัฒนาการของไวรัสคอมพิวเตอร์

ปี ค.ศ.	ชื่อไวรัส	อธิบาย
1969	ดาวิน (Darwin)	เป็นโปรแกรมเกมคอมพิวเตอร์ซึ่งถือว่าเป็นโปรแกรมที่มีรูปแบบคล้ายไวรัส สามารถสำเนาและทำลายตัวเอง มีจุดประสงค์ลบโปรแกรมคู่แข่ง
1970	ครีเปอร์ (Creeper)	ค้นพบในเครือข่าย APRAnet ไวรัสนี้ถือเป็นต้นแบบของไวรัสคอมพิวเตอร์ในปัจจุบันเพราะว่าสามารถแพร่กระจายผ่านเครือข่าย เมื่อติดไวรัสแล้วจะแสดงข้อความ "I'M THE CREEPER ... CATCH ME IF YOU CAN"
1974	Rabbit	ทำสำเนาตัวเองอย่างรวดเร็วไปในระบบเก็บข้อมูลของเมนเฟรม
1982	Elk Cloner	เป็นโปรแกรมไวรัสบนเครื่องพีซีตัวแรก มีการแพร่กระจายวงกว้างในห้องทดลองที่สร้างโปรแกรม (เขียนโดย Rich Skrenta) ติดไปกับโปรแกรม Apple DOS 3.3 ผ่านทาง Boot Sector มีผลให้หน้าจอแสดงผลกลับหัว ทำตัวอักษรกระพริบ
1983	-	Len Adleman เป็นผู้ตั้งคำว่า ไวรัส (Virus) คนแรก และ เฟรด โคเฮน (Fred Cohen) เป็นผู้ให้คำจำกัดความของ Virus Computer คนแรก และมีการสาธิตการทำงานของโปรแกรมไวรัส จึงถูกยกย่องให้เป็น บิดาแห่งไวรัสศาสตร์ (Virology)

วิวัฒนาการของไวรัสคอมพิวเตอร์

ปี ค.ศ.	ชื่อไวรัส	อธิบาย
1986	เบรน (Brain)	เป็นไวรัส Boot Sector สร้างโดย เบสิต ฟารุก และ อัมจาต ซึ่งเป็นไวรัสตัวแรกที่โจมตี MS-DOS ของเครื่อง IBM-PC นอกจากนี้ยังมีไวรัสชื่อ Verdem ซึ่งโจมตีไฟล์ Command.com และไวรัส PC-Write ซึ่งถือว่าเป็นโปรแกรมไวรัสประเภทโทรจันฮอรัส
1987	Lovechild หรือ Orphan	เป็นไวรัสที่ทำลายระบบคอมพิวเตอร์ส่วนบุคคลตัวแรกที่ทำงานเต็มระบบส่งผลกระทบทั่วโลก
1988	-	Peter Norton โปรแกรมเมอร์ที่เป็นผู้ก่อตั้งบริษัท Symantec พัฒนาโปรแกรมป้องกันไวรัส Norton-AntiVirus ออกขายในปี ค.ศ. 1991
ตุลาคม	Mr. RoChenle	เป็นโปรแกรมไวรัสประเภท HOAX ตัวแรก โดยอ้างถึงชื่อบุคคลที่ไม่มีตัวตน Mike RoChenle (Microchannel)
	Morris Worm	เป็นไวรัสประเภทเวิร์มตัวแรก แพร่กระจายบนเครือข่าย APANET จำนวนมากทำให้อินเทอร์เน็ตช้าอย่างมาก ทำให้ได้ก่อตั้งองค์กร CERT (www.cert.org) ขึ้น

วิวัฒนาการของไวรัสคอมพิวเตอร์

ปี ค.ศ.	ชื่อไวรัส	อธิบาย
1990	-	สมาคมนักพัฒนาไวรัสได้สร้างไวรัสประเภท Polymorphic Virus หรือเรียกว่า Chameleon หรือเรียกว่า Casper เป็นไวรัสที่ใช้เทคนิคการเข้ารหัสตัวเองเพื่อป้องกันการตรวจจับ และสามารถกลายพันธุ์ทุก ๆ ครั้งที่มีการสำเนาตัวเองใหม่ และมีไวรัส Tequila ซึ่งเป็นไวรัสประเภทนี้เกิดขึ้นตัวแรกที่มีการโจมตี
1992	Macro Virus	เป็นไวรัสที่แฝงตัวไปกับไฟล์ประเภท MS Office
1999	Mellissa	เป็นไวรัสที่แพร่กระจายผ่านอีเมลโดยอ่านอีเมลจาก MS Outlook
2000	I Love You	เขียนโดยนักเรียนชาวฟิลิปปินส์ คล้ายกับ Mellissa อาศัยอีเมลในการกระจายตัว
2001	- Code Red - Nimda	- เป็นเวิร์มที่ติดมากกว่าล้านเครื่องที่ใช้ MS Windows NT/2000 เซิร์ฟเวอร์ - คล้ายกับ Code Red โจมตี MS Windows แพร่กระจายได้มากที่ภายในเวลา 22 นาที
2003	- Slammer	- เป็นเวิร์มที่มีการแพร่กระจายได้เร็วที่สุดและติดหลายแสนเครื่องที่มีการติดตั้ง MS SQL Server นอกจากนี้ยังมีเวิร์มชื่อ Blaster หรือ Lovesan ที่สร้างขึ้นมาโจมตีช่องโหว่ของระบบ Windows

วิวัฒนาการของไวรัสคอมพิวเตอร์

ปี ค.ศ.	ชื่อไวรัส	อธิบาย
2004	- MyDoom - Sasser	- เป็นเวิร์มที่กระจายตัวได้เร็วที่สุด คล้ายการ Mellissa และ I Love You - เป็นเวิร์มที่โจมตีระบบ LSASS ของ MS Windows
2007	Zeus	เป็นเวิร์มที่ใช้เป็นเครื่องมือสร้าง Botnet เพื่อขโมยข้อมูลส่วนตัวของผู้ใช้
2009	Conficker หรือ Downup	เป็นเวิร์มที่โจมตีระบบ Windows ประมาณ 15 ล้านเครื่อง เป็นการอาศัยช่องโหว่ของระบบตรวจจับได้ยาก โดยจะสร้างซอมบี้เพื่อขโมยข้อมูลของผู้ใช้
2010	Alureon หรือ TDDS	เป็นมัลแวร์ประเภทโทรจัน และรูทคิตส์ ที่จะขโมยข้อมูลโดยการดักอ่านข้อมูลที่วิ่งผ่านเครือข่าย เน้นข้อมูล Username, Password และ Credit Card
2013	Cryptolocker	เป็นโทรจันเรียกค่าไถ่ โจมตีระบบ MS Windows เมื่อโจมตีระบบจะมีการเข้ารหัสไฟล์ในระบบ ด้วยรหัสแบบ RSA Public key โดย Private Key จะอยู่ที่ผู้สร้างมัลแวร์ แล้วมัลแวร์จะทำการเรียกค่าไถ่ โดยให้ผู้ใช้จ่ายเงินผ่าน Bitcoin หรือ Credit Card หากไม่จ่ายเงิน Cryptolocker จะทำการลบไฟล์นั้นทิ้ง แต่ถ้าจ่ายเงินผู้ใช้จะได้รับ Private Key ที่จะใช้สำหรับถอดรหัส

คุณลักษณะของมัลแวร์ในปัจจุบัน

■ ความเร็วในการโจมตี

- อาศัยเครื่องมือที่ทันสมัยในการค้นหาช่องโหว่ของเป้าหมาย และช่วยในการโจมตีด้วยความรวดเร็ว

■ ความซับซ้อนในการโจมตี

- มีการโจมตีครั้งเดียวมีหลายรูปแบบ ยากต่อการตรวจจับ
- เน้นการโจมตีบนโปรโตคอลที่ใช้งานทั่วไป

■ ความรวดเร็วในการค้นหาจุดอ่อน

- ระบบมีจุดอ่อนหรือช่องโหว่เพิ่มขึ้นเป็นสองเท่าทุกปี ทำให้ผู้พัฒนามีการออกแพตช์เพื่อปิดช่องโหว่เหล่านั้นไม่ทัน เช่น Zero-day Attack

■ การโจมตีแบบแยกกระจาย

- เป็นการโจมตีแบบช่วยกันโจมตีเป้าหมายเดียวกัน ทำให้ป้องกันและหยุดยั้งทำได้ยาก

■ ความซับซ้อนในการติดตั้งแพตช์

- การป้องกันที่ดีที่สุดคือการปิดช่องโหว่ของแอปพลิเคชันหรือระบบปฏิบัติการ ดังนั้นต้องมีความรู้ว่าจะติดตั้งแพตช์อะไร เมื่อไหร่

ประเภทของมัลแวร์

มัลแวร์ (Malware) หรือเรียกว่า Malicious Software หมายถึงโปรแกรมที่เป็นอันตรายต่อระบบคอมพิวเตอร์ สามารถแบ่งออกเป็น

- **โทรจันฮอर्स (Trojan Horse)**

- เป็นโปรแกรมที่ดูเหมือนมีประโยชน์ หรือไม่เป็นอันตรายแต่ภายในโปรแกรมจะแฝงโค้ดสำหรับใช้ประโยชน์จากผู้สร้าง หรืออาจทำลายระบบที่รันโปรแกรมนี้

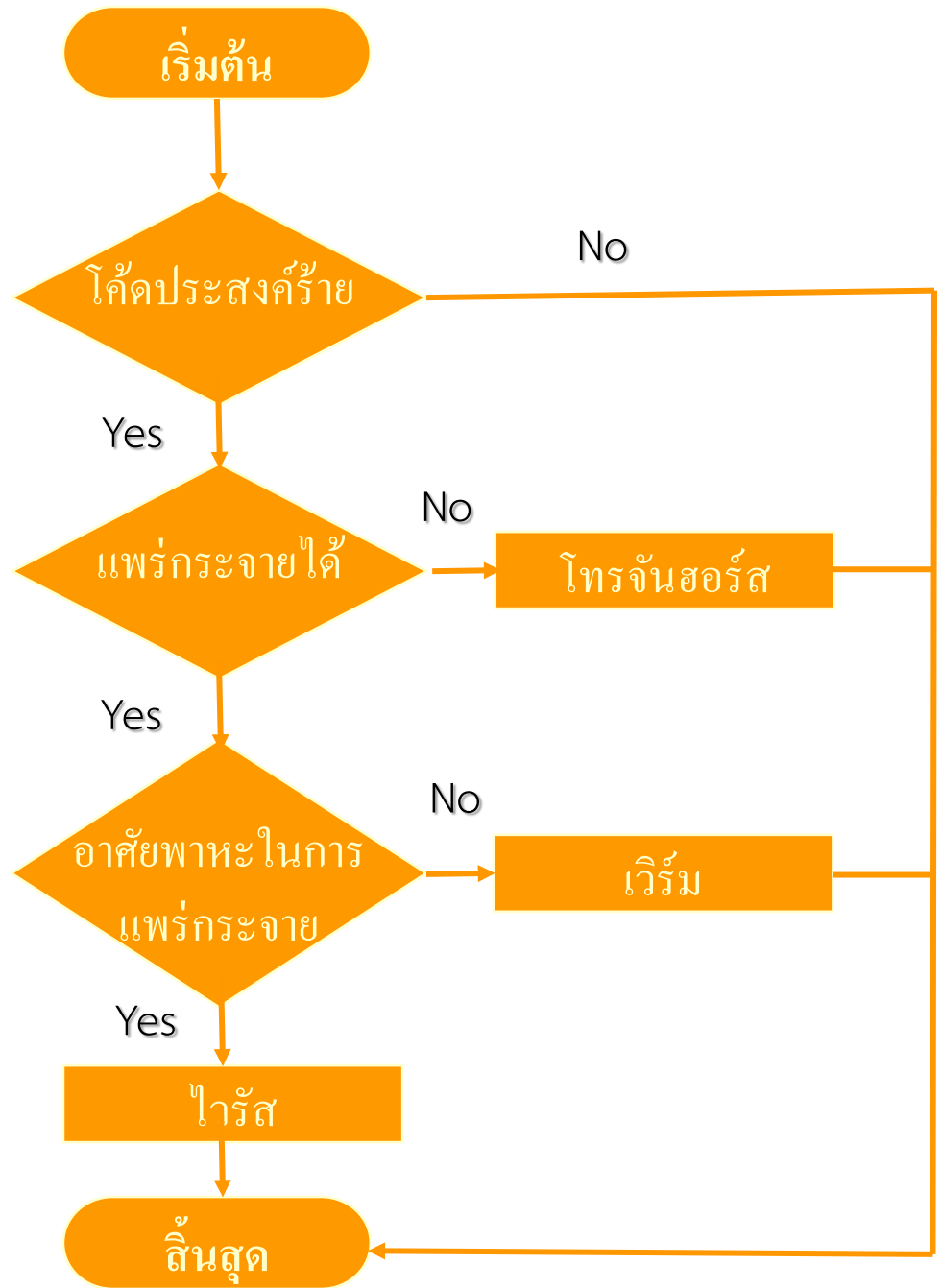
- **เวิร์ม (Worm)**

- คุณสมบัติของเวิร์มคือ ความสามารถกระจายตัวเอง โดยไม่ต้องอาศัยโปรแกรมอื่นในการแพร่กระจายไปยังเครื่องคอมพิวเตอร์เครื่องอื่น ๆ ผ่านทางเครือข่าย อันตรายของเวิร์ม เช่น การใช้รีซอร์สระบบ หรือ DoS เพื่อให้ระบบทำงานไม่ได้ และบางกรณียังสามารถทำลายระบบได้ด้วย

- **ไวรัส (Virus)**

- เป็นโปรแกรมที่ติดจากไฟล์หนึ่งไปอีกไฟล์หนึ่ง หรือไปยังเครื่องคอมพิวเตอร์เครื่องอื่น ๆ โดยการแนบตัวเองไปกับโปรแกรมหรือไฟล์อื่น
- จะทำงานเมื่อมีการรันโปรแกรมหรือไฟล์ที่ติดไวรัส อาจทำลายฮาร์ดแวร์ ซอฟต์แวร์ หรือข้อมูล และทำให้กระจายไปยังเครื่องอื่น หรือบางทีก็สร้างโค้ดใหม่

แผนผังแยกแยะมัลแวร์



คุณลักษณะของโปรแกรมมัลแวร์

- **โทรจันฮอर्स (Trojan Horse)**
 - ไม่จัดเป็นไวรัสหรือเวิร์มเพราะว่าไม่สามารถแพร่กระจายด้วยตัวเอง โทรจันฮอर्सที่เป็น Payload ของเวิร์มและไวรัส เรียกว่า **ดรอปปิง (Dropping)**
- **RAT (Remote Access Trojan)**
 - เป็นโปรแกรมที่สร้างแบ็คดอร์ ให้แฮกเกอร์เข้ามาในระบบ เพื่อขโมยข้อมูลหรือควบคุมระยะไกล
- **แบ็คดอร์ (Backdoor)**
 - แบ็คดอร์หรือประตูหลัง เป็นช่องทางพิเศษที่ใช้เข้าถึงระบบโดยไม่ต้องผ่านกระบวนการพิสูจน์ทราบตัวตน
- **รูทคิตส์ (Rootkits)**
 - เป็นชุดโปรแกรมที่แฮกเกอร์นิยมใช้สำหรับเจาะระบบ เพื่อควบคุมระบบหรือขโมยข้อมูล เช่น โปรแกรมเฝ้าดูคีย์สโตรค (Key Stroke) หรือโปรแกรมสำหรับการดูแลระบบหรือการมอร์นิเตอร์
- **เวิร์ม (Worm)**
 - มักจะพยายามคัดลอกตัวเองไปไว้ในระบบแล้วใช้ช่องทางเครือข่ายแพร่กระจายตัวเองไปยังเครือข่ายอื่น เช่น Sasser Worm ใช้ช่องช่องโหว่ของเซิร์ฟเวอร์วินโดวส์ ในการแพร่กระจายตัวเอง

คุณลักษณะของโปรแกรมมัลแวร์

■ ไวรัส (Virus)

- เป็นโปรแกรมที่คัดลอกตัวเองให้เป็นส่วนหนึ่งของไฟล์เอกสาร หรือ Boot Sector ของดิสก์ เพื่อให้สามารถกระจายตัวเอง

■ โจ๊กแอปพลิเคชัน (Joke Application)

- เป็นซอฟต์แวร์ที่ออกแบบมาเพื่อสร้างความสนุกสนาน หรือแยะที่สุดก็เพียงเพื่อให้เสียเวลา

■ โฮกซ์ (Hoaxes)

- เป็นโปรแกรมที่สร้างขึ้นเพื่อหลอกให้ผู้ใช้ทำบางอย่างให้ โดยจะใช้เทคนิคทางด้านวิศวกรรมสังคม (Social Engineering) จะไม่มีชุดคำสั่งประสงค์ร้ายใด ๆ นอกจากแค่ต้องการหลอกเท่านั้น

■ สแกมส์ (Scams)

- สแกมส์ หมายถึง การใช้ช่องทางการสื่อสารโดยผู้ประสงค์ร้าย พยายามหลอกให้คนอื่นช่วยเหลือตัวเองในการทำอาชญากรรมบนอินเทอร์เน็ต โดยอาจใช้เว็บไซต์หรืออีเมลหลอกเหยื่อ บางครั้งเรียกว่า ฟิชซิง (Phishing) หรือ แบรินด์สปูฟิง (Brand Spoofing) หรือการ์ดดิ้ง (Carding)

■ สเปน (Spam)

- คือการส่งอีเมลจำนวนมากโดยมีจุดประสงค์เพื่อการโฆษณาสินค้าหรือบริการ แต่บางครั้งอาจใช้เพื่อแพร่กระจายไวรัส เวิร์ม และมัลแวร์อื่น ๆ ได้ด้วย

คุณลักษณะของโปรแกรมมัลแวร์

■ สปายแวร์ (Spyware)

- อาจเรียกว่า สปายบ็อต (Spybot) หรือแทร็คกิ้งซอฟต์แวร์ (Tracking Software) เป็นโปรแกรมที่ใช้บางอย่างเพื่อลวงตา แต่ทำกิจกรรมบางอย่างในเครื่องคอมพิวเตอร์โดยไม่ได้รับความยินยอมจากผู้ใช้ สปายแวร์มักจะเก็บข้อมูลส่วนตัวของผู้ใช้ การปรับเปลี่ยนค่าในเบราว์เซอร์ เป็นต้น

■ แอดแวร์ (Adware)

- เป็นโปรแกรมโฆษณาสินค้าซึ่งจะเปิดป๊อปอัพวินโดว์ มันจะเป็นฟรีซอฟต์แวร์ และฝังตัวอยู่เนื่องจากได้รับความยินยอมจากผู้ใช้ บางครั้งอาจเป็นสปายแวร์ด้วย (ไม่ผิดกฎหมาย)

■ อินเทอร์เน็ตคุกกี้ (Internet Cookies)

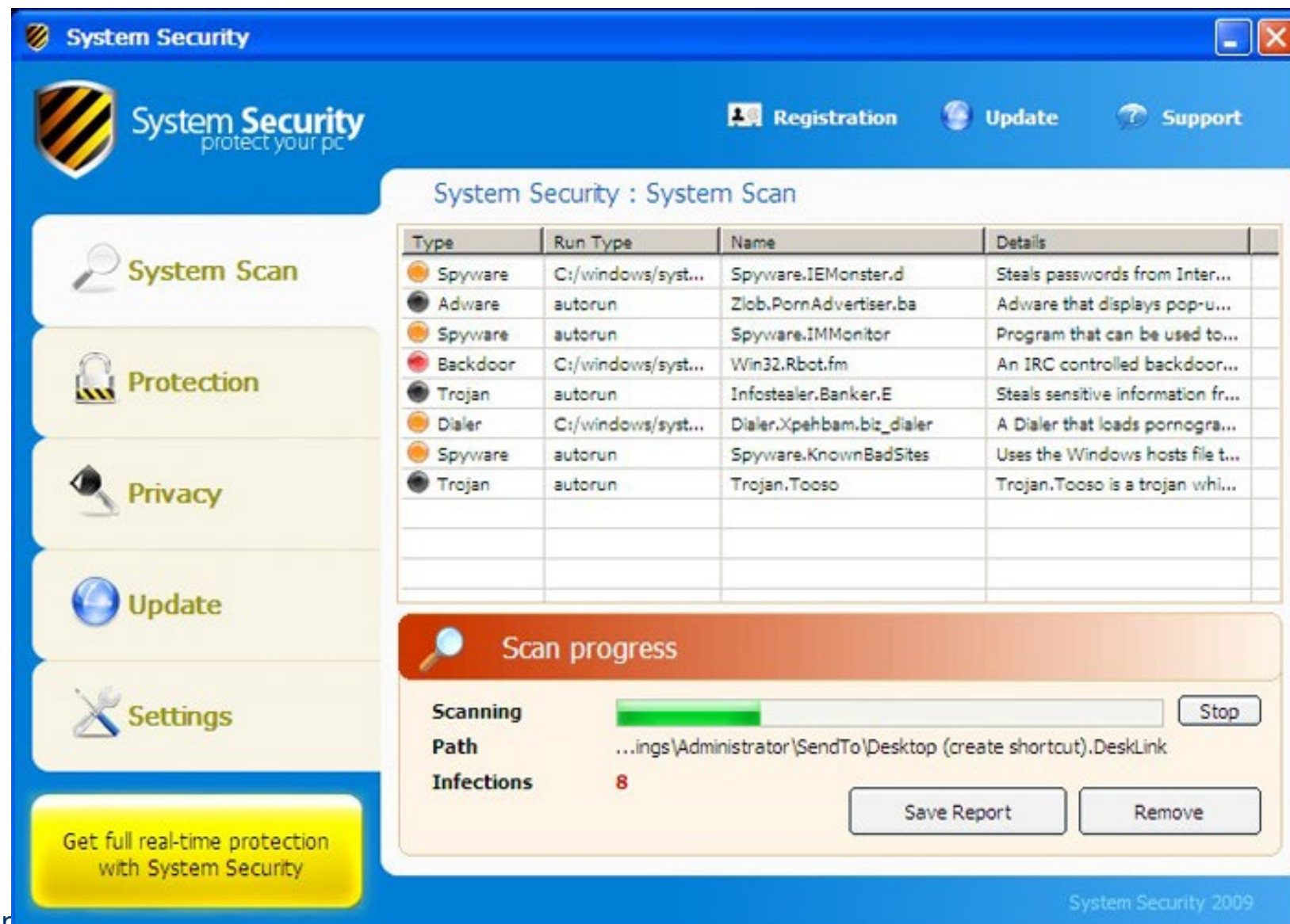
- คือเท็กสไฟล์ที่เก็บไว้ที่เครื่องคอมพิวเตอร์ของผู้ใช้โดยเว็บไซต์ที่เข้าไปเยี่ยมชม คุกกี้จะเก็บข้อมูลบางอย่างที่เว็บไซต์นั้นจะใช้เมื่อครั้งหน้าที่ผู้ใช้เข้าไปเยี่ยมชมอีกครั้ง มักจะเป็นข้อมูลส่วนตัวผู้ใช้

Adware

The image is a collage of various web advertisements and pop-ups, illustrating the concept of adware. The ads include:

- BT - Microsoft Internet Explorer**: Free connection, Free modem. Click here to find out more.
- Advertisement - Xerox - Microsoft Internet Explorer**: Enter to WIN! WIN an \$11,000 USD Business Upgrade Package or a Xerox Phaser® 8400 Color Printer. World's fastest color printer for under \$1,000 USD. Phaser 8400 Color Printer \$999.
- INSWEB**: Lower your insurance costs.
- Special Offer - Try AOL Free! - Microsoft Internet Explorer**: Before you go, did you know... You can add AOL® for Broadband to any high-speed cable or DSL connection! Works with and enhances any basic high-speed connection. Built-in protection for you and your family. The best on-demand and exclusive programming online. GET A FREE TRIAL! Up to 45 days FREE. Click here for details.
- Click Here**: Address, Folders, Units.
- Home-Owners Click Here**: AMERIQUEST MORTGAGE COMPANY®.
- What's New Netscape - Microsoft Internet Explorer**: Science Proves It: Drinking Causes... Teen Girls Beware: Popular Boys Do THIS Look What Was Found in Stone Age Cave Strange Space Object Mystery Deepens Did You See What Bush Dared to Wear? If You Get This E-Mail Scam, Delete It.
- PC WORLD - 15 FREE GIFTS! - Microsoft Internet Explorer**: TRY 2 RISK-FREE ISSUES! GET 15 FREE.
- Are You Paying Too Much?**: Lower your cost, not your expectations.
- UndertoneNetworks.com - Microsoft Internet Explorer**: Rates are at Historic Levels. Get cash back on your home loan.
- SpecificPOP Network - Microsoft Internet Explorer**: TRAVELZOO™. This Week's Top 10 on the Internet. Released APRIL 14, 2001. Song CheapCaribbean.com.
- ReliaQuote**: A better way to buy life insurance.
- Take this free test!**: Ticker: IQ and Personality Tests - Tickle.com: The Classic IQ Test! - Microsoft Internet Explorer.

Fake antivirus



คุณสมบัติของมัลแวร์

- **คุณสมบัติของเป้าหมาย** : ประเภทอุปกรณ์ ระบบปฏิบัติการ แอปพลิเคชัน
- **พาหะนำมัลแวร์** : Executable File, Script, Macros, Boot Sector
- **กลไกการแพร่กระจาย** : Removable media, Network shares, Network scanning, E-mail, Remote exploit
- **สื่อที่ใช้สำหรับการแพร่ระบาด** : เครือข่ายภายนอก, คอมพิวเตอร์ของผู้มาเยือน, เอ็กเซ็กคิวทีฟไฟล์, ไฟล์เอกสาร, อีเมล, มีเดียเก็บข้อมูล
- **เพย์โหลด** : Backdoor, Data Corruption or Deletion, Information Theft, DoS, DDoS, Network DoS เป็นต้น
- **การจุดชนวน** : Manual execution, Semi-automatic execution, Automatic execution, Time bomb, Conditional
- **กลไกการป้องกันตัวเอง** : Armor, Stealth, Encryption, Oligomorphic, Polymorphic
- **วงจรชีวิตของมัลแวร์** : การค้นพบช่องโหว่, การพัฒนา, การแพร่ระบาด, การทำลาย, การตรวจพบและแจ้งเตือน, การตรวจจับ, การป้องกันและกำจัด

มัลแวร์ที่มีชื่อเสียง

- SQLSlammer // ปี 2003 เวิร์มโจมตี SQLServer
- W32.Sasser.Worm //โจมตี registry สั่งรีสตาร์ททุก ๆ 30 วินาที
- [W32.Mydoom.BB@mm](#) //เดินทางไปทางอีเมล เพย์โหลดจะสร้าง backdoor
- [W32.Netsky.B@mm](#) //แพร่กระจายทาง SMTP และแชร์ไฟล์
- [W32.Blackmal.E@mm](#) //แพร่กระจายทาง SMTP และแชร์ไฟล์
- Win32/Conficker //หรือ Downup โจมตี service (SVCHOST.EXE) ทำให้เครื่องเซิร์ฟเวอร์โอเวอร์โหลด
- CryptoLocker //มัลแวร์เรียกค่าไถ่ หรือเรียกว่า Ransomware

แนวทางการป้องกันมัลแวร์

- การตรวจจับมัลแวร์
 - Signature Scanning
 - การสแกนหาคุณลักษณะเฉพาะ
 - การมอนิเตอร์พฤติกรรม
- ซอฟต์แวร์ป้องกันไวรัส
- การป้องกันไวรัสที่เครื่องไคลเอนต์
 - การลบโปรแกรมที่ไม่ได้ใช้งาน
 - การอัปเดตแพตช์
 - การติดตั้งโฮสต์เบสไฟร์วอลล์
- การป้องกันไวรัสที่เครื่องเซิร์ฟเวอร์

แนวทางการป้องกันมัลแวร์

- การป้องกันมัลแวร์ในระดับเครือข่าย
 - ติดตั้ง IDS
 - ติดตั้งไฟร์วอลล์
 - การบล็อกเว็บไซต์

Signature inference

PACKET HEADER

SRC: 11.12.13.14.3920 DST: 132.239.13.24.5000 PROT: TCP

PACKET PAYLOAD (CONTENT)

00F0 90 90 90
0100 90 90 90M?.w
0110 90 90 90cd.....
0120 90 90 90 90 90 90 90 90 90 90 90 90
0130 90 90 90 90 90 90 90 90 EB 10 5A 4A 33 C9 66 B9ZJ3.f.
0140 66 01 80 34 0A 99 E2 FA EB 05 E8 EB FF FF FF 70 f..4.....p
...

Kibvu.B signature captured by
Earlybird on May 14th, 2004



End.